

IBM RACF Security Impact Forecasting by using IBM zSecure

Bill White

Mike Riches

Elijah Swift

Jeroen Tiggelman

Scott Woolley

Tom Zeelandelaar



IBM Z

Security



IBM Redbooks

**IBM RACF Security Impact Forecasting by using IBM
zSecure**

May 2025

Note: Before using this information and the product it supports, read the information in “Notices” on page vii.

First Edition (May 2025)

This edition applies to IBM z/OS 3.1 (product number 5650-ZOS) and IBM zSecure Admin 3.1.1 (product number 5655-ABB).

© Copyright International Business Machines Corporation 2025. All rights reserved.

Note to U.S. Government Users Restricted Rights -- Use, duplication or disclosure restricted by GSA ADP Schedule Contract with IBM Corp.

Contents

Notices	vii
Trademarks	viii
Preface	ix
Authors	ix
Now you can become a published author, too!	xi
Comments welcome	xi
Stay connected to IBM Redbooks	xi
Chapter 1. Tightening access controls with confidence	1
1.1 IBM Z security challenges	2
1.2 Hardening practices	2
1.2.1 Zero trust	2
1.2.2 The principle of least privilege	3
1.2.3 Role-based access control	3
1.3 IBM Z security layers	3
1.3.1 External security managers on z/OS	3
1.3.2 RACF	4
1.4 A phased approach	4
1.4.1 Defining new security rules to strengthen security	4
1.4.2 Removing unused security definitions	5
1.4.3 Establishing role-based access control	5
1.4.4 Keeping defined privileges in the environment to a minimum	5
1.5 Lesser-known features in IBM zSecure Admin	5
1.5.1 zSecure Admin Access Monitor	6
1.5.2 zSecure Admin RACF-Offline	6
1.5.3 The Access Monitor function in zSecure Admin	6
Chapter 2. IBM zSecure capabilities for IBM Resource Access Control Facility administrators	7
2.1 IBM zSecure Admin for RACF administrators	8
2.2 zSecure Access Monitor	10
2.2.1 Possible uses for zSecure Access Monitor	10
2.2.2 Access Monitor environment	11
2.3 zSecure RACF-Offline	15
2.3.1 Testing the RACF database cleanup with RACF-Offline	15
2.4 General preparation steps for the use cases	16
2.4.1 Creating a RACF-Offline database	16
2.4.2 Starting a RACF-Offline session	17
2.4.3 Logging on to the RACF-Offline session	19
2.4.4 Resetting the RACF-Offline log data set	20
2.4.5 Starting and preparing your zSecure Admin session	20
2.5 Further access monitor capabilities	22
Chapter 3. Adding a set of profiles	27
3.1 Challenges with adding new resource profiles	28
3.2 Steering clear of default security settings	28
3.3 Temporarily allowing access for new resources or applications	28
3.4 Adding profiles for extra security checking	29

3.4.1 Analyzing statistics and discovering missing RACF resource profiles	29
3.4.2 Defining a RACF resource profile in the RACF-Offline database	35
3.4.3 Simulating Access Monitor data against the offline RACF database	39
Chapter 4. Removing unused security definitions.	57
4.1 Challenges with unused RACF definitions	58
4.2 Keeping the RACF database orderly and maintained.	58
4.2.1 Addressing inactive users	58
4.2.2 Addressing unused groups	59
4.2.3 Addressing users with outdated group connections	59
4.2.4 Removing unused resource profiles	60
4.3 Ensuring that only the required authorization is in place.	60
4.4 Removing unused resource profiles	60
4.4.1 Generating RACF commands to clean up resource profiles.	61
4.4.2 Running generated RACF commands to clean up resource profiles	64
4.4.3 Recovering deleted resource profiles	68
4.4.4 Reporting the potential security impact of deleted unused RACF profiles	71
4.4.5 Cleaning up unused profiles from the active primary RACF database	79
4.4.6 Cleaning up other unused security definitions from the active primary RACF database.	82
Chapter 5. Converting generic and specific access to group-based access	85
5.1 Challenges with generic and specific access permissions	86
5.2 Moving toward role-based access control.	86
5.2.1 Minimizing the usage of universal and generic permissions.	87
5.2.2 Minimizing the usage of personalized permissions.	87
5.2.3 Minimizing the assignment of the OPERATIONS attribute	88
5.2.4 Minimizing the usage of the WARNING attribute	88
5.2.5 Minimizing the usage of global access checking tables	89
5.3 Establishing groups that accurately reflect user roles.	89
5.4 Converting to group-based access	90
5.4.1 Reporting successful access that is allowed through the UACC setting.	90
5.4.2 Converting generic UACC access to group-based access.	94
5.4.3 Reporting the effect of the UACC conversion commands.	100
5.4.4 Reporting successful access through ID(*)	108
5.4.5 Converting generic ID(*) access to group-based access	112
5.4.6 Converting generic OPERATIONS access to group-based access	120
Chapter 6. Minimizing access control privileges	129
6.1 Challenges with access control privileges.	130
6.2 Avoiding the need to trust privileged users	130
6.2.1 Permitting higher access levels is a poor security practice.	130
6.2.2 Minimizing the usage of overly permissive RACF attributes.	131
6.2.3 Minimizing the usage of the WARNING attribute	131
6.2.4 Minimizing the usage of global access checking tables	131
6.3 Revealing permitted access levels that exceed a need	132
6.4 Minimizing access control privileges	132
6.4.1 Reporting the historical permitted DATASET access levels that exceed the used access levels	132
6.4.2 Implementing least privilege for the DATASET class	137
6.4.3 Verifying the permit commands for the DATASET class.	144
6.4.4 Running permit commands against the active primary RACF database.	148
6.4.5 Reporting permitted general resource access levels that exceed the used access levels.	153

Abbreviations and acronyms	157
---	------------

Notices

This information was developed for products and services offered in the US. This material might be available from IBM in other languages. However, you may be required to own a copy of the product or product version in that language in order to access it.

IBM may not offer the products, services, or features discussed in this document in other countries. Consult your local IBM representative for information on the products and services currently available in your area. Any reference to an IBM product, program, or service is not intended to state or imply that only that IBM product, program, or service may be used. Any functionally equivalent product, program, or service that does not infringe any IBM intellectual property right may be used instead. However, it is the user's responsibility to evaluate and verify the operation of any non-IBM product, program, or service.

IBM may have patents or pending patent applications covering subject matter described in this document. The furnishing of this document does not grant you any license to these patents. You can send license inquiries, in writing, to:

IBM Director of Licensing, IBM Corporation, North Castle Drive, MD-NC119, Armonk, NY 10504-1785, US

INTERNATIONAL BUSINESS MACHINES CORPORATION PROVIDES THIS PUBLICATION "AS IS" WITHOUT WARRANTY OF ANY KIND, EITHER EXPRESS OR IMPLIED, INCLUDING, BUT NOT LIMITED TO, THE IMPLIED WARRANTIES OF NON-INFRINGEMENT, MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE. Some jurisdictions do not allow disclaimer of express or implied warranties in certain transactions, therefore, this statement may not apply to you.

This information could include technical inaccuracies or typographical errors. Changes are periodically made to the information herein; these changes will be incorporated in new editions of the publication. IBM may make improvements and/or changes in the product(s) and/or the program(s) described in this publication at any time without notice.

Any references in this information to non-IBM websites are provided for convenience only and do not in any manner serve as an endorsement of those websites. The materials at those websites are not part of the materials for this IBM product and use of those websites is at your own risk.

IBM may use or distribute any of the information you provide in any way it believes appropriate without incurring any obligation to you.

The performance data and client examples cited are presented for illustrative purposes only. Actual performance results may vary depending on specific configurations and operating conditions.

Information concerning non-IBM products was obtained from the suppliers of those products, their published announcements or other publicly available sources. IBM has not tested those products and cannot confirm the accuracy of performance, compatibility or any other claims related to non-IBM products. Questions on the capabilities of non-IBM products should be addressed to the suppliers of those products.

Statements regarding IBM's future direction or intent are subject to change or withdrawal without notice, and represent goals and objectives only.

This information contains examples of data and reports used in daily business operations. To illustrate them as completely as possible, the examples include the names of individuals, companies, brands, and products. All of these names are fictitious and any similarity to actual people or business enterprises is entirely coincidental.

COPYRIGHT LICENSE:

This information contains sample application programs in source language, which illustrate programming techniques on various operating platforms. You may copy, modify, and distribute these sample programs in any form without payment to IBM, for the purposes of developing, using, marketing or distributing application programs conforming to the application programming interface for the operating platform for which the sample programs are written. These examples have not been thoroughly tested under all conditions. IBM, therefore, cannot guarantee or imply reliability, serviceability, or function of these programs. The sample programs are provided "AS IS", without warranty of any kind. IBM shall not be liable for any damages arising out of your use of the sample programs.

Trademarks

IBM, the IBM logo, and ibm.com are trademarks or registered trademarks of International Business Machines Corporation, registered in many jurisdictions worldwide. Other product and service names might be trademarks of IBM or other companies. A current list of IBM trademarks is available on the web at “Copyright and trademark information” at <https://www.ibm.com/legal/copytrade.shtml>

The following terms are trademarks or registered trademarks of International Business Machines Corporation, and might also be trademarks or registered trademarks in other countries.

CICS®	IBM Z®	System z®
Db2®	RACF®	z/OS®
IBM®	Redbooks®	
IBM Security®	Redbooks (logo)  ®	

The following terms are trademarks of other companies:

The registered trademark Linux® is used pursuant to a sublicense from the Linux Foundation, the exclusive licensee of Linus Torvalds, owner of the mark on a worldwide basis.

UNIX is a registered trademark of The Open Group in the United States and other countries.

Other company, product, or service names may be trademarks or service marks of others.

Preface

To guard against future cyberattacks efficiently, you should have a simple process to predict the impact of changes that are made to your security definitions. Security impact forecasting can provide a streamlined workflow in which historical data is captured automatically, and an intuitive interface enables you to set up security adaptations in a way that they can be quickly analyzed for effect and, when deemed correct, applied automatically.

In the context of IBM Resource Access Control Facility (RACF®), changes to existing access control definitions can be done in a proactive way with confidence by using IBM zSecure Admin. IBM zSecure Admin capabilities can help you assess and build stronger access controls against cyberthreats, rather than just reacting to them after they happen.

This IBM Redbooks® publication explores the value of analytics for security impact forecasting regarding RACF and IBM zSecure Admin (RACF-Offline and the Access Monitor functions). Use cases, best practices, and step-by-step guidance with examples are provided.

This publication is for IT Managers and Security Architects who are responsible for the technology that protects their assets, and the change management staff and security administrators who are responsible for the safeguarding applications and data from unauthorized access.

The reader is expected to have a basic understanding of IT security concepts and the principle of least privilege in a zero trust framework.

Authors

This book was produced by a team of specialists from around the world working at IBM Redbooks, Poughkeepsie Center.

Bill White is an IBM Redbooks Project Leader and Senior IT Infrastructure Specialist at IBM Poughkeepsie, New York.

Mike Riches is a Senior Technical Support Specialist who is based in the United Kingdom. He has 13 years of in-depth experience with mainframe security software, and worked with and supported mainframe networking software before his current role. Mike has worked at IBM® for nearly 23 years. His areas of expertise include IBM zSecure, IBM Z® Security and Compliance Center, and IBM Security® Key Lifecycle Manager for IBM z/OS®. He knows RACF, Access Control Facility 2 (ACF2), and Top Secret external security managers (ESMs). He is an author of other IBM Redbooks publications about IBM z/OS Communications Server and IBM Communication Controller for Linux on IBM System z®.

Elijah Swift is a Back-end Software Developer who is based in the US. He has 4 years of experience with mainframe security software, having previously worked elsewhere in both mainframe software and security engineering. Elijah has been with IBM for 5 years, supporting and working with various mainframe software and products. He holds a masters degree in electrical and computer engineering from the State University of New York at Binghamton. Elijah's area of expertise is RACF, having worked both as a technical support specialist for RACF and as a co-lead developer of the Python interface to the RACF CLI, which is an open-source Python library that users may use to administer their RACF environments in Python. As a part of these efforts, he has written extensively on RACF and its use.

Jeroen Tiggelman is a Senior Software Engineer who is based in the Netherlands. He has 29 years of experience in developing zSecure, and has been the zSecure development manager since 2001. Jeroen has been working for IBM since the company acquired Consul Risk Management in 2007. He holds two masters degrees in discrete mathematics and theoretical computer science from the University of Leiden. His areas of expertise include zSecure, RACF, and security principles. Jeroen supervised the creation of the first zSecure Alert User Reference Manual in 2003 and wrote the introduction sections to the zSecure CARLa Auditing and Reporting Language (CARLa) Command Language.

Scott Woolley is a z/OS software engineer who is based in IBM Poughkeepsie in the US. He was a member of the RACF development team for over 20 years, focusing on the areas of security auditing, cryptography, digital certificates, and identity mapping. Scott performs cybersecurity testing and analysis with the z/OS Secure Engineering team.

Tom Zeehandelaar is a zSecure Software Developer and Senior Technical Enablement Specialist. He joined IBM in January 2007 as part of an acquisition of Consul Risk Management where he worked as a zSecure instructor and Security Consultant since December 2000. Tom works for the IBM Security zSecure development team that is based in Delft, the Netherlands. He is responsible for maintaining and building the compliance evaluation framework that the IBM Security zSecure Audit product supports. Other responsibilities include the development, maintenance, and delivery of IBM Security zSecure training courses. In addition, Tom is occasionally involved in pre- and post zSecure sales activities, z/OS security health checks, and second-level zSecure client support. Before joining Consul Risk Management, Tom spent 13 years working for KLM (Royal Dutch Airlines) in various IT roles, with the last 10 years there as a Security Officer for the MVS-OS/390 platform. His expertise includes information security, security administration, z/OS auditing, and business continuity planning processes.

Thanks to the following people for their contributions to this project:

Hans Schoone
Chief Architect, IBM zSecure

Michael Zagorski
Program Director, IBM Z Security

Now you can become a published author, too!

Here's an opportunity to spotlight your skills, grow your career, and become a published author—all at the same time! Join an IBM Redbooks residency project and help write a book in your area of expertise, while honing your experience by using leading-edge technologies. Your efforts help to increase product acceptance and customer satisfaction, as you expand your network of technical contacts and relationships. Residencies run from two to six weeks in length, and you can participate either in person or as a remote resident working from your home base.

Find out more about the residency program, browse the residency index, and apply online at:

ibm.com/redbooks/residencies.html

Comments welcome

Your comments are important to us!

We want our books to be as helpful as possible. Send us your comments about this book or other IBM Redbooks publications in one of the following ways:

- ▶ Use the online **Contact us** review Redbooks form found at:

ibm.com/redbooks

- ▶ Send your comments in an email to:

redbooks@us.ibm.com

- ▶ Mail your comments to:

IBM Corporation, IBM Redbooks
Dept. HYTD Mail Station P099
2455 South Road
Poughkeepsie, NY 12601-5400

Stay connected to IBM Redbooks

- ▶ Find us on LinkedIn:

<https://www.linkedin.com/groups/2130806>

- ▶ Explore new Redbooks publications, residencies, and workshops with the IBM Redbooks weekly newsletter:

<https://www.redbooks.ibm.com/subscribe>

- ▶ Stay current on recent Redbooks publications with RSS Feeds:

<https://www.redbooks.ibm.com/rss.html>



Tightening access controls with confidence

Minimizing the risk of a data breach starts with controlling who can access specific resources. This chapter presents key concepts and standard security practices for granting access to the IBM Z platform. Some fundamental access control use cases are sketched, and a brief description of lesser-known components of IBM zSecure Admin is provided.

The following topics are covered in this chapter:

- ▶ 1.1, “IBM Z security challenges” on page 2
- ▶ 1.2, “Hardening practices” on page 2
- ▶ 1.3, “IBM Z security layers” on page 3
- ▶ 1.4, “A phased approach” on page 4
- ▶ 1.5, “Lesser-known features in IBM zSecure Admin” on page 5

1.1 IBM Z security challenges

Today, several trends make IBM Z security an urgent topic of attention. Many of the world's critical business data is managed and stored on IBM Z servers. Therefore, the mainframe is becoming the biggest target for bad actors, both external and internal to the organization. Although IBM Z is the most securable platform in the industry, you must help ensure that it is properly configured and that all security-related capabilities are used.

Where in the past organizations trusts that the mainframe was safe, today there are more compliance regulations that are in place to prove it. As a result, it is necessary to explain clearly why particular people have access to resources.

Also, the security skills that are needed to manage the environment are unique, and finding the right skilled personnel is a challenge.

At a minimum, the following tasks are essential for restricting access to only those users and tasks that need it:

- ▶ Obtaining relevant data representing all the required accesses
- ▶ Summarizing and consolidating this data to keep analysis manageable
- ▶ Provide security impact forecasting on the proposed security definition changes

For more information, see 2.2.2, “Access Monitor environment” on page 11 and 2.3.1, “Testing the RACF database cleanup with RACF-Offline” on page 15.

1.2 Hardening practices

As you evaluate your security policy and consider changes that can further secure or harden your environment, consider industry standard practices for managing security policies. The practices that are described in this document are underpinned by core security principles, namely the idea of *zero trust* and one of its core components *least privilege*, and role-based access control (RBAC).

1.2.1 Zero trust

In the past, security management sometimes relied on securing a system's perimeter. In recent years, the consensus is that the right assumption to make is that the perimeter might be compromised, so any access done by any user or process to any resource must always be verified. This approach is known as a *zero trust architecture*, as described in the National Institute of Standards and Technology (NIST) special publication [SP 800-207](#).

In simple terms, a zero trust architecture is designed to trust nothing and no one until their identity and authorization are confirmed. There are several core components to a zero trust architecture that z/OS enforces on its own. The ideas of “continuous” and “strict” authentication where the system regularly and for each request validates a user's access is managed by the system itself, except for application-based settings like user authorization caching, which are beyond the scope of this document.

1.2.2 The principle of least privilege

Zero trust implies that no access must be allowed before a user or process has authenticated, and access controls must allow only access that is required for the user or process to do their job. This requirement is known as the *principle of least privilege*.

Risks can further be mitigated by encrypting sensitive data: Even if someone can get at the data store, they cannot use the data unless they also obtain the key to decrypt the data.

A security administrator takes a more active role in enforcing the ideas of least privilege and “no implicit trust” as a part of a zero trust environment. No implicit trust means that, in the overarching term of zero trust, no user or agent (like a started task or job) shall be assumed to have access to the environment. You see in later chapters of this publication how to avoid or minimize generic accesses and authorities that contradict this principle. Also, least privilege means that accesses and authorities that are granted to users and agents are strictly limited to the privileges that allow the user to perform their job. You also see in later chapters some strategies to explicitly minimize privileges and eliminate authorities that go unused to maintain a least privilege environment.

1.2.3 Role-based access control

Helping ensure strong authentication through approaches like multi-factor authentication and data encryption schemes are relatively simple to set up. Maintaining the principle of least privilege can be far more difficult. One reason making it difficult is determining why access was granted in the past.

RBAC is an approach where access is never granted directly to a user, but rather to a particular access control group that represents the job role that a user is assigned. If the user moves to another job role, they can be removed from the role group, which helps ensure that no individual user permissions continue to exist for a task that are no longer required.

Access monitoring is still required because it is also possible that a particular task is no longer performed by a certain job role.

1.3 IBM Z security layers

The security capabilities that are incorporated into the IBM Z stack consists of several layers. For example, at the hardware level, encryption, secure key management, and tamper-resistant technology are available. At the operating system level, many security measures are built in, and the access decisions can be routed to an external security manager (ESM), such as IBM Resource Access Control Facility (RACF). The administration of security rules normally happens in a security database package, like in RACF.

1.3.1 External security managers on z/OS

Security starts at the hardware level, where pages of storage can be read/written only by processes that have the right permissions for them. This approach is in principle controlled by the operating system. The term *trusted computing base* is used for the overall environment that helps ensure secure operations.

When an application that is part of the trusted computing base is asked to perform a certain operation, it must verify that the user or process that is requesting it has the right level of access that is granted for the request. In z/OS, these verifications are directed to the System Authorization Facility (SAF), which asks the question, “Does identity “x” have access type “y” on resource “z?” The answer can be Yes, No, or Not known, after which the application decides whether to perform the operation or refuse it.

The SAF interface passes the request to a security package that contains the access rules. This package might be RACF or another ESM.

1.3.2 RACF

A central part of RACF is the security database, which contains security rules that define the identities and access to resources. The RACF term for a logical record in the database is *profile*.

There are four profiles:

- ▶ USER profiles describe the users and tasks, what attributes that they might have, and the means of authentication.
- ▶ GROUP profiles group users so that access to the resources can be permitted to members of a group. Adding a user to a group grants them the access that they group is granted.
- ▶ DATASET profiles describe the access rules for accessing datasets.
- ▶ General RESOURCE profiles control access to non-dataset resources. These profiles exist in many different classes for different kinds of resources.

A user or group can be granted a certain access level to a data set or resource profile that controls the protection of a set of resources. In RACF, access types are hierarchical, so someone with the access level UPDATE also has the access level READ.

It is also possible to grant access to everyone. There are two types of this access:

- ▶ Access that is granted to ID(*) requires that the identity of the requester is known.
- ▶ Universal access (UACC) grants access to nonauthenticated tasks.

Furthermore, there is also a global access table (GAT) that can specify that a certain level of access to a resource can be granted without consulting the database.

The overall system is flexible, but for managing security with confidence, it is a best practice to establish groups for clear functional purposes, and minimize granting both global and individual accesses.

1.4 A phased approach

Later chapters describe best practices for RACF environments that apply to the following sample activities that administrators may perform as they manage their environments. Together, they provide a phased approach for tightening your security with confidence.

1.4.1 Defining new security rules to strengthen security

When you know that access is needed for a particular user or role to a particular resource that is serviced by a more generic definition, it might make sense to define a specific profile for this access that satisfies that need and not grant wider access concurrently.

You can do this task as a first step to remove the particular function from the more generic rule, which might then become redundant. As a next step, you can reduce the access that is granted to the more generic profile.

When a new application or function must be established, they should be implemented in such a way that no more access is granted than required.

For more information, see Chapter 3, “Adding a set of profiles” on page 27.

1.4.2 Removing unused security definitions

When you have a full representative set of security access requests in use, you can use this set to identify security definitions that are not in active use. They should be removed to strengthen security.

For more information, see Chapter 4, “Removing unused security definitions” on page 57.

1.4.3 Establishing role-based access control

If you can group individual users into role groups, you can replace permissions for individuals with permissions that are managed by groups that represent user roles. Use this approach to maintain least privilege when users move to a different role, and to make auditing and proving compliance more efficient.

For more information, see Chapter 5, “Converting generic and specific access to group-based access” on page 85.

1.4.4 Keeping defined privileges in the environment to a minimum

After implementing the actions in the previous sections, run periodic verifications that permitted accesses are still needed.

For more information, see Chapter 6, “Minimizing access control privileges” on page 129.

1.5 Lesser-known features in IBM zSecure Admin

IBM zSecure Admin can boost productivity for RACF administrators. Its best-known feature is a user interface (UI) where you can change permissions and RACF commands. However, zSecure Admin has other features that are pertinent for hardening your security posture.

1.5.1 zSecure Admin Access Monitor

By using the Access Monitor component, you can observe all access requests that are posed to RACF, whether they are logged or not. This function is important because logging all access requests to the System Management Facilities (SMF) might be so voluminous that it is prohibitive to do so. Conversely, Access Monitor consolidates all identical requests that are performed during a certain interval into a single record, indicating the access request and the number of times that it occurred.

With Access Monitor, you can capture a full year's worth of access data and still use the data for analysis. You have good confidence that you captured all accesses that normally occur. (You must be aware of emergency measures that might have to be in place but are not normally used.)

1.5.2 zSecure Admin RACF-Offline

You can use the RACF-Offline component to direct standard RACF commands to a database that is not the active security database, which means that you can build a RACF command stream to adapt security definitions and set up a database with the changes without these changes immediately impacting the active security definitions.

1.5.3 The Access Monitor function in zSecure Admin

You can use the AM option in the zSecure Admin interface to work with ACCESS data to analyze it and evaluate historic accesses against a different RACF database.

If you set up your adjusted security database by using RACF-Offline, you can run an analysis to see what impact your proposed security changes have, which means that you can develop confidence in the command stream that is being built to change your security environment.

The ACCESS and RACF_ACCESS report types that are used by the AM menu are part of the CKRCARLA program, also known as the CARLa Auditing and Reporting Language (CARLa) engine. You may do this analysis by using a batch job.

For more information about the IBM zSecure Admin (Access Monitor and RACF-Offline) capabilities, see Chapter 2, “IBM zSecure capabilities for IBM Resource Access Control Facility administrators” on page 7.



IBM zSecure capabilities for IBM Resource Access Control Facility administrators

Managing the security and risk of your IBM Z stack and external security managers (ESMs) can sometimes seem like a daunting task. However, the IBM zSecure portfolio is equipped to help overcome that challenge by automating security administrative tasks for helping increase efficiency and reduce errors, detecting internal and external threats, issuing near-real-time alerts, and monitoring for compliance.

This chapter explains how specific IBM zSecure Admin capabilities can help build confidence in making access control decisions and policy changes to IBM Resource Access Control Facility (RACF). It also highlights the preparation steps that are needed to use those capabilities.

The following topics are covered in this chapter:

- ▶ 2.1, “IBM zSecure Admin for RACF administrators” on page 8
- ▶ 2.2, “zSecure Access Monitor ” on page 10
- ▶ 2.3, “zSecure RACF-Offline” on page 15
- ▶ 2.4, “General preparation steps for the use cases” on page 16
- ▶ 2.5, “Further access monitor capabilities” on page 22

2.1 IBM zSecure Admin for RACF administrators

As shown in Figure 2-1, there are several tools that are offered with the [IBM zSecure portfolio](#). This chapter concentrates only on a subset of the IBM zSecure portfolio that pertains to RACF administrator tasks, namely the IBM zSecure Admin capabilities.

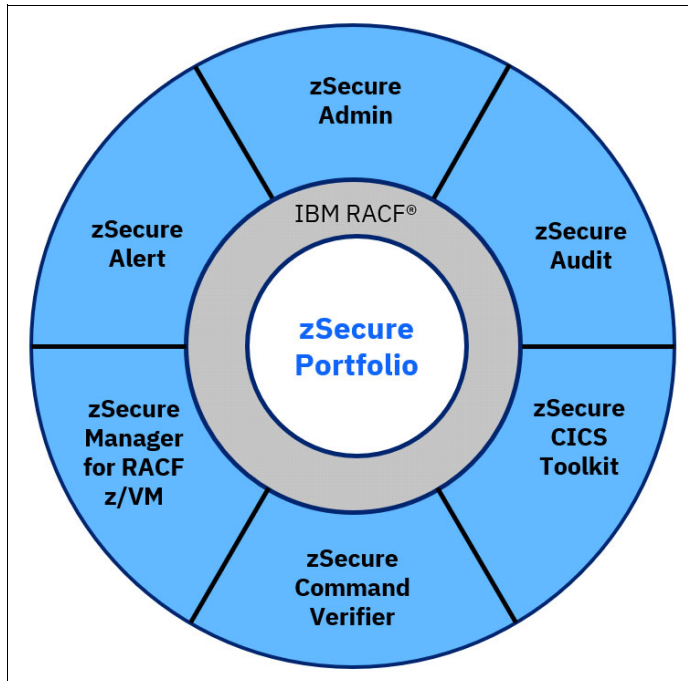


Figure 2-1 IBM zSecure portfolio overview

zSecure Admin provides a layer on top of RACF and extends the functions so that users can enter and process administrative commands quickly, generate custom reports, and clean up security databases. zSecure Admin enables RACF administrators to identify and analyze problems in RACF to prevent mistakes before they become a threat, which instills confidence in RACF administrators. zSecure Admin also provides administrative authority in a granular fashion so that users have only the specific amount that is required for their job.

zSecure Admin provides many other features. For example:

- ▶ You can administer multiple systems through a single application interface.
- ▶ You can monitor privileged users to help ensure that old accounts are properly deleted.
- ▶ You can compare profiles and report changes that occurred over time, or report differences between profiles with the same name that is defined in different security databases.
- ▶ You can copy or move users, groups, resources, applications, or entire databases between systems and rename IDs within the same database.
- ▶ You can merge profiles from different databases. zSecure Admin performs extensive consistency checks and reports potential conflicts before generating commands, helping ease the burden of consolidation efforts.

In addition to increasing productivity and avoiding unintentional changes, zSecure Admin can also act as a training aid for security administrators who are unfamiliar with RACF because they can learn about administration from the RACF commands that zSecure Admin generates.

zSecure Admin includes a multi-purpose program that is called CKRCARLA. It is a router program that calls the CARLa Auditing and Reporting Language (CARLa) processing program or engine to request reports.¹

The CKRCARLA program is used by many zSecure components to process data, including the zSecure Access Monitor task C2PACMON. For more information about C2PACMON, see 2.2.2, “Access Monitor environment” on page 11.

zSecure Admin has a comprehensive ISPF user interface (UI) with a breadth of RACF administration functions (see Figure 2-2).

zSecure Admin - Main menu		
Option====>		More: +
SE	Setup	Options and input datasets
RA	RACF	RACF Administration
U	User	User information
G	Group	Group information
D	dataset	dataset profiles
R	Resource	General resource profiles
S	Settings	Setropts, RRSF, and class settings
H	Helpdesk	One-panel helpdesk options
Q	Quick admin	Quick User Administration
1	Access	Access Check
2	Queued	Display and action on profiles with QUEUED commands
3	Reports	Reports with profiles and resources
4	Mass update	Specify mass copy/re-create/delete actions
5	RACDCERT	Work with certificates, key rings, filters and tokens
C	Custom	Custom report
AU	Audit	Audit security and system resources
RE	Resource	Resource protection reports
AM	Access	RACF Access Monitor
CR	Command review	Review and run commands
CO	CARLa	Work with CARLa queries and libraries
IN	Information	Information and documentation
LO	Local	Locally defined options

Figure 2-2 zSecure Admin ISPF user interface Main menu

IBM zSecure Admin includes the following components that are the focus of this book:

- Access Monitor, which can be used to collect and present information about actual usage of RACF resource profiles.
- RACF-Offline, which adds the ability to issue most RACF commands against an inactive RACF database to independently test changes.

¹ CARLa is a programming language where users generate audit reports and perform security administration tasks. CARLa programming is not a skill that zSecure beginners are expected to perform. It is often seen as one of the more advanced skills that seasoned zSecure users learn when using zSecure functions and features. Alternatively, users can attend the 3-day [IBM Security zSecure CARLa Audit and Reporting Language course](#) to learn the fundamentals of CARLa programming.

2.2 zSecure Access Monitor

zSecure Access Monitor was originally designed to provide the information that was required to enable effective RACF database cleanup. However, the data that is collected to provide this function also provides more usage capabilities that are described in 2.2.1, “Possible uses for zSecure Access Monitor” on page 10.

To achieve the primary goal of effective RACF database cleanup, you need complete access to information, meaning that the data that is collected must represent all RACF access request events. System Management Facilities (SMF) might be a possible data source, but it is incomplete because RACF writes only SMF records where auditing events are enabled. It is possible to enable auditing at the RACF class level, but then the SMF data is too large. The data must also cover a suitable period, that is, the more data that is collected, the higher level of confidence that you can have in making the right decision. There will also be many duplicate access events over time, so the design of Access Monitor copes with that situation by using a consolidation process. In summary, RACF access event data is collected by Access Monitor in addition to, and not instead of, SMF records.

More recently, zSecure Access Monitor was enhanced to capture information about many z/OS UNIX file system events. The information is captured at the full path level, and not at the directory level. You can also use specific access events, such as RACF VERIFY (RACINIT), for alerting through zSecure Alert, for example, alert 1122 when a site-defined sensitive user ID logs on.

These functions are not described here. For more information, see the [IBM zSecure documentation](#).

2.2.1 Possible uses for zSecure Access Monitor

Some of the possible usage examples of zSecure Access Monitor are as follows:

- ▶ RACF database cleanup
- ▶ Access restructure
- ▶ Performing ad hoc queries to evaluate profiles and access

RACF database cleanup

The access event information that is collected over time enables zSecure Admin to generate commands to clean up unused or obsolete definitions from your RACF database. These definitions the following ones:

- ▶ Access control lists (ACLs): Remove unused permits on ACLs.
- ▶ Connects: Remove unused group connects.
- ▶ Profiles: Remove unused profiles.

RACF administrators and analysts can also use Access Monitor data to test resource profiles and access rights by running simulations against a candidate RACF database. You can prepare the candidate database by using zSecure Admin RACF-Offline or a database on another z/OS system where you intend to host production processes.

Access restructure

The access event information that is collected over time enables you to restructure access definitions with the goal of tightening security by helping ensure that you follow the security principles of “least privilege” access and “zero trust”.

Examples of restructuring access are as follows:

- Convert usage of universal access (UACC) to access through a group.
- Convert use of ID(*) to access through a group.
- Convert OPERATIONS access to access through an ACL.
- Split batch applications by using a single user ID to use multiple user IDs based on job names.

Performing ad hoc queries to evaluate profiles and access

Using the Access Monitor function, you can monitor access events and collect the data for reporting and analysis. From the reports, you can view and analyze the resource profile and access usage.

2.2.2 Access Monitor environment

The Access Monitor environment requires that several building blocks are in place to collect and record the access event data that is required to perform a RACF database cleanup and generate reports. Figure 2-3 shows an overview of components that make up the Access Monitor environment.

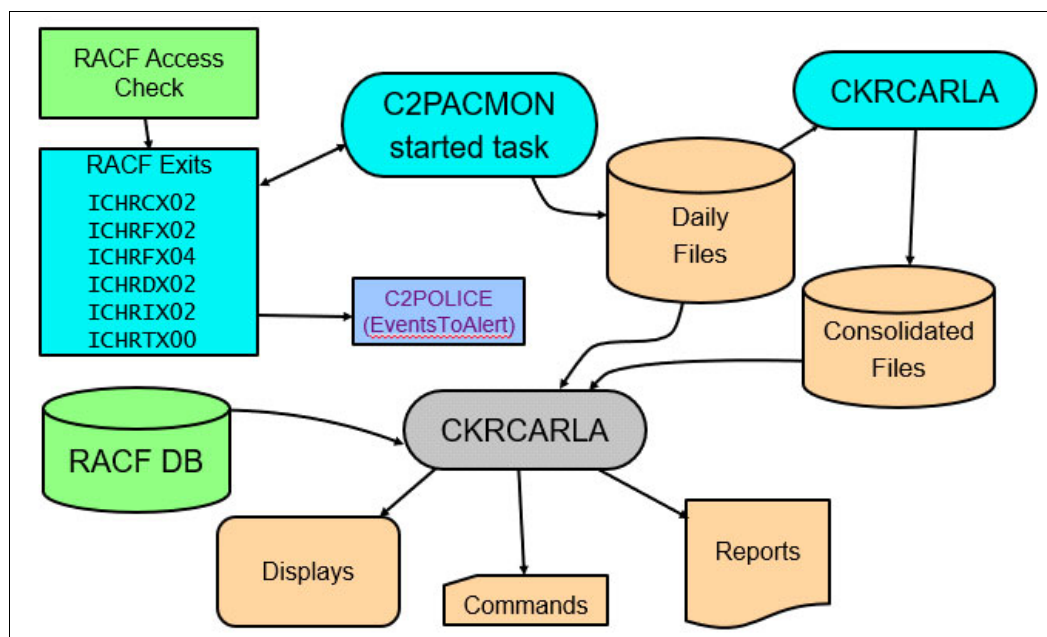


Figure 2-3 Schematic overview of the Access Monitor environment

The access event data is collected by dynamically loaded RACF post-processing exits. The exit code runs in the user address space where the RACF access requests occur. You do not need to concern yourself with the management of these exits unless your maintenance levels or release of zSecure change.

The Access Monitor started task, which by default is called C2PACMON, must be started on each LPAR to record the RACF access event request data. C2PACMON dynamically loads the required RACF post-processing exits when it starts and removes them when it stops. The data that is collected by the RACF exits is written from in-memory buffer space by C2PACMON by using the CKRCARLA program, which combines the collected records and writes them to an LPAR-specific daily collection data set. Each type of access event is saved in a corresponding access record, representing the access from a user to a resource. Once per day, the data from the collection data set or datasets is automatically consolidated into a single, LPAR-specific daily consolidation data set. The data set attributes for the daily collection and daily consolidation datasets are configured during the implementation of Access Monitor.

You can use batch jobs to consolidate these daily consolidation datasets into weekly, monthly, quarterly, or yearly summaries. Any of these datasets can be used as input to zSecure Admin with an input dataset type of ACCESS. In consolidated ACCESS datasets, only one record of information is stored per unique set of values. When the same user ID accesses the same resource in the same class with the same access level 500 times on the same system, these 500 access events are stored as one record in the ACCESS dataset. This consolidated record contains the timestamp of the last occurrence, system, user ID, resource, class name, access level, and a counter that indicates that this access occurred 500 times. This Access Monitor specific consolidation process is the reason why the size of ACCESS data sets is manageable.

Users process the consolidated access data by running ad hoc queries to evaluate the profile usage and access data. You can set up and run processing interactively by using the options that are available on the Access Monitor menu in the zSecure Admin UI. The access data is processed by using CKRCARLA. Two CARLA report types are available for this purpose:

- ▶ The ACCESS report type uses the Access Monitor records to report the collected events.
- ▶ The RACF_ACCESS report type shows profiles in the RACF database and annotates these profiles with usage data from the Access Monitor records.

zSecure Admin ISPF user interface

The zSecure Admin ISPF UI provides many Access Monitor menu options to report on access event data and automate the generation of cleanup commands. The AM – RACF Access Monitor menu options are shown in Figure 2-4.

zSecure Admin - Access		
Option====> _____		
1	Access	Access summary by user or profile
2	Compare	Compare monitored access against current RACF database
3	Permit usage	Permit usage information for current RACF database
4	Connect usage	Connect usage information for current RACF database
5	Profile usage	Profile usage information for current RACF database
6	Member usage	Member usage information for current RACF database
7	Global usage	Global usage summary for current RACF database
8	Remove	Remove unused profiles and authorizations
9	Cleanup	Remove permits, dataset, and general resource profiles
V	ID verify	ID verification (logon/start/job-start) summary
I	ID usage	ID usage information for current RACF database
U	Unix events	Access summary for unix events by user, uid/gid, or path

Figure 2-4 Access Monitor menu options

Use menu option AM.1 to select and report historic access events from the allocated access monitor records, as shown Figure 2-5 on page 13.

zSecure Admin - Access - Access

Command ==> _____

Show records that fit all of the following criteria:

User ID _____ (User ID or EGN mask)

Complex _____ (complex or EGN mask)

SAF resource class . . _____ (class or EGN mask)

SAF resource name . . . _____

RACF match on _____

Advanced selection criteria

_ Further selection _ Date selection _ Current RACF DB selection

Output/run options

1 1. Summary by User ID

2. Summary by member class and profile

3. Summary by simulated authorization used

4. Summary by simulated groups used for access

_ Show configured fields _ Show simulated fields _ Timezone (U/L/H)

_ Print format _ Customize title _ Send as e-mail

_ Background run _ Full page form

Figure 2-5 AM.1 menu option

In the “Output/run options” section, you can specify how you prefer the layout and content to be produced. zSecure Admin supports four different summary layouts:

- **Summary by User ID**
 Produces an access overview of all historic access events and decisions that were collected in the allocated access monitor records, which are summarized by the user ID that was involved in the access decision. If “Show simulated fields” is also selected, the detailed output includes a section that is titled “Current RACF database effect”, showing the authority path as simulated from the allocated RACF database.
- **Summary by member class and profile**
 Produces an access overview of all historic access events and decisions that were collected in the allocated access monitor records, which are summarized by resource class and profiles. If “Show simulated fields” is also selected, the detailed output includes a section that is titled “Current RACF database effect” that shows the authority path as simulated from the allocated RACF database.

► Summary by simulated authorization used

Produces an access overview of all historic access events and decisions that were collected in the allocated access monitor records, which are summarized by the simulated authority that allows or disallows that access based on the allocated RACF database source. The access event records do not contain all the possible authority paths because that information is not available from the RACF post-processing exits that are used by Access Monitor to collect the data. This simulation summary determines the authority path from the allocated RACF database and summarizes the output by the simulated authorization method.

► Summary by simulated groups used for access

Produces an access overview of all historic access events and decisions that were collected in the allocated access monitor records, which are summarized by the group connection that allow or disallow that access based on the allocated RACF database source. The access event records do not contain the group connect information because that information is not available from the RACF post-processing exits that are used by Access Monitor to collect the data. This simulation summary determines the group connects from the allocated RACF database and summarizes the output by the simulated groups that are used for access.

The detailed examples of converting access that are shown in later chapters use different summary options that are best suited to the individual use case.

Figure 2-6 shows an example of reporting on the summarized access for user ID CRMBMJ2 by using menu option AM.1.

IBM Security zSecure ACCESS summary						Line 1 of 18
Command ==>					Scroll==> CSR_	
Access monitor records for User IDs like CRMBMJ2						
Occurrence	User ID	Name		First occurrence		Last occurrence
41911	CRMBMJ2	FRED SMITH		27Oct2023 05:45		27Sep2024 10:39
Occurrence	Intent	Type	RetAll	AccRC		
3476	READ	Auth		0		
491	READ	Auth		4		
48	READ	Auth		8		
198	READ	Fast				
28	READ	Fast		0		
13	UPDATE	Auth		0		
12	UPDATE	Auth		8		
7	DEFDELETE	Define		0		
7	ALTER	Auth		0		
2	ALTER	Auth		8		
37629	ALTER	Auth	RetAll	8		

Figure 2-6 Access Monitor Access Summary overview report

You can use the Access Monitor menu options to generate commands to clean up unused accesses or profiles from the RACF database. This process is described in more detail in later chapters.

For more information about how to implement zSecure Access Monitor, see the [zSecure product documentation](#).

2.3 zSecure RACF-Offline

RACF-Offline is a component of zSecure Admin that you can use to run and test RACF commands on a RACF database that is not active in the system. By using this function, you can test changes to RACF definitions without impacting any other software that is running on the system and without using a dedicated test system.

Using RACF-Offline, you can direct all RACF commands to an offline, or inactive, RACF database. RACF access verifications are not affected and are still performed against the system's active primary RACF database. Thus, the RACF-Offline environment applies only to RACF commands that are used to change the Offline RACF database's security definitions.

You can use the offline RACF database as an input selection within the zSecure Admin UI, and zSecure Admin can generate the RACF commands that are required to make the changes. Alternatively, RACF-Offline can run in a batch job to process the RACF commands that are specified as input.

For more information about how to implement zSecure RACF-Offline, see the [zSecure documentation](#).

2.3.1 Testing the RACF database cleanup with RACF-Offline

You can use Access Monitor with RACF-Offline to generate commands to clean up your RACF database, and then run those commands against an offline RACF database. You can then run a simulation of historic access events against the updated offline RACF database to test the results of the cleanup.

Figure 2-7 depicts a high-level overview of the components that make up the Access Monitor and RACF-Offline testing environment.

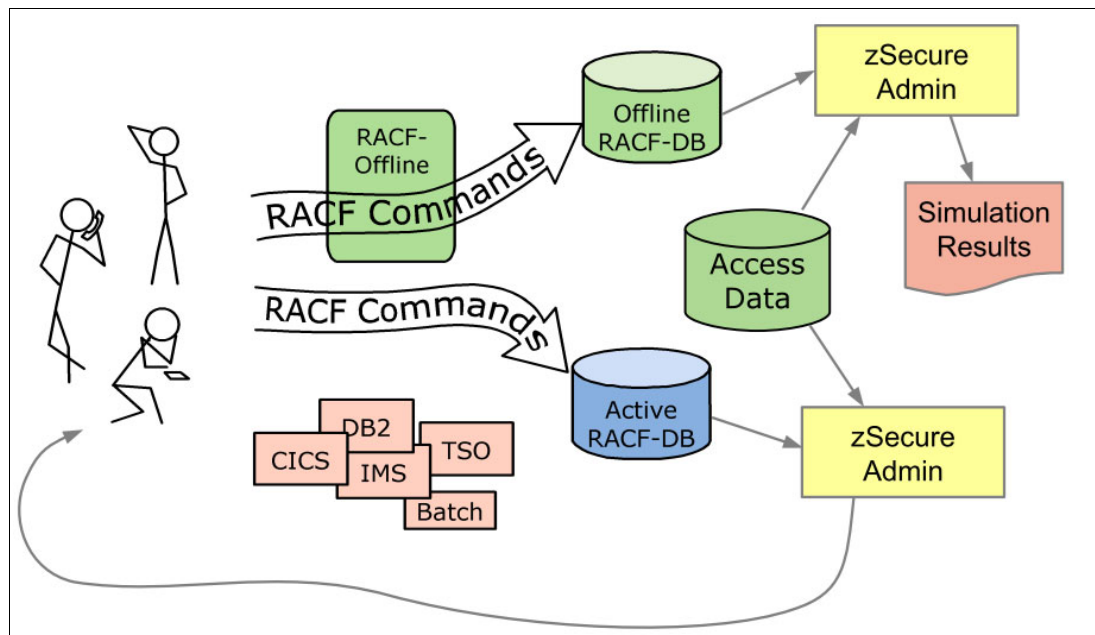


Figure 2-7 Schematic overview of Access Monitor and RACF-Offline testing environment

To clean up unused definitions in the FACILITY class, complete the following steps:

1. Create a copy of the pertinent RACF database that is ready to be used for a RACF-Offline session.
2. Start RACF-Offline with the appropriate parameters.
3. Start zSecure Admin and select an input set that contains ACCESS, CKFREEZE, and RACF sources.
4. Analyze the profile and permit usage of the FACILITY class.
5. Generate and run commands to clean up unused FACILITY class profiles and permits.
6. End the RACF-Offline session.
7. Start a zSecure Admin session.
8. Use the Access Monitor compare option to analyze the effects of cleanup commands.
9. When all is OK, you can run the cleanup commands against the live RACF database.

This process is described in more detail in later chapters.

2.4 General preparation steps for the use cases

The use cases that are presented in later chapters require the preparation steps that are outlined in this section. The steps are detailed here as a central reference.

- ▶ Creating a RACF-Offline database
- ▶ Starting a RACF-Offline session
- ▶ Logging on to the RACF-Offline session
- ▶ Resetting the RACF-Offline log data set
- ▶ Starting and preparing your zSecure Admin session

2.4.1 Creating a RACF-Offline database

When you intend to test running RACF cleanup commands against a RACF-Offline database, a good start is to copy the RACF primary or active backup database to a data set that you can use as an offline database. RACF supports the IRRUT200 utility, which you can use to create a backup of the primary RACF database. Figure 2-8 is sample batch job to create a RACF-Offline database that can be used for cleaning up unused security definitions.

```
//Add a valid job card for your environment here!
/*-----*/
//COPY      EXEC PGM=IRRUT200
//SYSRACF   DD DISP=SHR,DSN=<name of RACF primary/backup database>
//SYSUT1    DD DSN=<name of RACF offline database>,
//           DISP=SHR
//*         DCB=(LRECL=4096,RECFM=F),
//*         SPACE=(CYL,(300)),DISP=(NEW,CATLG),
//*         UNIT=3390
//SYSUT2    DD SYSOUT=*
//SYSPRINT  DD SYSOUT=*
//SYSIN     DD DUMMY
```

Figure 2-8 Sample batch job to create a RACF-Offline database

Customize this job with the following definitions:

- ▶ Add a job card that is valid to run in your system environment.
- ▶ Supply the data set name of the RACF primary or active backup database that you want to copy to the RACF-Offline database.
- ▶ Specify the data set name of the RACF-Offline database.

If you must allocate a new data set for the RACF-Offline database, comment out DISP=SHR and uncomment the dataset attribute lines that are shown as comments. Adjust the SPACE specification if required. You can verify the space that the primary RACF database uses and specify the same space allocation for your RACF-Offline database.

When you run cleanups regularly, it might be a best practice to schedule a periodic batch job that creates a fresh copy of the primary RACF database in a time slot when the system is not heavily used.

2.4.2 Starting a RACF-Offline session

To run the cleanup commands against the offline RACF database that you created or refreshed in 2.4.1, “Creating a RACF-Offline database” on page 16, you may use RACF-Offline in batch or interactively. This book documents the interactive usage of TSO commands with RACF-Offline.

Important: To enable RACF-Offline to run as a TSO command, the TSO authorized commands list must be updated. If you have not done this task, you see the message IKJ56500I COMMAND B8RACF NOT FOUND. The optional steps to update the [TSO authorized commands list](#) is required for the examples that are shown in the later chapters.

When RACF-Offline is installed, you can use the default options module that is named B8R0PT to configure the default RACF-Offline database, log datasets, and SMF processing options. You use the command B8RACF on the TSO ready prompt to activate RACF-Offline. Pressing Enter starts the RACF-Offline session by using the options from the module B8R0PT as configured (see Figure 2-9).

```
READY
b8racf
B8R100I B8RACF version 3.1.0
B8R274I RACF DB to be used is CRMB.T.RACF.OFFLINE
B8R268I LOG data set to be used is CRMB.T.RACF.OFFLINE.B8RLOG
B8R304I New SMF-ID:$B8R
B8R121I Completed processing B8R0PT options module
B8R200A Enter RACF Command or "END"
```

Figure 2-9 RACF-Offline started with the default configuration

The various B8RxxxI informational messages report the configured offline RACF database name, the name of the log data set, and SMF-ID to use for the SMF records that are generated during your RACF-Offline session. The purpose of the LOG data set is to collect the RACF commands that you run during your RACF-Offline session. A different SMF-ID is configured to distinguish SMF records that are written during your RACF-Offline session from the SMF records of the ‘live’ system to avoid confusion between actual and RACF-Offline triggered SMF records.

When you are satisfied with the predefined configuration, you can continue with the logon command for RACF-Offline, which is described in 2.4.3, “Logging on to the RACF-Offline session” on page 19.

Steps to override the default configuration settings for RACF-Offline

If you prefer to work with a different RACF-Offline configuration, you can override the default RACF-Offline settings that are configured by the systems programmer by using either of the following optional steps:

- Use a prepared B8RPARM member.

You can prepare a member that contains the RACFDB, LOGDS, and SMF ID parameters and the values that you prefer to use during your RACF-Offline session. Figure 2-10 shows what that member might look like.

```
VIEW          CRMB.T.ZSECURE.TESTLIB(B8RPARM) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
001200 RACFDB 'CRMB.T.RACF.OFFLINE'
001210 LOGDS 'CRMB.T.RACF.OFFLINE.B8RLOG'
***** ***** Bottom of Data *****
```

Figure 2-10 Sample B8RPARM member configuration

Use the command that is shown in Figure 2-11 to allocate your prepared RACF-Offline parameter member before you start a RACF-Offline session.

```
READY
alloc fi(b8rparm) da('crmb.t.zsecure.testlib(b8rparm)')
READY
b8racf
B8R100I B8RACF version 3.1.0
B8R274I RACF DB to be used is CRMB.T.RACF.OFFLINE
B8R268I LOG data set to be used is CRMB.T.RACF.OFFLINE.B8RLOG
B8R304I New SMF-ID:$B8R
B8R121I Completed processing B8ROPT options module
RACFDB 'CRMB.T.RACF.OFFLINE'
B8R274I RACF DB to be used is CRMB.T.RACF.OFFLINE
LOGDS 'CRMB.T.RACF.OFFLINE.B8RLOG'
B8R268I LOG data set to be used is CRMB.T.RACF.OFFLINE.B8RLOG
B8R143I Completed processing B8RPARM file
B8R200A Enter RACF Command or "END"
```

Figure 2-11 Starting RACF-Offline with parameters that are configured in the B8RPARM member

- Interactively and dynamically configure RACF-Offline configuration settings.

If you prefer, you can also specify the RACFDB, LOGDS, and SMF ID configurations parameters interactively in your RACF-Offline session. In that case, you must allocate file B8RPARM dynamically to your session before you start RACF-Offline (see Figure 2-12 on page 19).


```

READY
alloc fi(b8rparm) da(*)
READY
b8racf
B8R100I B8RACF version 3.1.0
B8R274I RACF DB to be used is CRMB.T.RACF.OFFLINE
B8R268I LOG data set to be used is CRMB.T.RACF.OFFLINE.B8RLOG
B8R304I New SMF-ID:$B8R
B8R121I Completed processing B8ROPT options module
racfdb 'crmb.t.racf.offline.other'
RACFDB 'CRMB.T.RACF.OFFLINE.OTHER'
B8R274I RACF DB to be used is CRMB.T.RACF.OFFLINE.OTHER
smf id($TST)
SMF ID($TST)
B8R304I New SMF-ID:$TST
end
END
B8R143I Completed processing B8RPARM file
B8R200A Enter RACF Command or "END"

```

Figure 2-12 Specifying the RACF-Offline configuration parameters to use dynamically

After you start RACF-Offline, you can then specify the RACF-Offline parameters interactively if the RACFDB and LOGDS that you specify are predefined for this purpose and you have UPDATE access to them.

In general, it is a best practice that the RACF-Offline configuration that was prepared by the system programmer matches your requirements. When you are satisfied with the configuration of your RACF-Offline session, log on to your RACF-Offline session.

2.4.3 Logging on to the RACF-Offline session

When you want to use the same user ID for your RACF-Offline session as you use on the 'live' system, specify the command `logon *` and press Enter to log on to RACF-Offline (see Figure 2-13).

```

READY
b8racf
B8R100I B8RACF version 3.1.0
B8R274I RACF DB to be used is CRMB.T.RACF.OFFLINE
B8R268I LOG data set to be used is CRMB.T.RACF.OFFLINE.B8RLOG
B8R304I New SMF-ID:$B8R
B8R121I Completed processing B8ROPT options module
B8R200A Enter RACF Command or "END"
logon *
B8R251I CRMBTZ1 logged on
B8R200A Enter RACF Command or "END"

```

Figure 2-13 Logging on to RACF-Offline

That command logs you on with the same user ID that you already use. Optionally, if your user ID is not assigned with the SPECIAL attribute, you can add the SPECIAL keyword to the `logon *` command to assign the SPECIAL attribute to your user ID for the configured RACF-Offline database.

2.4.4 Resetting the RACF-Offline log data set

Before running RACF commands in your RACF-Offline session, empty the associated log data set to remove RACF commands from previous RACF-Offline sessions that are still stored in the log data set (see Figure 2-14).

```
b8racflg reset
B8R277I RACF LOG file reset
B8R200A Enter RACF Command or "END"
```

Figure 2-14 Clearing the log data set that is configured in RACF-Offline

Run the command `ispf` and press Enter to start an ISPF session within your RACF-Offline session. That command opens the regular ISPF Primary Option Menu (see Figure 2-15).

ISPF Primary Option Menu		
Option ==>		
0 Settings	Terminal and user parameters	User ID . : CRMBTZ1
1 View	Display source data or listings	Time. . . : 11:28
2 Edit	Create or change source data	Terminal. : 3278
3 Utilities	Perform utility functions	Screen. . : 1
4 Foreground	Interactive language processing	Language. : ENGLISH
5 Batch	Submit job for language processing	Appl ID . : ISR
6 Command	Enter TSO or Workstation commands	TSO logon : TSOZSEC
7 Dialog Test	Perform dialog testing	TSO prefix: CRMBTZ1
9 IBM Products	IBM program development products	System ID : NMPIPL87
10 SCLM	SW Configuration Library Manager	MVS acct. : ACCT#
11 Workplace	ISPF Object/Action Workplace	Release . : ISPF 8.1
P PRODUCTS	Dialogs for installed products	
G GROUP	Dialogs used with your organization	
U User	Your Own Dialogs	
S SDSF	System Display and Search Facility	
C Consul	Consul Risk Management applications	

Figure 2-15 ISPF started within a RACF-Offline session

2.4.5 Starting and preparing your zSecure Admin session

How you start zSecure Admin depends on how your organization installed and configured it. Some customers configure a zSecure menu option for users to select. Other customers prefer to use the supplied REXX exec by using `tso ckr` from the CLI to start zSecure. Use your regular method to start zSecure Admin in your system.

In all the examples in this book, we use the following confirmation options to help ensure that commands run on the local system after confirmation. Select option SE.4 (Setup Confirm) to verify that you use the same options (see Figure 2-16 on page 21).

zSecure Admin - Setup - Confirm				
Command ==> _____				
Action on command . . .	2	1. Queue	2. Execute	3. Not allowed
Execute display commands (for option 1 only)				
Confirmation	5	1. None	2. Deletes	3. Passwords 4. All 5. Add
Command Routing . . .	2	1. Ask	2. Normal	3. Local only

Figure 2-16 zSecure Setup Confirm options

To generate RACF cleanup commands for security definitions that are not used in access decisions, allocate a RACF input source (primary, active backup, unload, or RACF copy), a CKFREEZE data set of the target system, and an ACCESS data set with preferably 1 year of historic consolidated access records.²

Select option SE.1 (Setup Input files) to define a new input set or select an already defined input set to use during your zSecure session. If you are not familiar with the naming convention of RACF, CKFREEZE, and ACCESS datasets on your system, consult a systems programmer to retrieve this information before you can set up an appropriate input set.

Figure 2-17 shows what the content of your zSecure input set might look like.

zSecure Admin - Setup - Input files		Row 1 of 3
Command ==> _____		Scroll ==> <u>CSR</u>
Description <u>Recent RACF, CKFREEZE, ACCESS datasets</u>		
Complex	<u>TVT6003</u>	Version _____
Enter data set names and types. Type END or press F3 when complete.		
Enter dsname with .* to get a list Type SAVE to save set, CANCEL to quit.		
Valid line commands: E L I R D Type REFRESH to submit unload job.		
Dataset name or DSNPREF=, or Unix file name	Type or ?	NJE node
- <u>'CRMB.T.RACF.OFFLINE'</u>	<u>COPY.RACF</u>	_____
- <u>'CRMB.T.CKFREEZE'</u>	<u>CKFREEZE</u>	_____
- <u>'C2PACMON.TVT6003.Y12MON'</u>	<u>ACCESS</u>	_____
***** Bottom of data *****		

Figure 2-17 zSecure input set for cleanup purposes

This sample input set contains an offline RACF database, a CKFREEZE data set, and a 12-month rolling ACCESS data set. The ACCESS data set contains consolidated access records of the last 12 months. For example, if today is October 25th, 2024, this ACCESS dataset contains the collected and consolidated access records from September 2023 to September 2024.

² When your RACF database is shared with more systems, allocate a CKFREEZE data set and an ACCESS data set of each system that shares the RACF database that is targeted for the cleanup.

Important: When deciding about cleaning up unused definitions in your RACF database, you must consider all processing activities, which include those activities that occur only once a year, such as batch jobs that produce financial reports about last year's performance. Thus, collecting and using historical access event data of at least *1 year* increases the confidence that your cleanup efforts do not disrupt access paths that are infrequently used.

Select this input set to use in your zSecure session by entering S. The selected input set is marked with label selected (see Figure 2-18).

zSecure Admin - Setup - Input files		Row 1 from 18
Command ==> _____		Scroll ==> <u>CSR</u>
(Un)select (U/S/C/M) set of input files or work with a set (B, E, R, I, D, or F)		
Description	Complex	
— Recent RACF, CKFREEZE, ACCESS datasets	TVT6003	selected
— Active primary RACF data base		
— Active primary RACF data base and live SMF datasets		
— Active backup RACF data base		
— Active backup RACF data base and live SMF datasets		
— Active backup ACF2 data base and live SMF datasets		
— Live settings		

Figure 2-18 Selecting the input set to use for cleanup

2.5 Further access monitor capabilities

Although certain functions are not described in further detail in this document, zSecure Access Monitor has many more selection criteria and reporting functions that can help you in your journey toward the principles of zero trust and least privilege.

For example, before you perform intelligent cleanup that is guided by Access Monitor data, clicking zSecure Admin option AM.9 (Cleanup option 1) performs a scan of your RACF database and generate commands to remove redundant permits for user IDs that already have access through group connect. If you use option 2, you generate commands to remove redundant dataset profiles.

After you remove the redundant definitions by using the static analysis, you can use Access Monitor data to perform dynamic analysis based on real access usage.

Another example relates to zSecure Admin option AM.7 (Global usage) and AM.1 (Access) with the selection option Use of global access checking table. With these reports, you can check that access that is granted through the RACF Global Access Checking (GAC) table is not excessive, and that only datasets and resources that are truly “public and must be accessed frequently are defined to enable the performance gain from bypassing full access checking.

Figure 2-19 shows the “Further selection” filtering options that are available when you select Advanced selection criteria from menu options AM.1 and AM.2. With these options, you can refine your reports based on what the access event records show in relation to the historical access requests.

zSecure Admin - Access - Further selection

Command ==> _____

All access monitor records

Specify further selection criteria:

Jobname _____ (jobname or EGN mask)

Port Of Entry class . . _____ (class or EGN mask)

Port Of Entry _____ (POE or EGN mask)

Select access records(Y/N/blank)

☐ Use of RACF commands
☐ Use of global access checking table
☐ Use of discrete profiles
☐ System special authority used
☐ Operations authority used
☐ Installation exit used
☐ User requesting access is owner

☐ Retrieval of access allowed
☐ Bypass JESSPOOL profiles
☐ ID was undefined during event
☐ User had special attribute
☐ User had operations attribute
☐ User had (ro)auditor attribute

Resource action	Intended access	Result	Program status
☐ Define	☐ 1. Read	☐ Success	☐ Defined program
☐ Delete	☐ 2. Update	☐ No profile	☐ Controlled program
☐ Addvol	☐ 3. Control	☐ Not authorized	☐ Specific program
☐ Chgvol	☐ 4. Alter	☐ Other	☐ Controlled library

Figure 2-19 Further selection menu

The “Specify further selection criteria” section, which you can use to perform more filtering by Jobname and Port Of Entry, is seen only when Show configured fields is also selected from menu options AM.1 and AM.2. Jobname and Port Of Entry information is not collected by default because it makes the consolidation of access records less effective, so configuring C2PACMON to collect this data must be done selectively for specific purposes.

Figure 2-20 shows the “Current RACF DB selection” filtering options that are available when you select Advanced selection criteria from menu options AM.1 and AM.2. By using these options, you can select events based on the simulation of the event by using the current RACF source.

zSecure Admin - Access - Current Database

Command ==> _____

Specify simulated fields (Current DB effect) selection criteria:
Groups used for access _____ (groups or filter)
Essential groups . . . _ (Y/N/blank)
Not using groups . . . _____ (groups or filter)
Profile owned by _____ (id or filter)
RACF return code _ _____ (operator: > >= < <= = <> ^=)

Authority used in the current DB

_ APF	_ GRP_OPER	_ <u>L</u> ID_USER	_ PRIVTRUS	_ SYS_OPER
_ CLAUTH	_ GRP_SPEC	_ INACTIVE	_ PROTFAIL	_ SYS_SPEC
_ CREATE	_ GRP_UACC	_ NO_CDT	_ QUALOWN	_ UACC
_ DFLTRC	_ ID_GROUP	_ NO_PROF	_ RESTRICTED	_ UNPROT
_ GLOBAL	_ ID_STAR	_ NOTHING	_ SPOOLRCVR	_ WARNING

User attributes in current DB (Y/N/blank)

_ ID present	_ ID Revoked	
_ ID has special	_ ID has operations	_ ID has (ro)auditor

Figure 2-20 Current RACF DB simulation section menu

ID_USER is selected, which produces a report showing where access was granted because a user ID is permitted on the ACL of a profile protecting a resource. You can use this report as a starting point to learn where in the journey to implement role-based access control (RBAC) you are, and where you should grant access by group based on the user’s role.

zSecure Access Monitor can also help you identify user IDs that are not used for the period that is covered by the access event data that is allocated as input. Menu option AM.V – ID Verify reports the actual RACROUTE REQUEST=VERIFY (also known as RACINIT) events. By using the “Further selection” criteria that are shown in Figure 2-21 on page 25, you see all the RACF system special user IDs that are logged on.

zSecure Admin - Access - Further selection

Command ==> _____
All access monitor records
Specify further selection criteria:
Application name . . . _____ (application name or EGN mask)

Select authentication method	Other flags(Y/N/blank)
☐ Started ☐ None	☐ Priv/Trust assigned
☐ Password ☐ MultiFactor	☐ Password changed
☐ Passphrase ☐ IDToken	☐ Passphrase changed
☐ Passticket ☐ Omitted	☐ Passticket replay
	☐ Undefined user
	☐ Group-only verify

User attributes(Y/N/blank)
☒ User has special attribute ☐ User has operations attribute
☐ User has (ro)auditor attribute

Figure 2-21 AM.V Further selection menu

You can check the resulting report against all user IDs that are defined with the system special attribute by using menu option RA.U. Select Attributes for the Additional selection criteria, and select Systemwide and group authorizations of Special.

After more verification, any user IDs in the RA.U report that were not used by the AM.V report can potentially be removed.

These examples are a few that demonstrate some of the additional functions that are available with zSecure Access Monitor. This chapter contains a few use cases that are detailed in later chapters. When you become more familiar with the value proposition of zSecure Admin, you discover more practical ways that you can benefit from using other supported filters to fuel your potential future cleanup efforts. For more information, see [IBM zSecure documentation](#).



Adding a set of profiles

Often, the role of a security administrator involves configuring their environment for new applications or expanding the security environment to better manage existing applications as features or security requirements change over time.

Also, security administrators might change the environment's protections for datasets. Managing these changes and anticipating their impact on a security environment can be a challenging aspect to this process.

The following topics are covered in this chapter:

- ▶ 3.1, "Challenges with adding new resource profiles" on page 28
- ▶ 3.2, "Steering clear of default security settings" on page 28
- ▶ 3.3, "Temporarily allowing access for new resources or applications" on page 28
- ▶ 3.4, "Adding profiles for extra security checking" on page 29

3.1 Challenges with adding new resource profiles

Security administrators are tasked with defining resource profiles to the IBM Resource Access Control Facility (RACF) for various reasons. The definition of a profile is often related to defining or controlling the usage of an application or features for an application. Also, profiles are used to protect resources in RACF environments. When administrators are assigned such changes, they are challenged by the following factors:

- ▶ When targeting resource profiles that govern an application's new features or requirements for the application, the administrator faces uncertainty surrounding the existing usage of the application and its resource profiles to minimize the security impact of these security definition changes on production workloads.
- ▶ When defining a set of resource profiles for a new application, it can be crucial to verify that these resource profiles do not have a security impact on existing applications or functions in the environment. When defining dataset profiles, an administrator might struggle with evaluating these changes against the existing environment to help ensure that the required access is retained to key data and no additional access is granted. Leaving default or generic uses can allow for unintended use of key applications.

3.2 Steering clear of default security settings

RACF can secure only subsystems, applications, and resources that are configured to consult RACF for authentication and access verification. When consulted, RACF verifies the authentication and access verification requests by looking for RACF profile definitions to govern access to subsystems, applications, or resources. Many applications and third-party vendor products document how you can configure RACF or other security products to regulate access to the various features. It documents how you can enable certain features, disable certain features, or allow for any security checking and logging at all. Before installing or updating an application, it is a best practice to help ensure that the environment is set up to secure this application.

When applications or their features are left unsecured by RACF or other products, they might hinge on defaults that allow for their use but do not process security checking or logging. Such an implementation might allow for unintended and unsecured usage of subsystems, applications, and resources through these default or generic permissions. Such a configuration is not acceptable in a zero trust environment, where no user should be trusted to access any resource or application feature by default. Also, any implementation of least privilege should not allow users whose job role does not require the usage of an application or its features to allow this access.

3.3 Temporarily allowing access for new resources or applications

Most security administrators have familiarity with both the intended application profiles and their security environment. An administrator may establish generic or backstop resource profiles with broad access control lists (ACLs) for new applications to function. You can configure these profiles with auditing features so that the administrator can later trim the accesses that are granted to such profiles.

Also, an administrator can use the activation of the WARNING mode for a new profile to temporarily permit ALTER access to non-permitted users to the resources that a new resource profile protects and cut audit records that security administrators can use to grant more appropriate access later. Using WARNING mode enables all non-permitted users to access a resource or application function with ALTER access, which still enables unintended usage of resources or applications.

With zSecure Access Monitor, you can review historic access events to determine resources or datasets that are not controlled by RACF profiles. Also, although Access Monitor can automatically generate commands to create ACLs for new profiles based on historic access to the resources, it is not the best approach because Access Monitor records bases such an access list on individual user access attempts. It is more meaningful and secure for you to review the users in this report and define accesses to them through either existing or new groups that represent job roles. Lastly, with RACF-Offline through zSecure, you can validate that your new definitions and ACLs do not introduce overly permissive or unexpected access failures before applying them in your production environment.

3.4 Adding profiles for extra security checking

The details for the general use case preparation steps by using automated (semi-) conversion and cleanup features in zSecure Admin are documented in 2.4, “General preparation steps for the use cases” on page 16, which include these steps:

- ▶ Creating a RACF-Offline database
- ▶ Starting a RACF-Offline session
- ▶ Logging on to the RACF-Offline session
- ▶ Resetting the RACF-Offline log data set
- ▶ Starting and preparing your zSecure Admin session

After completing these steps, you can continue with the definition of resource profiles as follows:

- ▶ Analyzing statistics and discovering missing RACF resource profiles
- ▶ Defining a RACF resource profile in the RACF-Offline database
- ▶ Simulating Access Monitor data against the offline RACF database

3.4.1 Analyzing statistics and discovering missing RACF resource profiles

In this section, you learn how to analyze Access Monitor statistics and discover missing RACF resource profiles.

Suppose that your auditors demand that access to all TS0AUTH resources must be controlled by a RACF resource profile, and it is your job to implement the protection of the TS0AUTH resources that are used in your company.

A good starting point for this activity is to research whether any TSOAUTH resources are accessed through the default return code (DFLTRC) that is configured for the TSOAUTH resource class in the class descriptor table (CDT). When you use option RA.S for SETROPTS RRSF and class settings, it generates five standard audit reports. You can access the RACFCLAS report by entering S to review the configuration and settings of all RACF resource classes in your system. You can issue find tsoauth in the CLI and press Enter to find the class configuration settings of the TSOAUTH resource class (see Figure 3-1). You can specify S again to display the class configuration settings.

RACF class settings				Line 1 of 38	
Command ==> _____				Scroll==> <u>CSR</u>	
				25 Oct 2024 12:31	
Class	Description				
TSOAUTH	TSO user authorities such as OPER and MOUNT				
Class SETROPTS settings				TVT6003	ZS34
Protection active	<u>Yes</u> _____				
Command auditing active	<u>Yes</u> _____				
Logoptions	<u>Profile</u> _____				
GLOBAL (fast path) active	<u>Yes</u> _____				
Generics checked	<u>Yes</u> _____	Generics can be activated		Yes	
Generic commands allowed	<u>Yes</u> _____				
Profiles RACLISTed	<u>Yes</u> _____	Profiles can be RACLISTed		Yes	
Profiles GENLISTed	<u>No</u> _____	Profiles can be GENLISTed		No	
Statistics collected	<u>No</u> _____				
Profile syntax rules	1st	rest	Class properties		
Alphabetic allowed	Yes	Yes	Original order (class number)		259
National allowed	Yes	Yes	Class identifier		48
Numeric allowed	Yes	Yes	POSIT (options set ID)		124

Figure 3-1 TSOAUTH class settings in the class descriptor table

You see Yes for the Protection active option, which means that protection of access to resources in the TSOAUTH class is active on this system. Press F8 to scroll down to find the configured default return code for the TSOAUTH class (see Figure 3-2 on page 31).

```

RACF class settings
Line 21 of 38
Command ==> _____ Scroll==> CSR
25 Oct 2024 12:31

Maximum length      8      Generic scan limit (quals)    0
Maximum length with ENTITY  8      Installation-defined class    No
Related grouping class      Profile names case-sensitive No
Related member class      Default not-found RC      4

Class activity options      Profile residency options
Profile definition forbidden No      Profiles in dataspace      Yes
OPERATIONS honored      No      RACLIST required      No
Send ENF signal      No      RACLISTed by application only No

Mandatory access control properties
SECLABEL required      No
Reverse MAC checking      No
Equal MAC checking      No

***** Bottom of Data *****

```

Figure 3-2 TSOAUTH class default return code

The default return code for resource class TSOAUTH in the CDT is 4, as reported by option **Default not-found RC**, which means that when RACF does not find a matching resource profile for a TSOAUTH resource that a user tries to access, RACF provides return code 4. This return code means that RACF cannot make an access decision based on a resource profile and leaves the decision whether access is allowed or denied to the requesting resource manager (RM), such as z/OS, TSO, IMS, IBM CICS®, IBM Db2®, or others. Most RMs allow access when the external security manager (ESM) RACF, Access Control Facility 2 (ACF2), or TSS does not restrict access.

To verify whether any users can access TSOAUTH resources through this default return code, use the historic access decisions that Access Monitor collected.

Select option AM (RACF Access Monitor) on the zSecure Admin Main menu and press Enter. Next, select option 1 from the zSecure Access Monitor menu (see Figure 3-3).

zSecure Admin - Access		
Option ==> <u>1</u>		
1	Access	Access summary by user or profile
2	Compare	Compare monitored access against current RACF database
3	Permit usage	Permit usage information for current RACF database
4	Connect usage	Connect usage information for current RACF database
5	Profile usage	Profile usage information for current RACF database
6	Member usage	Member usage information for current RACF database
7	Global usage	Global usage summary for current RACF database
8	Remove	Remove unused profiles and authorizations
9	Cleanup	Remove permits, dataset, and general resource profiles
V	ID verify	ID verification (logon/start/job-start) summary
I	ID usage	ID usage information for current RACF database
U	Unix events	Access summary for unix events by user, uid/gid, or path

Figure 3-3 Selecting option Access from the zSecure Admin Access menu

On the next menu, specify to report all historical access events that are related to the TSOAUTH resource class. To use more granular selection filters for historical access events, select the option Current RACF Database Selection. To report which users accessed TSOAUTH resources, select a summary based on a member class and profile (see Figure 3-4).

zSecure Admin - Access - Access		
Command ==> _____		
Show records that fit all of the following criteria:		
User ID	_____	(user ID or EGN mask)
Complex	_____	(complex or EGN mask)
SAF resource class . .	<u>tsoauth</u>	(class or EGN mask)
SAF resource name . .	_____	
RACF match on	_____	
Advanced selection criteria		
_ Further selection	_ Date selection	/ Current RACF DB selection
Output/run options		
<u>2</u>	1. Summary by user ID	
	2. Summary by member class and profile	
	3. Summary by simulated authorization used	
	4. Summary by simulated groups used for access	
_ Show configured fields	_ Show simulated fields	_ Timezone (U/L/H)
_ Print format	Customize title	Send as email
_ Background run	Full page form	

Figure 3-4 Selecting access events for the TSOAUTH resource class on the AM.1 menu

In Figure 3-5, you can specify which additional filtering criteria that you want to use. In this scenario, you are interested in reporting on specific type of access events that used the DFLTRC. The DFLTRC setting reports historic access events that, when simulated against your allocated RACF source, returns the default return code for a resource access check for a class that is defined in RACF CDT. The DFLTRC is returned when no matching resource profile was found in the resource access check (RACHECK) call. The access events that are included in this report are the events that are affected when you define a RACF resource profile for the accessed resource.

zSecure Admin - Access - Current Database

Command ==>

Access monitor records for Classes like TSOAUTH

Specify simulated fields (Current DB effect) selection criteria:

Groups used for access (groups or filter)

Essential groups . . . (Y/N/blank)

Not using groups . . . (groups or filter)

Profile owned by . . . (ID or filter)

RACF return code . . . (operator: > >= < <= = <> ^=)

Authority used in the current DB

-	APF	-	GRP_OPER	-	ID_USER	-	PRIVTRUS	-	SYS_OPER
-	CLAUTH	-	GRP_SPEC	-	INACTIVE	-	PROTFAIL	-	SYS_SPEC
-	CREATE	-	GRP_UACC	-	NO_CDT	-	QUALOWN	-	UACC
/	DFLTRC	-	ID_GROUP	-	NO_PROF	-	RESTRICTED	-	UNPROT
-	GLOBAL	-	ID_STAR	-	NOTHING	-	SPOOLRCVR	-	WARNING

User attributes in current DB (Y/N/blank)

-	ID present	-	ID Revoked
-	ID has special	-	ID has operations
-		-	ID has (ro)auditor

Figure 3-5 Selecting access events that use authority DFLTRC

Press Enter to produce the summary of access events where RACF returns the default return code for TSOAUTH class resources as defined in the CDT (see Figure 3-6).

IBM Security zSecure ACCESS summary 0 s elapsed, 0.1 s CPU

Command ==>

Access monitor records for Classes like TSOAUTH 16 Dec 2024 13:55

Scroll==> CSR

Occurrence Class First occurrence Last occurrence

751003 TSOAUTH 1Dec2023 22:31 2Nov2024 22:58

Occurrence Profile key used

751003

Occurrence Intent Type RetAll AccRC

751003 READ Auth 4

Occurrence Resource

525 CONOPER

S_ 750478 MOUNT

***** Bottom of Data *****

Figure 3-6 Summary report of TSOAUTH access events that use DFLTRC

Exploring the summary statistics, you see that the field “Profile key used” is missing in the report. Thus, this report indicates that two TSOAUTH resources, CONOPER and MOUNT, are not protected by a profile in the allocated RACF database. To see more detailed information about the users that accessed the TSOAUTH MOUNT resource during the last year (see Figure 3-7), specify S before MOUNT and press Enter.

```

IBM Security zSecure ACCESS summary
Line 1 of 30
Command ==>
Scroll==> CSR
Access monitor records for Classes like TSOAUTH 16 Dec 2024 13:55
Occurrence Class      First occurrence Last occurrence
751003 TSOAUTH      1Dec2023 22:31  2Nov2024 22:58
Occurrence Profile key used
751003
Occurrence Intent      Type      RetAll AccRC
751003 READ            Auth            4
Occurrence Resource
750478 MOUNT
Occurrence User ID Name
749543 AXRUSER
333 CRMAUTO  ZTEAM AUTOTASKS
1 CRMBAB1  SYSPROG1 AB
1 CRMBAB2  SYSPROG2 AB
23 CRMBAH1  SYSPROG1 AH
18 CRMBAH2  SYSPROG2 AH
2 CRMBAH6  SYSPROG VK
2 CRMBEP1  SYSPROG1 EP
4 CRMBFN1  SYSPROG FN1
4 CRMBFN2  SYSPROG FN2
1 CRMBGUS  SYSPROG GUS
40 CRMBJK1  SYSPROG1 JK

```

Figure 3-7 Reporting detailed access statistics for the TSOAUTH class resource MOUNT

After reviewing the outcome of the access simulation of historic access events, you decide to define a resource profile that is named “MOUNT” in the resource class TSOAUTH. Access to the MOUNT resource allows TSO/E users to issue dynamic allocation requests for datasets, which result in the need for volume mounting. Next, you can simulate the security impact of adding the profile MOUNT by using your RACF-Offline database before defining the MOUNT profile in the TSOAUTH class of your active RACF database.

Analyzing the historic access events, you discovered that most reported users are either systems programmers or automation task users. You do not want to permit access to the TSOAUTH class MOUNT resource to individual users because your company is implementing role-based access control (RBAC). You know that all systems programmers are connected to role-base group SYSPROG and automation task users are members of role-based group SYS1, so you decide to permit READ access to these groups. In a real-life scenario, it might be impossible to find an existing role-based group that represents a specific job role. If so, you might want to consider introducing a role-based group that allows efficient access management to this resource and potentially other sensitive z/OS resources.

Also, you might discover that some of the users do not fall into specific job roles or functions that you expect to require access to the TSOAUTH class MOUNT resource. If so, the user access must not be provisioned in the TSOAUTH class MOUNT profile. Therefore, that user no longer has this access after you introduce the TSOAUTH class MOUNT profile in the active RACF database.

3.4.2 Defining a RACF resource profile in the RACF-Offline database

In this section, you learn how to define a RACF resource profile in the RACF-Offline database.

To run the appropriate RACF commands to create the TSOAUTH class resource profile MOUNT and define ACL entries based on the results of your security assessment of historical access events for the TSOAUTH class MOUNT resource, select the option RA.R (RACF Administration - General resource profiles) from the zSecure Admin Main menu (see Figure 3-8), and press Enter.

zSecure Admin - RACF - Resource Selection			
Command ==> _____		_ start panel	
_ Add a new general resource profile or segment			
Show general profiles that fit all of the following criteria			
Class name	<u>tsoauth</u>	(class or filter)	
Resource profile .	_____		
Owned by	_____	(group or user ID, or filter)	1 1 EGN mask
Installation data .	_____	(substring or *)	2 Exact
			3 Match
			4 Any match
Additional selection criteria			
_ Profile fields	_ Access list	_ Segment presence	_ Absence
_ Audit settings			
Output/run options			
= Show segments	_ All	_ Enable full ACL	_ Specify scope
_ Show differences	_ Summarize by class		
_ Print format	Customize title	Send as email	
Background run	Full detail form	Sort differently	Narrow print
Print ACL	Resolve to users	Incl operations	Print names

Figure 3-8 Selecting the profiles that are defined in the TSOAUTH class

Specify TSOAUTH at Class name and press Enter to see the profiles that are defined in the TSOAUTH class, as shown in Figure 3-9. Instead of reporting existing TSOAUTH profiles by using this menu, you can use the option Add new general resource profile or segment to build a new TSOAUTH class profile from scratch. Usually, it is more efficient to copy an existing TSOAUTH class profile and adjust the generated commands to match your requirements rather than entering all the required profile settings manually. Specify C (Copy) before the profile PARMLIB and press Enter.

zSecure Admin General resource overview					0 s elapsed, 0.0 s CPU	
Command ==> _____					Scroll==> <u>CSR</u>	
Class TSOAUTH					16 Dec 2024 14:41	
Class	Profile key	T	UACC	Owner	S/F	W
__ TSOAUTH	ACCT		<u>READ</u>	<u>SYSAUTH</u>	<u>R</u>	<u>R</u>
__ TSOAUTH	CONSOLE		<u>NONE</u>	<u>SYSAUTH</u>	<u>R</u>	<u>R</u>
__ TSOAUTH	JCL		<u>READ</u>	<u>SYSAUTH</u>	<u>R</u>	<u>R</u>
__ TSOAUTH	OPER		<u>READ</u>	<u>SYSAUTH</u>	<u>R</u>	<u>R</u>
<u>C</u> TSOAUTH	PARMLIB		<u>NONE</u>	<u>SYSAUTH</u>	<u>R</u>	<u>R</u>
__ TSOAUTH	RECOVER		<u>READ</u>	<u>SYSAUTH</u>	<u>R</u>	<u>R</u>
***** Bottom of Data *****						

Figure 3-9 Copying the profile PARMLIB in the TSOAUTH class

In the next panel (see Figure 3-10), specify that you want to copy the TSOAUTH profile PARMLIB to the TSOAUTH profile MOUNT. Use option 1 (Create permanent profile) and suboption 1 (Copy segments and members), and press Enter.

zSecure Admin - RACF - Resource Copy

Command ==> _____

From class TSOAUTH

profile PARMLIB

To class TSOAUTH

profile MOUNT

1 1. Create permanent profile

1 1. Copy segments and members (commands are stored in CKRCMD)

2. Use "copy from" (does not copy segments and members)

__ RACF commands optimized for post-processing

2. Create temporary profile

Date of removal . . . _____ (ddmmmyyyy or yyyy-mm-dd or +days)

Reason _____

Figure 3-10 Specifying the TSOAUTH class profile name mount to add

After pressing Enter, you return to the result of your original query, as shown in Figure 3-11.

zSecure Admin General resource overview					Queued in CKRCMD	
Command ==>					Scroll ==> CSR	
Class TSOAUTH					16 Dec 2024 14:41	
	Class	Profile key	T	UACC	Owner	S/F W
__	TSOAUTH	ACCT		READ	SYSAUTH	R R _
__	TSOAUTH	CONSOLE		NONE	SYSAUTH	R R _
__	TSOAUTH	JCL		READ	SYSAUTH	R R _
__	TSOAUTH	OPER		READ	SYSAUTH	R R _
__	TSOAUTH	PARMLIB		NONE	SYSAUTH	R R _
__	TSOAUTH	RECOVER		READ	SYSAUTH	R R _
***** Bottom of Data *****						

Figure 3-11 Generating the commands to copy the TSOAUTH profile PARMLIB in the CKRCMD work dataset

The message Queued in CKRCMD in the upper right of the panel informs you that the RACF commands are generated in the CKRCMD work dataset. Press F3 to exit this panel and access the work dataset with the generated RACF commands (see Figure 3-12).

EDIT		CRMBTZ1.DATA.C2R1DC6.CKRCMD		Columns 00001 00072	
Command ==>				Scroll ==> <u>CSR</u>	
***** Top of Data *****					
=NOTE= Enter GO or RUN to run commands, SUB or SUBMIT to generate a batch job					
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.					
000001	/* CKRCMD file CKR1CMD complex TVT6003 generated 16 Dec 2024 14:41 */				
000002	/* CKRCMD file CKRT1CMD complex TVT6003 NJE TVT6003 generated 16 Dec -				
000003	2024 14:54 */				
000004	rdefine	TSOAUTH	mount +		
000005		owner(SYSAUTH)	+		
000006		uacc(NONE)	+		
000007		audit(all(READ))			
000008	permit	mount	+		
000009		class(TSOAUTH)	+		
000010		id(SYSPROG)	access(UPDATE)		
000011	permit	mount	+		
000012		class(TSOAUTH)	+		
000013		id(CRMBGUS)	access(UPDATE)		
000014	permit	mount	+		
000015		class(TSOAUTH)	+		
000016		id(CRMBPH1)	access(UPDATE)		

Figure 3-12 Generating the RACF commands to copy the TSOAUTH class PARMLIB profile to the MOUNT

Adjust the generated commands to fit with your requirements for the TSOAUTH class profile MOUNT (see Figure 3-13).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
000001  /* CKRCMD file CKR1CMD complex TVT6003 generated 16 Dec 2024 14:41 */
000002  /* CKRCMD file CKRT1CMD complex TVT6003 NJE TVT6003 generated 16 Dec -
000003  2024 14:54 */
000004  rdefine  TSOAUTH  mount +
000005          owner(SYSAUTH) +
000006          uacc(NONE) +
000007          audit(failures(READ))
000008  permit   mount +
000009          class(TSOAUTH) +
000010          id(SYSPROG) access(read)
000011  permit   mount +
000012          class(TSOAUTH) +
000013          id(SYS1) access(read)
***** ***** Bottom of Data *****

```

Figure 3-13 Editing the commands to define the TSOAUTH class profile MOUNT

When you are satisfied with the RACF commands to define the TSOAUTH class profile MOUNT, either specify G0 to run the generated commands or press F3 to return to the zSecure Admin Results menu. Specify R (see Figure 3-14) and press Enter to run the commands.

```

                                zSecure Admin - Results          Enter R to run commands
Command ==> _____

The following selections are supported:
B Browse file                S Default action (for each file)
E Edit file                  R Run commands
P Print file                 J Submit Job to run commands
V View file                  M Email report
W Write file into seq. or partitioned dataset

Enter a selection in front of a highlighted line below:
_ SYSPRINT  messages
_ REPORT    printable reports
_ CKRTSPRT  output from the last TSO commands
R CKRCMD    queued TSO commands
_ CKR2PASS  queued commands for zSecure Admin
_ COMMANDS  zSecure Admin input commands from last query
_ SPFLIST   printable output from PRT primary command
_ OPTIONS   set print options

_ View files from recursive call (now on level 0)

```

Figure 3-14 Running commands to define the TSOAUTH class profile MOUNT

You automatically transfer the zSecure CKRTSPRT work dataset that shows the results of the RACF commands. Because no Command failed message is shown in the upper right of your display, all RACF commands ran successfully (see Figure 3-15).

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT          Line 0000000000 Col 001 080
Command ==> _____ Scroll ==> CSR_
***** Top of Data *****
=====
=== Multiple TSO command output file - scroll max down for overview ===
=== Input dataset CRMBTZ1.DATA.C2R1DC6.CKRCMD          ===
=====
===== Commands for local node
=====
/* CKRCMD file CKR1CMD complex TVT6003 generated 16 Dec 2024 14:41 */
/* CKRCMD file CKRT1CMD complex TVT6003 NJE TVT6003 generated 16 Dec 2024 14:54

===== 16Dec24 15:14:33.16377 start record 4 =====
rdefine TSOAUTH mount owner(SYSAUTH) uacc(NONE) audit(failures(READ))
ICH10006I RACLISTED PROFILES FOR TSOAUTH WILL NOT REFLECT THE ADDITION(S) UNTIL

===== 16Dec24 15:14:33.17609 start record 8 =====
permit mount class(TSOAUTH) id(SYSPROG) access(read)
ICH06011I RACLISTED PROFILES FOR TSOAUTH WILL NOT REFLECT THE UPDATE(S) UNTIL A

===== 16Dec24 15:14:33.18249 start record 11 =====

```

Figure 3-15 The commands to define the TSOAUTH class profile MOUNT ran successfully

Optionally, you can press F8 to scroll down to the comment box that reports the All commands completed successfully message.

The TSOAUTH class profile MOUNT was successfully added to your offline RACF database.

3.4.3 Simulating Access Monitor data against the offline RACF database

In this section, you learn how to conduct a simulation of Access Monitor data against the offline RACF database.

After you run the RACF commands to define the TSOAUTH class MOUNT profile against your offline RACF database, you can verify the correct addition of this new resource profile.

Select the option RA.R (RACF Administration General resource profiles) from the zSecure Admin Main menu and press Enter. Specify the class name TSOAUTH and the resource profile MOUNT, and press Enter to list the profile (see Figure 3-16).

zSecure Admin - RACF - Resource Selection

Command ==> _____ _ start panel

_ Add new general resource profile or segment

Show general profiles that fit all of the following criteria

Class name TSOAUTH_ (class or filter)

Resource profile . mount_

Owned by _____ (group or user ID, or filter)

Installation data . _____ (substring or *)

1 1 EGN mask

2 Exact

3 Match

4 Any match

Additional selection criteria

_ Profile fields _ Access list _ Segment presence _ Absence

_ Audit settings

Output/run options

_ Show segments _ All _ Enable full ACL _ Specify scope

_ Show differences _ Summarize by class

_ Print format Customize title Send as email

Background run Full detail form Sort differently Narrow print

Print ACL Resolve to users Incl operations Print names

Figure 3-16 Using the option RA.R to list the details of the resource profile MOUNT in the TSOAUTH class

After selecting the RACF class TSOAUTH and profile MOUNT, press Enter to list the profile (see Figure 3-17).

zSecure Admin General resource overview

Command ==> _____ Scroll==> CSR_

Class TSOAUTH, like mount 16 Dec 2024 15:30

Class

Profile key

T

UACC

Owner

S/F

W

S_

TSOAUTH

MOUNT

NONE

SYSAUTH_

R_

***** Bottom of Data *****

Figure 3-17 Accessing the detailed information of TSOAUTH class profile MOUNT

Specify S before the TSOAUTH MOUNT profile and press Enter to review the correct definition of the resource profile and all its settings (see Figure 3-18 on page 41).

Line 1 of 33

zSecure Admin General resource overview

Command ==> _____ Scroll==> CSR

Class TSOAUTH, like mount 16 Dec 2024 15:37

_ Identification TVT6003
 Class TSOAUTH
 Profile name MOUNT
 Type
 Volume serial list
 Owner SYSAUTH_ AUTHORIZATION GRO
 _ Installation data _____
 Application data _____

User	Access	ACL id	When	RI Name	DfltGrp
_ -group-	<u>READ</u>	<u>SYSPROG</u>			
_ -group-	<u>READ</u>	<u>SYS1</u>			

Safeguards
 User to notify of violation _____ Allow all accesses WARNING No
 Audit access success/failures R Universal access authority NONE

Figure 3-18 Verifying the correct definition of the TSOAUTH class profile MOUNT

As you can see, the profile is correctly added and shows the intended role-based groups SYSPROG and SYS1 with READ access on the ACL.

Next, you can simulate running the historic access events against the RACF-Offline database that contains the new TSOAUTH class resource profile MOUNT. To do so, run the AM.1 report with the same selection parameter DFLTRC to verify whether the simulation still associates the outcome with a missing RACF resource profile. The report is expected to return No records found because the TSOAUTH class profile MOUNT is defined (see Figure 3-19).

zSecure Admin - Access - Access		No records found
Command ==> _____		
Show records that fit all of the following criteria:		
Userid	_____	(user ID or EGN mask)
Complex	_____	(complex or EGN mask)
SAF resource class . .	<u>TSOAUTH</u>	(class or EGN mask)
SAF resource name . . .	<u>mount</u>	
RACF match on	_____	
Advanced selection criteria		
_ Further selection	_ Date selection	_ Current RACF DB selection
Output/run options		
<u>1</u>	1. Summary by user ID	
	2. Summary by member class and profile	
	3. Summary by simulated authorization used	
	4. Summary by simulated groups used for access	
_ Show configured fields	/ Show simulated fields	_ Timezone (U/L/H)
_ Print format	Customize title	Send as email
	Background run	Full page form

Figure 3-19 Simulating access to the TSOAUTH class resource MOUNT against the RACF-Offline database

You can simulate access decisions that result from the new TSOAUTH class MOUNT profile by using option AM.2 from the zSecure Admin Access menu. You can use similar filtering criteria as in Figure 3-19 except you do not report authority by using DFLTRC (see Figure 3-20 on page 43).


```

zSecure Admin - Access - Compare
Command ==> _____

Show records that fit all of the following criteria:
Userid . . . . . _____ (user ID or EGN mask)
Complex . . . . . _____ (complex or EGN mask)
SAF resource class . . tsoauth_ (class or EGN mask)
SAF resource name . . . mount_
RACF match on . . . . . _____
Comparison selection
Simulated results . . . / Same      / Less      / More
Profile used . . . . . 3 1. Same    2. Different 3. All

Advanced selection criteria
_ Further selection _ Date selection _ Current RACF DB selection

Output/run options
1 1. Summarize by user ID 2. Summarize by member class and profile
_ Show configured fields _ Timezone (U/L/H)
_ Print format           _ Customize title      Send as email
_ Background run         _ Full page form

```

Figure 3-20 Reviewing access decisions for the TSOAUTH class resource MOUNT through the compare function

As shown in Figure 3-21, the access simulation results are divided into three separate reports:

- ▶ The report SIMSAMED shows access simulation results where the simulated access decisions are the same as the historic access decision.
- ▶ The report SIMLESSD shows access simulation results where the simulated access decisions allow less access than the historic access decision.
- ▶ The report SIMMORED shows access simulation results where the simulated access decisions allow more access than the historic access decision.

```

zSecure Admin Display Selection      0 s elapsed, 0.1 s CPU
Command ==> _____ Scroll==> CSR_

```

Name	Summary	Records	Title
<u>1</u> SIMSAMED	0	0	ACCESS summary simulated access is same
3 SIMLESSD	9	13	ACCESS summary simulated access is less
5 SIMMORED	21	37	ACCESS summary simulated access is more
***** Bottom of Data *****			

Figure 3-21 Result of comparing simulated access against historic access

The report SIMSAMED is expected to report 0 records for the simulation of the TSOAUTH class resource MOUNT. Because you added the TSOAUTH class profile MOUNT, the simulated historic access events no longer result in a default return code of 4. This outcome proves that your profile successfully protected the TSOAUTH class resource MOUNT.

When you permit access to all users that historically accessed the TSOAUTH class resource MOUNT, the report SIMLESSD also reports 0 records. However, in this sample scenario, not all historic access through DFLTRC were granted with a permission. Thus, users that used the TSOAUTH class resource MOUNT during the last year but are not connected to role-based groups SYSPROG and SYS1 now receive a violation at their next attempt to use this resource. To review which users no longer have access to the TSOAUTH class resource MOUNT, specify S before the report SIMLESSD and press Enter (see Figure 3-22).

```
0.0 s CPU, RC=4
ACCESS summary simulated access is less
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like TSOAUTH 17 Dec 2024 09:40
  Occurrence Userid Name First occurrence Last occur
  _____
  S 1 CRMBAB2 SYSPROG2 AB 1Dec2023 22:31 1Dec2023
  23 CRMBAH1 SYSPROG1 AH 5Jun2024 13:53 12Sep2024
  18 CRMBAH2 SYSPROG2 AH 16Jan2024 14:07 12Mar2024
  2 CRMBEP1 SYSPROG1 EP 19Apr2024 13:21 19Apr2024
  1 CRMBLU2 SYSPROG2 LU 4Jan2024 12:12 4Jan2024
  2 CRMBNAT SYSPROG NAT 25Mar2024 11:36 25Mar2024
  1 CRMBSG1 SYSPROG1 SG 29Jan2024 09:53 29Jan2024
  1 CRMBSG2 SYSPROG2 SG 29Jan2024 09:54 29Jan2024
  14 HZSPROC 2Nov2024 09:05 2Nov2024
***** Bottom of Data *****
```

Figure 3-22 Reviewing users that no longer have access to the TSOAUTH class resource MOUNT

To access the simulation details for user CRMBAH1, specify S again and press Enter (see Figure 3-23).

```
Line 1 of 2
ACCESS summary simulated access is less
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like TSOAUTH 17 Dec 2024 09:40
  Occurrence Userid Name First occurrence Last occur
  _____
  23 CRMBAH1 SYSPROG1 AH 5Jun2024 13:53 12Sep2024
  Occurrence Intent Type RetAll AccRC SimRC
  23 READ Auth 4 8
  Occurrence Class
  23 TSOAUTH
  Occurrence Resource Profile key us
  23 MOUNT
  Occurrence Complex Syst RGPJCAVP GUGSOPGX0 SOA PCSL First occurrenc Last oc
  23 TVT6003 ZS34 S A 5Jun2024 13:53 12Sep20
  Occurrence Timestamp
  1 5Jun2024 13:53
  22 12Sep2024 20:02
***** Bottom of Data *****
```

Figure 3-23 Simulated access decisions for user CRMBAH1 to the TSOAUTH class resource MOUNT

The column “SimRC” reports that the simulated RC is 8, meaning that the user is not authorized by the allocated RACF database source, which is the offline RACF database. Column “AccRC” reports the historic access result of RC=4, which means that no matching profile was found. Therefore, adding the TSOAUTH class profile MOUNT successfully stops this user from accessing this resource when you define the same profile in the active RACF database. Potentially, you can decide that some of the users that are reported in the report SIMLESSD do need to be authorized to use the TSOAUTH MOUNT resource after all. You can decide to add another permit to the ACL of the TSOAUTH class profile MOUNT. When this user must not have this access in the future, adding the profile works as designed.

The report SIMMORED contains records, as shown in Figure 3-24. The reason why report SIMMORED contains records where the simulated access results allow “more” or “higher” access than the historic access decision from the access records is because you permitted these users to be on the access list of the TSOAUTH class MOUNT profile.

Line 1 of 21

ACCESS summary simulated access is more

Command ===> _____ Scroll===> CSR

Access monitor records for Classes like TSOAUTH 17 Dec 2024 09:40

	Occurrence	Userid	Name	First occurrence	Last occur
<u>S</u>	749543	AXRUSER		23Jun2024 11:51	2Nov2024
—	333	CRMAUTO	ZTEAM AUTOTASKS	22Jun2024 23:10	2Nov2024
—	1	CRMBAB1	SYSPROG1 AB	1Dec2023 22:32	1Dec2023
—	2	CRMBAH6	SYSPROG VK	12Sep2024 20:12	12Sep2024
—	4	CRMBFN1	SYSPROG FN1	7May2024 14:09	7May2024
—	4	CRMBFN2	SYSPROG FN2	7May2024 14:09	7May2024
—	1	CRMBGUS	SYSPROG GUS	6Mar2024 09:21	6Mar2024
—	40	CRMBJK1	SYSPROG1 JK	19Apr2024 07:25	31Oct2024
—	8	CRMBLU1	SYSPROG1 LU	16May2024 13:12	16May2024
—	3	CRMBMC1	SYSPROG1 MC	20May2024 06:40	20May2024
—	2	CRMBMJ1	SYSPROG1 MJ	7Dec2023 09:35	7Dec2023
—	18	CRMBMK1	SYSPROG1 MK	30Oct2024 16:07	30Oct2024
—	1	CRMBPH1	SYSPROG1 PH	7Mar2024 10:22	7Mar2024
—	3	CRMBRL1	SYSPROG1 RL	15Dec2023 13:54	11Sep2024
—	5	CRMBRS1	SYSPROG1 RS	20Jun2024 11:06	11Sep2024
—	2	CRMBRT1	SYSPROG1 RT	30Apr2024 09:56	30Apr2024
—	23	CRMBTZ1	SYSPROG1 TZ	1Nov2024 16:02	1Nov2024
—	77	CRMBVK1	SYSPROG1 VK	16Jan2024 15:55	1Nov2024
—	6	CRMBVK2	SYSPROG2 VK	1Aug2024 12:36	1Aug2024

Figure 3-24 Reviewing users that are permitted access to the TSOAUTH class resource MOUNT

To review the access event details, specify S (see Figure 3-25).

```

Line 1 of 2
ACCESS summary simulated access is more
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like TSOAUTH 17 Dec 2024 09:40
  Occurrence Userid  Name                               First occurrenc Last occur
    749543 AXRUSER                                     23Jun2024 11:51  2Nov2024
  Occurrence Intent  Type    RetAll AccRC SimRC
    749543 READ      Auth           4      0
  Occurrence Class
    749543 TSOAUTH
  Occurrence Resource                               Profile key us
    749543 MOUNT
  Occurrence Complex  Syst  RGPJCAVP GUGSOPGX0 SOA PCSL First occurrenc Last oc
    749543 TVT6003  ZS34                                     23Jun2024 11:51  2Nov20
  Occurrence Timestamp
S      8824 23Jun2024 11:51
      740719 2Nov2024 22:58
***** Bottom of Data *****

```

Figure 3-25 Reviewing the user AXRUSER that is permitted access to the TSOAUTH class resource MOUNT

The column “SimRC” reports that the simulated RC is 0 from the allocated RACF database (the offline RACF database), meaning that the user is authorized to READ this resource. Column “AccRC” reports a historic access result of RC=4, so adding the TSOAUTH class profile MOUNT authorizes this user to access the TSOAUTH MOUNT resource with READ access when you define the same profile in the active RACF database.

To review the details of the access event record, specify S again and press Enter (see Figure 3-26).

```
Line 1 of 47
ACCESS summary simulated access is more
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like TSOAUTH 17 Dec 2024 09:40

Access summary
- Security complex name      TVT6003
- RACF user ID              AXRUSER
- Access intent              READ
Record type                  Auth
System name                  ZS34
SAF resource class           TSOAUTH
SAF resource name            MOUNT
Timestamp of last occurrence  23Jun2024 11:51
Access count                  8824

Request flags                  Define flags
RACFIND                       Use internal RACROUTE AUTH
Limit to generics              No    Verify
Private/CSA (no global)        No    Propagated
Bypass JESSPOOL profiles       No
Command                        No
Retrieval of access allowed     No
```

Figure 3-26 Reviewing the access event details for the AXRUSER to TSOAUTH class resource MOUNT

When you review the detailed access events statistics, you find out which resource profile is selected as the best matching resource profile during the access simulation. Press F8 to scroll down (see Figure 3-27).

```

Line 30 of 47
ACCESS summary simulated access is more
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like TSOAUTH 17 Dec 2024 09:40

Global access table used      No      Installation exit used      No
Special authority used        No      Owner access                  No
Operations authority used     No

Access-time user attributes
User systemwide SPECIAL      No      Program status
User systemwide OPERATIONS   No      Defined program (any lib)
User systemwide (RO)AUDITOR   No      Controlled program
                                   Specific controlled program
                                   Controlled library (any pgm)

Current RACF database effect
RACF return code current DB   0
Authority used in current DB  ID_GROUP
RACF Profile type current DB  DISCRETE
_ RACF class and profile in DB TSOAUTH MOUNT
_ Profile owner                SYSAUTH
Installation data
Creation/definition date      16 Dec 2024
***** Bottom of Data *****

```

Figure 3-27 Reviewing which resource profile protects access to the TSOAUTH class resource MOUNT

The simulation access event details are shown in the section Current RACF database effect at the bottom of your display. From this section, you conclude that user AXRUSER is allowed READ access to the TSOAUTH class profile MOUNT that is granted to a group, as indicated by the ID_GROUP in the field Authority used in current DB.

When you are satisfied with the outcome of your access simulation, end your RACF-Offline session and define the TSOAUTH class profile MOUNT to the active RACF database.

Press F3 several times until you reach the ISPF Primary Option Menu. Specify option X to leave ISPF and return to your RACF-Offline session (see Figure 3-28 on page 49).

ISPF Primary Option Menu		
Option ==> X		
	More:	+
0	Settings	Terminal and user parameters
1	View	Display source data or listings
2	Edit	Create or change source data
3	Utilities	Perform utility functions
4	Foreground	Interactive language processing
5	Batch	Submit job for language processing
6	Command	Enter TSO or Workstation commands
7	Dialog Test	Perform dialog testing
9	IBM Products	IBM program development products
10	SCLM	SW Configuration Library Manager
11	Workplace	ISPF Object/Action Workplace
P	PRODUCTS	Dialogs for installed products
G	GROUP	Dialogs used with your organization
U	User	Your Own Dialogs
S	SDSF	System Display and Search Facility
C	Consul	Consul Risk Management applications
Enter X to Terminate using log/list defaults		

Figure 3-28 Exiting ISPF

Specify what you want to do with your ISPF Log Data Set. Press Enter to return to the RACF-Offline session (see Figure 3-29).

Specify Disposition of Log Data Set	
Command ==>	More: +
Log Data Set (CRMBTZ1.SPFL0G1.LIST) Disposition:	
Process Option 2	1. Print dataset and delete
	2. Delete dataset without printing
	3. Keep dataset - Same
	(allocate same dataset in next session)
Keep dataset - New	(allocate new dataset in next session)
Batch SYSOUT class . .	_____
Local printer ID or	_____
writer-name	_____
Local SYSOUT class . .	_____
List Data Set Options not available	
Press ENTER key to complete ISPF termination.	
Enter END command to return to the primary option menu.	
Job statement information: (Required for system printer)	
==>	_____
==>	_____
==>	_____

Figure 3-29 Specifying the Log Data Set disposition option

You return to the RACF-Offline interface. Specify the command end (see Figure 3-30) and press Enter to exit your RACF-Offline session.

```
CRMBTZ1.SPFLOG1.LIST has been deleted.
B8R200A Enter RACF Command or "END"
end
```

Figure 3-30 Exiting your RACF-Offline session

You are now in TSO READY mode. Next, specify ISPF here once more and press Enter. You return to the ISPF Primary Option Menu again, but you are no longer in a RACF-Offline session.

Start zSecure Admin by using your regular method. You can continue to use the same zSecure Admin input set that you used during your RACF-Offline session. Any RACF commands that you run are against the production RACF database because you are no longer inside a RACF-Offline session (see Figure 3-31).

```

                                zSecure Admin - Setup - Input files          Row 1 of 3
Command ==> _____ Scroll ==> CSR_

Description . . . . Recent RACF, CKFREEZE, ACCESS datasets_____
Complex . . . . . TVT6003_   Version . . . .   _____

Enter dataset names and types.          Type END or press F3 when complete.
Enter dsname with .* to get a list      Type SAVE to save set, CANCEL to quit.
Valid line commands: E L I R D          Type REFRESH to submit unload job.

      Dataset name or DSNPREF=, or Unix file name          Type or ?   NJE node
_   'CRMB.T.RACF.OFFLINE'          COPY.RACE_   _____
_   'CRMB.T.CKFREEZE'             CKFREEZE_   _____
_   'C2PACMON.TVT6003.Y12MON'      ACCESS_     _____
***** Bottom of data *****
```

Figure 3-31 Using the same input set for your zSecure Admin session

Because you still use your RACF-Offline database as input to this zSecure Admin session, you can define the TS0AUTH class profile MOUNT by copying it from your offline RACF database.

Select the option RA.R (RACF Administration General resource profiles) from the zSecure Admin Main menu and press Enter (see Figure 3-32 on page 51).


```

zSecure Admin - RACF - Resource Selection
Command ==> _____ _ start panel

_ Add new general resource profile or segment
Show general profiles that fit all of the following criteria
Class name . . . . TSOAUTH_ (class or filter)
Resource profile . mount_____

Owned by . . . . . _____ (group or userid, or filter)
Installation data . _____ (substring or *)

Additional selection criteria
_ Profile fields      _ Access list      _ Segment presence  _ Absence
_ Audit settings

Output/run options
_ Show segments      _ All              _ Enable full ACL  _ Specify scope
_ Show differences    _ Summarize by class
_ Print format        _ Customize title   Send as email
_ Background run      Full detail form    Sort differently   Narrow print
_ Print ACL           Resolve to users    Incl operations    Print names

```

Figure 3-32 Using the option RA.R to list details of the resource profile MOUNT in the TSOAUTH class

Specify the class name TSOAUTH and resource profile MOUNT, and press Enter to list the profile (see Figure 3-33).

```

zSecure Admin General resource overview
Command ==> _____ Scroll==> CSR_
Class TSOAUTH, like mount 16 Dec 2024 15:30
Class Profile key T UACC Owner S/F W
C_ TSOAUTH MOUNT NONE SYSAUTH R_
***** Bottom of Data *****

```

Figure 3-33 Copying the TSOAUTH class profile MOUNT

Specify C (Copy) to generate the appropriate RACF commands to copy the TSOAUTH class profile MOUNT to the production RACF database (see Figure 3-34).

zSecure Admin - RACF - Resource Copy

Command ==> _____

From class TSOAUTH

profile MOUNT

To class TSOAUTH_

profile MOUNT

1 1. Create permanent profile

1 1. Copy segments and members (commands are stored in CKRCMD)

2. Use "copy from" (does not copy segments and members)

_ RACF commands optimized for post-processing

2. Create temporary profile

Date of removal . . . _____ (ddmmmyyyy or yyyy-mm-dd or +days)

Reason _____

Figure 3-34 Copying the TSOAUTH class profile MOUNT to the TSOAUTH class MOUNT

Because the TSOAUTH class profile MOUNT does not yet exist in the active RACF database, you do not have to adjust the “To class” and “profile” specifications (see Figure 3-35). You can continue by pressing Enter to generate the commands.

Queued in CKRCMD

zSecure Admin General resource overview

Command ==> _____ Scroll==> CSR

Class TSOAUTH, like mount 17 Dec 2024 14:36

Class Profile key T UACC Owner S/F W

TSOAUTH MOUNT NONE SYSAUTH R

***** Bottom of Data *****

Figure 3-35 Commands to copy the TSOAUTH profile MOUNT that is queued in the CKRCMD work dataset

The message Queued in CKRCMD in the upper right of your panel states that the RACF commands were successfully generated in the CKRCMD work dataset. Press F3 to leave your panel and access the generated RACF commands in the CKRCMD work dataset (see Figure 3-36 on page 53).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          0.0 s CPU, RC=0
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to run commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001  /* CKRCMD file CKR1CMD complex TVT6003 generated 17 Dec 2024 14:36 */
000002  /* CKRCMD file CKRT1CMD complex TVT6003 NJE TVT6003 generated 17 Dec -
000003  2024 14:43 */
000004 rdefine  TSOAUTH  MOUNT +
000005          owner(SYSAUTH) +
000006          uacc(NONE) +
000007          audit(failures(READ))
000008 permit   MOUNT +
000009          class(TSOAUTH) +
000010          id(SYSPROG) access(READ)
000011 permit   MOUNT +
000012          class(TSOAUTH) +
000013          id(SYS1) access(READ)
000014 setropts refresh raclist(TSOAUTH)
***** ***** Bottom of Data *****

```

Figure 3-36 Commands to copy the TSOAUTH class MOUNT profile to MOUNT

Either specify GO to run the generated commands or press F3 to return to the zSecure Admin Results menu. As indicated by the message in the upper right of your panel, you can specify R (see Figure 3-37) and press Enter to run the commands.

```

                                zSecure Admin - Results      Enter R to run commands
Command ==> _____

The following selections are supported:
B Browse file                S Default action (for each file)
E Edit file                  R Run commands
P Print file                 J Submit Job to run commands
V View file                  M Email report
W Write file into seq. or partitioned dataset

Enter a selection in front of a highlighted line below:
_ SYSPRINT  messages
_ REPORT    printable reports
_ CKRTSPRT  output from the last TSO commands
R CKRCMD    queued TSO commands
_ CKR2PASS  queued commands for zSecure Admin
_ COMMANDS  zSecure Admin input commands from last query
_ SPFLIST   printable output from PRT primary command
_ OPTIONS   set print options

_ View files from recursive call (now on level 0)

```

Figure 3-37 Running commands to define the TSOAUTH class profile MOUNT to the production RACF database

The zSecure CKRTSPRT work dataset that shows the results of the run RACF commands is automatically transferred. Because there is no Command failed message in the upper right of the panel, all RACF commands ran successfully (see Figure 3-38).

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT          Line 0000000000 Col 001 080
Command ==> _____ Scroll ==> CSR_
***** Top of Data *****
=====
=== Multiple TSO command output file - scroll max down for overview ===
=== Input dataset CRMBTZ1.DATA.C2R1DC6.CKRCMD          ===
=====
=====
=== Commands for local node
=====
/* CKRCMD file CKR1CMD complex TVT6003 generated 17 Dec 2024 14:36 */
/* CKRCMD file CKRT1CMD complex TVT6003 NJE TVT6003 generated 17 Dec 2024 14:43

===== 17Dec24 14:53:23.51300 start record 4 =====
rdefine TSOAUTH MOUNT owner(SYSAUTH) uacc(NONE) audit(failures(READ))
ICH10006I RACLISTED PROFILES FOR TSOAUTH WILL NOT REFLECT THE ADDITION(S) UNTIL

===== 17Dec24 14:53:23.56440 start record 8 =====
permit MOUNT class(TSOAUTH) id(SYSPROG) access(READ)
ICH06011I RACLISTED PROFILES FOR TSOAUTH WILL NOT REFLECT THE UPDATE(S) UNTIL A

===== 17Dec24 14:53:23.57118 start record 11 =====

```

Figure 3-38 Output of the RACF commands to define the TSOAUTH class profile MOUNT

Optionally, you can press F8 to scroll down to the comment box that reports the message All commands completed successfully, as shown in Figure 3-39 on page 55.

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT          Line 0000000009 Col 001 080
Command ==> _____ Scroll ==> CSR
/* CKRCMD file CKRT1CMD complex TVT6003 NJE TVT6003 generated 17 Dec 2024 14:43

===== 17Dec24 14:53:23.51300 start record 4 =====
rdefine TSOAUTH MOUNT owner(SYSAUTH) uacc(NONE) audit(failures(READ))
ICH10006I RACLISTED PROFILES FOR TSOAUTH WILL NOT REFLECT THE ADDITION(S) UNTIL

===== 17Dec24 14:53:23.56440 start record 8 =====
permit MOUNT class(TSOAUTH) id(SYSPROG) access(READ)
ICH06011I RACLISTED PROFILES FOR TSOAUTH WILL NOT REFLECT THE UPDATE(S) UNTIL A

===== 17Dec24 14:53:23.57118 start record 11 =====
permit MOUNT class(TSOAUTH) id(SYS1) access(READ)
ICH06011I RACLISTED PROFILES FOR TSOAUTH WILL NOT REFLECT THE UPDATE(S) UNTIL A

===== 17Dec24 14:53:23.57784 start record 14 =====
setropts refresh raclist(TSOAUTH)
=====
=== All commands completed successfully ===
=====
***** Bottom of Data *****

```

Figure 3-39 The RACF commands to define the TSOAUTH class profile MOUNT ran successfully

The TSOAUTH class profile MOUNT was successfully added to your active RACF database. Your auditors now control access to the TSOAUTH class resource MOUNT.

This step concludes the walk-through to add the TSOAUTH class profile MOUNT to control access to this z/OS sensitive resource. Alternatively, you can use the same or a similar scenario to perform the following tasks:

- ▶ Add another resource profile for the TSOAUTH class resource CONOPER that is accessed through the authority DFLTRC (see Figure 3-6 on page 33).
- ▶ Report general resources in other general resource classes that were accessed through authority DFLTRC and define appropriate resource profiles for these resources.
- ▶ When you have not set SETROPTS PROTECTALL(FAIL), you can report which datasets are accessed through the authority UNPROT. Access simulation against the RACF database returns UNPROT when no best matching dataset profile is found to control access to this dataset. You can use this same scenario to set up dataset profiles to protect these datasets.



Removing unused security definitions

One of the most difficult tasks for IBM Resource Access Control Facility (RACF) security administrators is to keep the RACF database orderly, maintained, and compliant. Many RACF installations also cannot identify security definitions that were created in the past but are no longer needed or used, which cause security exposures that potentially give an attacker unintended access to a system and sensitive data.

The following topics are covered in this chapter:

- ▶ 4.1, “Challenges with unused RACF definitions” on page 58
- ▶ 4.2, “Keeping the RACF database orderly and maintained” on page 58
- ▶ 4.3, “Ensuring that only the required authorization is in place” on page 60
- ▶ 4.4, “Removing unused resource profiles” on page 60

4.1 Challenges with unused RACF definitions

RACF databases collect many unused or outdated profile definitions that make them harder and more labor-intensive to maintain. Also, passing audits is more challenging because auditors might pose questions about definitions that might not be used by the company. Also, unused security definitions can pose security risks because they can lead to further misconfigurations or unexpected permissions.

Some general reasons why a RACF database can become unstructured and not meet specified standards are as follows:

- ▶ RACF security administrators are often requested by business process owners to create certain RACF user, group, data set, or general resource profiles. However, when these profiles are no longer required, the security definitions are often not removed from RACF.
- ▶ Resource names are changed to adhere to a new naming convention standard, but the resource profiles that refer to the former resource names are not deleted.
- ▶ Security administrators are not informed when staff members leave the company, so their user IDs remain defined in the RACF database.
- ▶ Business processes or applications that were used in the past are changed, stopped, or superseded by other processes, tools, or applications. The required RACF security definitions to support the new or changed implementations are added to RACF, but the old definitions are not removed.

4.2 Keeping the RACF database orderly and maintained

As a best practice, RACF administrators should maintain the accuracy of their RACF database and keep the security definitions up to date. These actions help to minimize clutter that might cause problems for the administrators, auditors, compliance officers, users, or owners of the environment. The administrators should act on the following items:

- ▶ Addressing inactive users
- ▶ Addressing unused groups
- ▶ Addressing users with outdated group connections
- ▶ Removing unused resource profiles

This document does not specify a frequency for some of these checks because every environment is different. Depending on your business requirements and the frequency that certain applications or workloads run, you may want to deviate from these practices to some degree.

4.2.1 Addressing inactive users

Removing inactive users is a part of RACF database maintenance. Inactive users can have logon credentials through multiple means, with access to many types of applications and resources in the system. These users present an unnecessary security exposure that an attacker may use to gain access to a system and all the privileges that these users are assigned. There is also potential for deliberate misuse of these user IDs by former users of the system.

RACF includes several ways to minimize the risk that is associated with this problem. The [RACF Security Administrator's Guide](#) describes how to automatically revoke unused user IDs (INACTIVE option) in more detail. The INACTIVE option is a standard way of revoking users that have not had any activity in the environment for some time. However, without proper monitoring and configuration, this setting can be underused. Ensure that the frequency that is specified in revoking user IDs aligns with your security policies. Also, even with automatic revocation, you should still actively take steps to delete unused user IDs when you are aware of a personnel change.

Leaving inactive user IDs in your RACF environment is incompatible with a least-privilege environment where only the user IDs that are necessary should exist and have privileges. Therefore, keeping defined user IDs current is an important aspect of maintaining such an environment.

4.2.2 Addressing unused groups

Removing unused groups is another aspect of RACF database maintenance. These groups might still have connections to active users and access to resource profiles, and persist past important updates to your security environment because they might not be documented or monitored after they are relegated to obscurity. Like inactive users, these unused group profiles can provide unforeseen or outdated access to an attacker or malicious user with a connection to this group.

Leaving outdated groups in your RACF environment is incompatible with a least-privilege environment because they can lead to extraneous and outdated privileges for connected users. As such, keeping groups current is an important aspect of maintaining such an environment.

4.2.3 Addressing users with outdated group connections

Although sometimes you have groups that are no longer being used at all, there might be groups in your environment where the connected users no longer use this group connection. If so, it is vital to make sure that the security information in your environment is current and that these outdated connections are addressed. Users that are connected to groups that they no longer need can still use the permissions that are associated with these groups. This configuration enables unforeseen or outdated accesses by an attacker or malicious user with a connection.

Another concern that involves the maintenance of user and group profiles in a RACF environment is managing users with multiple differing job roles or groups. Unfortunately, users are not always removed from role-based groups that no longer align with their current job role. To help monitor this situation, review the groups and roles that a user uses to keep these group connections and permissions current. Groups that represent different job roles can be “incompatible” or even “toxic” with another job role. Users that are connected to incompatible or toxic groups might indicate that a change in job role or function for this user occurred that was not adequately administered in RACF.

RACF provides a useful option in the case where an administrator might not want to disconnect the group connection immediately. The CONNECT command contains a REVOKE option that enables an administrator to prevent a user from using a group connection to access resources while maintaining the existence of this connection. This REVOKE option for a connection enables an administrator to restore these permissions if this change is meant to be temporary, or to remove them after a job role change is validated.

Leaving outdated groups in your RACF environment is incompatible with a least-privilege environment because they can lead to extraneous and outdated privileges for connected users. As such, keeping these groups current is an important aspect of maintaining a least-privilege environment.

4.2.4 Removing unused resource profiles

Removing unused resource profiles is another aspect of RACF database maintenance. Just because a resource profile is no longer used does not mean that it no longer offers privileges to the users and groups in its access lists. These privileges are another unnecessary security exposure for an attacker to gain access to whatever functions or resources that this profile protects. There is also potential for inadvertent or deliberate misuse of these functions, resources, or datasets by users that might lead to more concerns in your environment.

Leaving unused resource profiles in your RACF environment is incompatible with a least-privilege environment where only the minimum privileges that are required for functions should be in place. As such, keeping resource profiles current is an important aspect of maintaining a least privilege environment.

4.3 Ensuring that only the required authorization is in place

Typically, businesses and organizations state in their security policies that the RACF security definitions must contain only profiles that are used to protect sensitive resources. However, how does a RACF security administrator know that the deletion of security definitions might result in started tasks, jobs, applications, or subsystems that no longer have the necessary authorization to work as expected?

A traditional method that is available for determining whether RACF definitions are used for access requests is to log all successful accesses to all resources to System Management Facilities (SMF). But, this solution is not feasible because of the sheer amount of SMF records that this implementation produces, and the required CPU time and storage.

Using zSecure Access Monitor, you can analyze and report the usage of profiles, group connections, and permissions. Optionally, zSecure Admin can generate the RACF commands to delete profiles, connections, or permissions that have not been used for a prolonged period, for example, over a year. Also, with RACF-Offline, you can validate that removing any such profile, connection, or permission would not have a negative system impact based on the captured data.

4.4 Removing unused resource profiles

The details for the general use case preparation steps that use automated (semi-) conversion and cleanup features in zSecure Admin are documented in 2.4, “General preparation steps for the use cases” on page 16, which include the following steps:

- ▶ Creating a RACF-Offline database
- ▶ Starting a RACF-Offline session
- ▶ Logging on to the RACF-Offline session
- ▶ Resetting the RACF-Offline log data set
- ▶ Starting and preparing your zSecure Admin session

After you complete these steps, you can continue with the subsequent steps to remove unused resource profiles:

- ▶ Generating RACF commands to clean up resource profiles
- ▶ Running generated RACF commands to clean up resource profiles
- ▶ Recovering deleted resource profiles
- ▶ Reporting the potential security impact of deleted unused RACF profiles
- ▶ Cleaning up unused profiles from the active primary RACF database
- ▶ Cleaning up other unused security definitions from the active primary RACF database

4.4.1 Generating RACF commands to clean up resource profiles

This section describes how to generate RACF commands to clean up the resource profiles that are not used.

In zSecure Admin, you can use option AM.8 (Remove) to automatically generate RACF commands to clean up profiles, permits, or connections that were not used during the last year according to Access Monitor.

To remove unused resource profiles, select option 1 and press Enter (see Figure 4-1).

zSecure Admin - Access - Remove		
Option ==> <u>1</u>		
1	Profiles	Remove unused profiles
2	Permits	Remove unused permits
3	Connects	Remove unused connects
Recovery command file		
<u>CRMBTZ1.PROFS.RECOVERY.CKRCMD</u>		

Figure 4-1 Selecting unused security definitions to remove

Note: You can customize the name of the automatically generated recovery command file. The commands in this recovery command file can be used to restore profiles that are cleaned up if you must rebuild the profile in its original state.

In the next panel (see Figure 4-2), you may remove unused profiles from all resource classes in the RACF database. In this example, the SURROGAT class is specified. Before pressing Enter, you must select the option Additional profile filters by entering S or / in front of the option. If you omit a class and RACF profile name in this panel, by default zSecure Admin generates delete commands to remove the unused profiles of all resource classes.

zSecure Admin - Access - Profiles

Command ==> _____

Remove unused profiles that fit all of the following criteria:
Class surrogat (class or EGN mask)
RACF profile name . . . _____

Advanced selection criteria
☒ Additional profile filters ☐ Date selection

Output options
☐ Background run

Figure 4-2 Specifying a class name to restrict your cleanup to a resource class

After pressing Enter, the “Further selection” panel opens (see Figure 4-3). To prevent the deletion of recently added SURROGAT profiles, for example, during the last 2 weeks, specify today-14 for the option Until, which verifies the profile creation date.

zSecure Admin - Access - Further selection

Command ==> _____

Access monitor records for classes like SURROGAT
Profile selection
Profile creation date _____ Until today-14
Discrete profiles . . . ☐ (Y/N)

Figure 4-3 Specifying additional profile filters on the Further selection panel

Press Enter to produce the automatically generated cleanup commands for unused profiles in the SURROGAT class (see Figure 4-4 on page 63).

```

                                zSecure Admin – Results                Use END for other files

COMMAND ==> _____ Scroll ==> CSR_

The following selections are supported:
B Browse file                      S Default action (for each file)
E Edit file                        R Run commands
P Print file                       J Submit Job to execute commands
V View file                       W Write file into seq. or partitioned data set
M E-mail report

CKRCMD for the specified environments:

Complex  Njenode  Rrsfnode  System  zSecNode #Lines
S TVT6003  <LOCAL>  ?        ZS34   ?        126
_ RECOVERY <LOCAL>  ?        ZS34   ?        591
***** Bottom of data *****

```

Figure 4-4 Cleanup and recovery commands for the SURROGAT class

Specify S to review the generated SURROGAT class cleanup commands and press Enter (see Figure 4-5).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD                      Columns 00001 00072
Command ==> _____ Scroll ==> CSR_
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to execute commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001 /* CKRCMD file CKR1CMD complex TVT6003 generated 1 Nov 2024 17:03 */
000002 rdelete SURROGAT *.SUBMIT /* 18 Jun 2021 */
000003 rdelete SURROGAT ALERT.SUBMIT /* 17 Mar 2014 */
000004 rdelete SURROGAT BCSCGB*.SUBMIT /* 16 Feb 2010 */
000005 rdelete SURROGAT BPX.SRV.ANONYMO /* 16 Feb 2010 */
000006 rdelete SURROGAT BPX.SRV.CRMBRT1 /* 15 Apr 2014 */
000007 rdelete SURROGAT BPX.SRV.CRMBVK2 /* 23 Sep 2020 */
000008 rdelete SURROGAT BPX.SRV.CRMBVK3 /* 21 Jul 2021 */
000009 rdelete SURROGAT BPX.SRV.GUEST /* 16 Feb 2010 */
000010 rdelete SURROGAT BPX.SRV.INTERNAL /* 16 Feb 2010 */

```

Figure 4-5 Reviewing the generated rdelete commands

zSecure Admin analyzes the allocated ACCESS data set to find SURROGAT class profiles for which no access decisions are found and then generates an RDELETE command for all SURROGAT profiles that were not used in any access decision during the past year.

Note: The profile creation date is reported as an “eye catcher” between CARLa Auditing and Reporting Language (CARLa) comment signs (/*... */). When you run the RDELETE commands, the commented sections are ignored.

Review the generated commands to help ensure that you do not delete needed profiles despite their non-usage. There might be plausible reasons that (some of) these SURROGAT profiles are not used:

- ▶ Some profiles are used only when your system is running from an alternative site.
- ▶ A security policy requires that all defined users and group profiles have a top generic hlq.** dataset profile that must be defined independent of whether these profiles are used.
- ▶ Some profiles might be used only in emergency situations.
- ▶ Other reasons might be valid for your company.

zSecure Admin cannot account for these company-specific security policies and implementations. Therefore, use your company knowledge and experience to prevent the automatic deletion of profiles that must not be deleted.

4.4.2 Running generated RACF commands to clean up resource profiles

This section describes how to run the generated RACF commands to clean up the resource profiles that are not used.

As shown in the =NOTE= lines at the top of Figure 4-5 on page 63, you can run the commands GO or RUN in the CLI to interactively run the cleanup commands. Alternatively, you can run the commands SUB or SUBMIT to submit a batch job to run the cleanup commands in the background. If so, you access the zSecure Submit menu (see Figure 4-6).

zSecure Admin - Submit menu

Option ===> _____

1	View	View JCL
2	Edit	Edit JCL
3	Submit	Submit JCL for execution
4	Cancel	Do not submit the JCL
5	Select	Select an alternate set of input files

Batch input files Active RACF backup, CKFREEZE, ACCESS datasets

Job statement information: (Verify before proceeding)

> //CRMBTZ1A JOB , 'TOM ZEEHANDELAAR', TIME=(10), NOTIFY=&SYSUID, MSGCLASS=V

> _____

> _____

> _____

Figure 4-6 zSecure Admin Submit menu

When you access the zSecure Admin Submit menu for the first time, the “Job statement information” field might not be populated. If so, specify a job card that is valid on your installation. You can select the options 1 (View JCL) or 2 (Edit JCL) to access the JCL of the batch job before submitting the job with option 3 (Submit JCL) for running commands.

Instead of running or submitting the commands directly from within the CKRCMD work data set, press F3 to return to the Results panel (see Figure 4-7). On this panel, depending on your preferences, you can run or submit the cleanup commands for the SURROGAT class profiles from here.

```

                                zSecure Admin - Results          Enter R to run commands

COMMAND ==> _____ Scroll ==> CSR

The following selections are supported:
B Browse file                      S Default action (for each file)
E Edit file                        R Run commands
P Print file                       J Submit Job to execute commands
V View file                        W Write file into seq. or partitioned data set
M E-mail report

CKRCMD for the specified environments:

   Complex   Njenode   Rrsfnod   System   zSecNode #Lines
R TVT6003   <LOCAL>   ?       ZS34     ?       126
_ RECOVERY  <LOCAL>   ?       ZS34     ?       591
***** Bottom of data *****

```

Figure 4-7 Running the cleanup commands in the foreground

After you press Enter, the cleanup commands run against the offline RACF database. The CKRTSPRT work dataset that reports the results of the RACF cleanup commands automatically transfers (see Figure 4-8).

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT          Line 0000000000 Col 001 080
Command ==> _____ Scroll ==> CSR
***** Top of Data *****
=====
=== Multiple TSO command output file - scroll max down for overview ===
=== Input data set CRMBTZ1.DATA.C2R1DC6.CKRCMD                        ===
=====
=====
=== Commands for local node
=====
/* CKRCMD file CKR1CMD complex TVT6003 generated  5 Nov 2024 11:17 */

===== 5Nov24 11:18:10.40828 start record 2 =====
rdelete  SURROGAT *.SUBMIT /* 18 Jun 2021 */
ICH12002I RACLISTED PROFILES FOR SURROGAT WILL NOT REFLECT THE DELETION(S)
UNTIL

===== 5Nov24 11:18:10.41639 start record 3 =====
rdelete  SURROGAT ALERT.SUBMIT /* 17 Mar 2014 */
ICH12002I RACLISTED PROFILES FOR SURROGAT WILL NOT REFLECT THE DELETION(S)
UNTIL

===== 5Nov24 11:18:10.42267 start record 4 =====
rdelete  SURROGAT BCSCGB*.SUBMIT /* 16 Feb 2010 */

```

Figure 4-8 Reviewing the output of running the cleanup commands

If one of the cleanup commands failed, the message Command failed shows up in the upper right of your panel. If so, a reference to the record number of the commands that failed is reported at the bottom of the CKRTSPRT work data set. Specify the command M (Maximum) in the CLI, and press F8 to scroll to the bottom of the output (see Figure 4-9 on page 67).


```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT           Line 0000000493 Col 001 080
Command ==> _____ Scroll ==> CSR

===== 5Nov24 11:18:11.11977 start record 123 =====
rdelete SURROGAT TWS.SUBMIT /* 26 Mar 2014 */
ICH12002I RACLISTED PROFILES FOR SURROGAT WILL NOT REFLECT THE DELETION(S)
UNTIL

===== 5Nov24 11:18:11.12590 start record 124 =====
rdelete SURROGAT U807018.SUBMIT /* 16 Feb 2010 */
ICH12002I RACLISTED PROFILES FOR SURROGAT WILL NOT REFLECT THE DELETION(S)
UNTIL

===== 5Nov24 11:18:11.13163 start record 125 =====
rdelete SURROGAT WZ903007.SUBMIT /* 16 Feb 2010 */
ICH12002I RACLISTED PROFILES FOR SURROGAT WILL NOT REFLECT THE DELETION(S)
UNTIL

===== 5Nov24 11:18:11.13816 start record 126 =====
rdelete SURROGAT Z714240.SUBMIT /* 16 Feb 2010 */
ICH12002I RACLISTED PROFILES FOR SURROGAT WILL NOT REFLECT THE DELETION(S)
UNTIL

=====
=== All commands completed successfully ===
=====
***** Bottom of Data *****

```

Figure 4-9 Confirm successful execution of cleanup commands

As expected, all cleanup commands ran successfully. Pressing F3 returns you to the results panel.

4.4.3 Recovering deleted resource profiles

This section describes how to review and save the RACF commands for recovering deleted resource profiles that are not used.

The RECOVERY dataset contains more lines than the cleanup data set (as reported in the #Lines column) (see Figure 4-10). There is a higher number of lines in the RECOVERY data set because rebuilding a deleted profile requires multiple commands to redefine the resource profile and populate the access control list (ACL) and conditional ACL (CACL) with their original permissions. You can use the commands S, V, B, or E to review or edit the RACF commands to recover the SURROGAT profiles that you deleted from the offline RACF database. These SURROGAT profiles still exist in the primary RACF database at this stage.

```
zSecure Admin – Results      Enter R to run commands
COMMAND ==> _____ Scroll ==> CSR

The following selections are supported:
B Browse file                S Default action (for each file)
E Edit file                  R Run commands
P Print file                 J Submit Job to execute commands
V View file                  W Write file into seq. or partitioned data set
M E-mail report

CKRCMD for the specified environments:

Complex  Njenode  Rrsfnode  System  zSecNode #Lines
TVT6003  <LOCAL>   ?         ZS34    ?        126
S RECOVERY <LOCAL> ?         ZS34    ?        591
***** Bottom of data *****
```

Figure 4-10 Access recovery commands to rebuild deleted commands

The top of the RECOVERY work data set shows the rdefine commands to rebuild the SURROGAT profiles that you removed during your cleanup activity (see Figure 4-11). When you scroll down, you also encounter the required permit commands to restore the IDs and access levels that the original profile contained before you deleted it.

```

EDIT          CRMBTZ1.PROFS.RECOVERY.CKRCMD          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to execute commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001 /* CKRCMD file CKR1RECV complex RECOVERY @#$@ generated 1 Nov 2024 -
000002 17:03 */
000003 rdefine SURROGAT *.SUBMIT owner(SYSAUTH) audit(failures(READ)) -
000004 uacc(NONE )
000005 rdefine SURROGAT ALERT.SUBMIT owner(SYSAUTH) audit(all(READ)) -
000006 uacc(NONE )
000007 rdefine SURROGAT BCSCGB*.SUBMIT owner(SYSAUTH) audit(all(READ)) -
000008 uacc(NONE )
000009 rdefine SURROGAT BPX.SRV.ANONYMO owner(SYSAUTH) audit(all(READ)) -
000010 uacc(NONE )
000011 rdefine SURROGAT BPX.SRV.CRMBRT1 owner(SYSAUTH) audit(all(READ)) -
000012 uacc(ALTER )
000013 rdefine SURROGAT BPX.SRV.CRMBVK2 owner(SYSAUTH) audit(all(READ)) -
000014 uacc(NONE )
000015 rdefine SURROGAT BPX.SRV.CRMBVK3 owner(SYSAUTH) audit(all(READ)) -
000016 uacc(NONE )
000017 rdefine SURROGAT BPX.SRV.GUEST owner(SYSAUTH) audit(all(READ)) -

```

Figure 4-11 Reviewing or editing recovery commands to rebuild the deleted SURROGAT profiles

The purpose of these RECOVERY commands is that they can quickly restore profiles when the cleanup causes security issues. As a best practice when running cleanup commands against the primary RACF database, save these RECOVERY commands to a permanent data set and put that data set in quarantine for a period, for example, 3 - 12 months after the cleanup. This approach enables you to restore the original SURROGAT profile if necessary. Press F3 to return to the results panel.

Specify the command W (Write) before the RECOVERY data set to save the commands in a sequential data set or partitioned data set of your preference (see Figure 4-12).

zSecure Admin – Results		Enter R to run commands
COMMAND ==>	Scroll ==> <u>CSR</u>	
The following selections are supported:		
B Browse file	S Default action (for each file)	
E Edit file	R Run commands	
P Print file	J Submit Job to execute commands	
V View file	W Write file into seq. or partitioned data set	
M E-mail report		
CKRCMD for the specified environments:		
Complex	Njenode	Rrsfnode System zSecNode #Lines
TVT6003	<LOCAL>	? ZS34 ? 126
<u>W</u> RECOVERY	<LOCAL>	? ZS34 ? 591
***** Bottom of data *****		

Figure 4-12 Saving the recovery commands for potential later use

Pressing Enter shows the panel where you specify the data set or PDS in which you want to save the recovery commands, which in this example are commands for the deleted SURROGAT class profiles (see Figure 4-13).

zSecure Admin - Results of last query	
Command ==>	
Write the zSecure Admin+Audit for RACF message file to the following dataset:	
Data set name	'CRMB.T.RACF.RECOVERY.COMMANDS'
Member	<u>SURROGAT</u>
Disposition	<u>2</u> 1. Append 2. Overwrite 3. Generate
Processing option after Write completed:	
Go into Edit	<u>Y</u> (Y/N)

Figure 4-13 Specifying a location for saving your SURROGAT class recovery commands

Optionally, to access the saved recovery commands at the specified location, specify Y at the option Go into Edit (see Figure 4-14 on page 71).

```

EDIT          CRMB.T.RACF.RECOVERY.COMMANDS(SURROGAT) - 01.00 Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
==MSG> -Warning- The UNDO command is not available until you change
==MSG>          your edit profile using the command RECOVERY ON.
000001 /* CKRCMD file CKR1RECV complex RECOVERY @$@$ generated 1 Nov 2024 -
000002 17:03 */
000003 rdefine SURROGAT *.SUBMIT owner(SYSAUTH) audit(failures(READ)) -
000004 uacc(NONE )
000005 rdefine SURROGAT ALERT.SUBMIT owner(SYSAUTH) audit(all(READ)) -
000006 uacc(NONE )
000007 rdefine SURROGAT BCSCGB*.SUBMIT owner(SYSAUTH) audit(all(READ)) -
000008 uacc(NONE )
000009 rdefine SURROGAT BPX.SRV.ANONYMO owner(SYSAUTH) audit(all(READ)) -
000010 uacc(NONE )
000011 rdefine SURROGAT BPX.SRV.CRMBRT1 owner(SYSAUTH) audit(all(READ)) -
000012 uacc(ALTER )
000013 rdefine SURROGAT BPX.SRV.CRMBVK2 owner(SYSAUTH) audit(all(READ)) -
000014 uacc(NONE )
000015 rdefine SURROGAT BPX.SRV.CRMBVK3 owner(SYSAUTH) audit(all(READ)) -
000016 uacc(NONE )
000017 rdefine SURROGAT BPX.SRV.GUEST owner(SYSAUTH) audit(all(READ)) -

```

Figure 4-14 Accessing the data set containing your SURROGAT class recovery commands

If you must rebuild a SURROGAT profile in the future, run only the relevant redefine and permit commands to restore the SURROGAT profile that you intend to restore. However, at this stage you might not know whether this cleanup action might have a security impact. Press F3 several times until you reach the zSecure Admin RACF Access Monitor panel.

4.4.4 Reporting the potential security impact of deleted unused RACF profiles

This section describes how to report the potential security impact of the deletion of unused profiles.

The SURROGAT profiles that Access Monitor indicated were not used during the last year were successfully deleted from the offline RACF database that you allocated as input. Next, you can use the Compare function, which uses the identical access data set that you used for the cleanup as input, and then simulates all recorded access events from last year against the allocated RACF input source. Your session uses the offline RACF database that no longer contains unused SURROGAT class profiles. The return code (SimRC) of each simulated access event is compared to the historic return code (AccRC) of the event.

To start the Compare function, specify option 2 (Compare) and press Enter (see Figure 4-15).

zSecure Admin - Access		
Option ==> 2		
		More: +
1	Access	Access summary by user or profile
2	Compare	Compare monitored access against current RACF database
3	Permit usage	Permit usage information for current RACF database
4	Connect usage	Connect usage information for current RACF database
5	Profile usage	Profile usage information for current RACF database
6	Member usage	Member usage information for current RACF database
7	Global usage	Global usage summary for current RACF database
8	Remove	Remove unused profiles and authorizations
9	Cleanup	Remove permits, dataset and general resource profiles
V	ID verify	ID verification (logon/start/job-start) summary
I	ID usage	ID usage information for current RACF database
U	Unix events	Access summary for unix events by user, uid/gid, or path

Figure 4-15 Comparing monitored access against the RACF database

On the Compare panel, specify that you want to restrict the Compare function to the SURROGAT class by entering surrogat for the option SAF resource class.

Because you want to forecast the possible security impact of your cleanup commands, use the filters in the “Comparison selection” section of this panel to omit occurrences where the historic AccRC is the same as the simulated SimRC. By removing the / in the Simulated results line before the option Same, your generated report includes only results where the historic and simulated return codes are not the same. That result might indicate that your cleanup commands impact security because users have less or more access than before your cleanup of the unused SURROGAT profiles. Optionally, you can also specify 2 in the “Output/run options” section to summarize by resource rather than by user ID (see Figure 4-16 on page 73).

```

zSecure Admin - Access - Compare
Command ==> _____

Show records that fit all of the following criteria:
Userid . . . . . _____ (userid or EGN mask)
Complex . . . . . _____ (complex or EGN mask)
SAF resource class . . surrogat (class or EGN mask)
SAF resource name . . . _____
RACF match on . . . . . _____
Comparison selection
Simulated results . . . _ Same      / Less      / More
Profile used . . . . . 3 1. Same  2. Different 3. All

Advanced selection criteria
_ Further selection _ Date selection _ Current RACF DB selection

Output/run options
2 1. Summarize by userid 2. Summarize by member class and profile
_ Show configured fields _ Timezone (U/L/H)
_ Print format           _ Customize title      Send as e-mail
_ Background run         _ Full page form

```

Figure 4-16 Reporting access events where historic and simulated access have a different return code

Press Enter to generate the simulation reports (see Figure 4-17).

```

zSecure Admin Display Selection      0 s elapsed, 0.1 s CPU
Command ==> _____ Scroll==> CSR

Name      Summary Records Title
_ SIMLESSD      0      0 ACCESS summary simulated access is less
3 SIMMORED      1      1 ACCESS summary simulated access is more
***** Bottom of Data *****

```

Figure 4-17 Access simulation reports generated

The 0 records statistic that shows for the report SIMLESSD indicates that the cleanup commands for the SURROGAT profiles do not impact security. All users that accessed SURROGAT resources during the last year still have the same access after the cleanup of the unused SURROGAT profiles.

However, when you look at the report SIMMORED, it shows one record where the simulated access decision enables more access at the time of the event.

Specify S to access the details of the report SIMMORED (see Figure 4-18).

```

Line 1 of 1
ACCESS summary simulated access is more
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like SURROGA 5 Nov 2024 11:34
  Occurrence Class      First occurrenc Last occurrence
    1 SURROGAT 12Mar2024 19:42 12Mar2024 19:42
  Occurrence Profile key used
    1 CRMBAH2.SUBMIT
  Occurrence Intent    Type    RetAll AccRC SimRC
    1 ALTER    Auth              8      4
  Occurrence Resource
    1 CRMBAH2.SUBMIT
  Occurrence Userid    Name
    1 CRMBAH2    SYSPROG2 AH
  Occurrence Complex    Syst RGPJCAVP GUGSOPGX0 SOA PCSL First occurrence Last oc
    1 TVT6003    ZS34      C              12Mar2024 19:42 12Mar20
  Occurrence Timestamp
    1 12Mar2024 19:42
S
***** Bottom of Data *****

```

Figure 4-18 Simulated access decision enables more access than the historic access decision

This SIMMORED report shows one occurrence where the RC at the time of the event was 8, as reported in the column AccRC, and the simulated access RC, shown in column SimRC, is 4. This SimRC 4 value indicates that no profile was found in the allocated RACF database that protects the SURROGAT class resource CRMBAH2.SUBMIT.

Specify S in the last line and press Enter to access the details of the access record (see Figure 4-19 on page 75).


```

Line 1 of 47
ACCESS summary simulated access is more
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like SURROGA 5 Nov 2024 11:34

Access summary
- Security complex name      TVT6003
- RACF userid                CRMBAH2  SYSPROG2 AH
- Access intent              ALTER
Record type                  Auth
System name                  ZS34
SAF resource class           SURROGAT
- SAF resource name          CRMBAH2.SUBMIT
Timestamp of last occurrence  12Mar2024 19:42
Access count                  1

Request flags                  Define flags
RACFIND                       Use internal RACROUTE AUTH
Limit to generics             No    Verify
Private/CSA (no global)       No    Propagated
Bypass JESSPOOL profiles      No
Command                       Yes

```

Figure 4-19 Reviewing the access record details

The Command flag reports Yes.

Hover your cursor over the field Command or Yes, and press F1 to access the field-sensitive help information for this request flag (see Figure 4-20).

```

CARLa field      : REQ_COMMAND
Newlist type     : ACCCES
Header default   : Cmd
Field prefix header: Command

This flag field (YES/NO) indicates whether the event occurred as the
result of a RACF command. This can be because the command flag was set on
the RACROUTE macro, or because the data collector found an active RACF
command.

The field is present in DEFINE and AUTH records.

```

Figure 4-20 Reviewing the help information about the meaning of the Command flag

The help information explains that the occurrence comes from a RACF command that was run by user CRMBAH2.

Press F3 several times to add an extra filter to the simulation reports to suppress access events that are reported as the result of a RACF command, which does not represent a real access event. Back on the Compare panel, activate the “Further selection” panel by tagging it with /, and press Enter. The previous selection criteria that you used are saved in your ISPF session automatically (see Figure 4-21).

zSecure Admin - Access - Compare		0.1 s CPU, RC=4
Command ==> _____		
Show records that fit all of the following criteria:		
Userid	_____	(userid or EGN mask)
Complex	_____	(complex or EGN mask)
SAF resource class . .	<u>SURROGAT</u>	(class or EGN mask)
SAF resource name . . .	_____	
RACF match on	_____	
Comparison selection		
Simulated results	Same / Less / More	
Profile used	<u>3</u> 1. Same 2. Different 3. All	
Advanced selection criteria		
/ Further selection	_ Date selection	_ Current RACF DB selection
Output/run options		
<u>1</u> 1. Summarize by userid	2. Summarize by member class and profile	
_ Show configured fields	_ Timezone (U/L/H)	
_ Print format	Customize title	Send as e-mail
Background run	Full page form	

Figure 4-21 Rerunning the Compare function with additional selection filters

After pressing Enter, the “Further selection” panel opens. Specify N (No) to suppress access events from your reports that occurred as a result of a RACF command that was issued (see Figure 4-22 on page 77).

```

zSecure Admin - Access - Further selection
Command ==> _____
Access monitor records for Classes like SURROGAT

Select access records(Y/N/blank)
N Use of RACF commands           - Retrieval of access allowed
- Use of global access checking table - Bypass JESSPOOL profiles
- Use of discrete profiles         - ID was undefined during event
- System special authority used    - User had special attribute
- Operations authority used        - User had operations attribute
- Installation exit used           - User had (ro)auditor attribute
- User requesting access is owner

Resource action  Intended access  Result          Program status
- Define        - 1. Read        - Success        Defined program
- Delete        - 2. Update      - No profile      Controlled program
- Addvol        - 3. Control   - Not authorized  Specific program
- Chgvol        - 4. Alter     - Other          Controlled library

```

Figure 4-22 Rerunning the Compare function with the RACF commands suppressed

Press Enter to generate the compare reports again (see Figure 4-23).

```

zSecure Admin Display Selection          0 s elapsed, 0.1 s CPU
Command ==> _____ Scroll==> CSR_

Name      Summary Records Title
- SIMLESSD      0      0 ACCESS summary simulated access is less
- SIMMORED      0      0 ACCESS summary simulated access is more
***** Bottom of Data *****

```

Figure 4-23 Regenerating access simulation reports

This result indicates that the cleanup of the SURROGAT profiles does not have a negative or positive security impact if the same access events that occurred last year for SURROGAT resources occur today against the cleaned RACF-Offline database.

This result does not mean that there is a 100% certainty that this cleanup does not have any security impact when you run it against the active primary RACF database. For example, historic SURROGAT access events occurring more than 1 year ago might still produce a violation when certain SURROGAT class profiles are no longer defined. But at minimum, you can feel confident that your cleanup does not result in major incidents that cause important jobs to fail, such as started tasks failing or running with reduced authorization, or subsystems or applications that no longer function as expected.

When you run the Compare reports option on your z/OS systems, other issues might be reported. For example, these issues can be caused by changes that were made to the RACF database that you copied to define your RACF-Offline database but that are not covered in your 12-month rolling ACCESS data set. If so, investigate whether the issues that are reported in the SIMLESSD or SIMMORED reports are caused by the cleanup of the profiles or are they related to a resource profile that you did not touch during your cleanup. If you run this same Compare report against the active primary RACF database (that still contains the unused SURROGAT class profiles) and the same occurrences are reported, it indicates that there is an issue that is not caused by your cleanup activities.

Sometimes, you might find occurrences in the SIMLESSD or SIMMORED reports that are related to profiles that you deleted. If for whatever reason you cannot explain the issue, you can always decide not to delete the involved resource profile by removing the corresponding commands from the cleanup commands data set before running the commands.

When you are satisfied with the outcome of the Compare reports, after analyzing and resolving the reported issues, end your RACF-Offline session and run the cleanup against the active primary RACF database.

Press F3 several times until you reach the ISPF Primary Option Menu. Specify option X to leave ISPF and return to RACF-Offline (see Figure 4-24).

Option ==> X			ISPF Primary Option Menu
	More:	+	
0	Settings	Terminal and user parameters	User ID . : CRMBTZ1
1	View	Display source data or listings	Time. . . : 17:19
2	Edit	Create or change source data	Terminal. : 3278
3	Utilities	Perform utility functions	Screen. . : 1
4	Foreground	Interactive language processing	Language. : ENGLISH
5	Batch	Submit job for language processing	Appl ID . : ISR
6	Command	Enter TSO or Workstation commands	TSO logon : TSOZSEC
7	Dialog Test	Perform dialog testing	TSO prefix: CRMBTZ1
9	IBM Products	IBM program development products	System ID : TVT6003
10	SCLM	SW Configuration Library Manager	MVS acct. : ACCT#
11	Workplace	ISPF Object/Action Workplace	Release . : ISPF 8.1
P	PRODUCTS	Dialogs for installed products	
G	GROUP	Dialogs used with your organization	
U	User	Your Own Dialogs	
S	SDSF	System Display and Search Facility	
C	Consul	Consul Risk Management applications	
Enter X to Terminate using log/list defaults			

Figure 4-24 Exiting ISPF

Specify what you want to do with your ISPF Log Data Set. Press Enter to reach the READY mode (see Figure 4-25 on page 79).

Specify Disposition of Log Data Set	
Command ==>	_____
	More: +
Log Data Set (CRMBTZ1.SPFL0G1.LIST) Disposition:	
Process Option 2	1. Print data set and delete 2. Delete data set without printing 3. Keep data set - Same (allocate same data set in next session) 4. Keep data set - New (allocate new data set in next session)
Batch SYSOUT class	_____
Local printer ID or	
writer-name	_____
Local SYSOUT class	_____
List Data Set Options not available	
Press ENTER key to complete ISPF termination.	
Enter END command to return to the primary option menu.	
Job statement information: (Required for system printer)	
==>	_____
==>	_____
==>	_____

Figure 4-25 Specifying the Log Data Set disposition option

When you return to the RACF-Offline interface, specify end and press Enter to exit your RACF-Offline session (see Figure 4-26).

CRMBTZ1.SPFL0G1.LIST has been deleted.
B8R200A Enter RACF Command or "END"
end

Figure 4-26 Exiting your RACF-Offline session

You are back in TSO READY mode. Specify ISPF and press Enter. You return to the ISPF Primary Option Menu again, but you are no longer in a RACF-Offline session.

4.4.5 Cleaning up unused profiles from the active primary RACF database

This section describes how to clean up unused profiles from the active primary RACF database.

Run the cleanup of the unused SURROGAT profiles against the active primary RACF database. You can use the following two options to clean up the unused SURROGAT profiles:

- ▶ Rerun the logged RACF commands from your RACF-Offline session against the active RACF database.
- ▶ Rerun option AM.8.1 for the SURROGAT class and run the commands against the active RACF database.

Rerunning the logged RACF commands against the active RACF database

You can decide to rerun the RDELETE commands from your RACF-Offline log data set CRMB.T.RACF.OFFLINE.B8RLOG. You might prefer to run the commands in the background by using a batch job.

Alternatively, you can run the collected commands interactively by copying the RACF commands that are collected in the data set CRMB.T.RACF.OFFLINE.B8RLOG to your CKRCMD work data set. Run the commands in the CLI of any zSecure panel and press Enter to access the zSecure work datasets. Specify E (Edit) before the CKRCMD data set (see Figure 4-27) and press Enter.

zSecure Admin - Results

Command ==> _____

The following selections are supported:

B Browse file	S Default action (for each file)
E Edit file	R Run commands
P Print file	J Submit Job to execute commands
V View file	M E-mail report
W Write file into seq. or partitioned data set	

Enter a selection in front of a highlighted line below:

- SYSPRINT messages
- REPORT printable reports
- CKRTSPRT output from the last TSO commands
- E** CKRCMD queued TSO commands

- CKR2PASS queued commands for zSecure Admin+Audit for RACF
- COMMANDS zSecure Admin+Audit for RACF input commands from last query
- SPFLIST printable output from PRT primary command
- OPTIONS set print options

Figure 4-27 Accessing the CKRCMD work data set in edit mode

Specify COPY 'crmb.t.racf.offline.b8rlog' in the CLI and press Enter to copy the logged RACF-Offline commands to the CKRCMD work data set (see Figure 4-28 on page 81).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          Data set copied
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to execute commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001 CKGRACF show myaccess
000002 RDELETE SURROGAT *.SUBMIT /* 18 Jun 2021 */
000003 RDELETE SURROGAT ALERT.SUBMIT /* 17 Mar 2014 */
000004 RDELETE SURROGAT BCSCGB*.SUBMIT /* 16 Feb 2010 */
000005 RDELETE SURROGAT BPX.SRV.ANONYMO /* 16 Feb 2010 */
000006 RDELETE SURROGAT BPX.SRV.CRMBRT1 /* 15 Apr 2014 */
000007 RDELETE SURROGAT BPX.SRV.CRMBVK2 /* 23 Sep 2020 */
000008 RDELETE SURROGAT BPX.SRV.CRMBVK3 /* 21 Jul 2021 */
000009 RDELETE SURROGAT BPX.SRV.GUEST /* 16 Feb 2010 */
000010 RDELETE SURROGAT BPX.SRV.INTERNAL /* 16 Feb 2010 */
000011 RDELETE SURROGAT BPX.SRV.OMVSKERN /* 24 Jul 2019 */
000012 RDELETE SURROGAT BPX.SRV.PRIVATE /* 16 Feb 2010 */
000013 RDELETE SURROGAT BPX.SRV.PUBLIC /* 16 Feb 2010 */
000014 RDELETE SURROGAT BPX.SRV.WEBADM /* 7 Jul 2003 */
000015 RDELETE SURROGAT CICSUSER.DFHINSTL /* 16 Feb 2010 */
000016 RDELETE SURROGAT CKNSERV%.SUBMIT /* 18 May 2010 */
000017 RDELETE SURROGAT CRMA.DFHINSTL /* 16 Feb 2010 */

```

Figure 4-28 Copying the cleanup commands from the RACF-Offline log data set to the CKRCMD work data set

You can run the commands interactively by running the command GO or RUN in the CLI or submit them in the background by running the command SUB or SUBMIT.

The cleanup of unused SURROGAT profiles is complete.

Rerunning option AM.8.1 against the active RACF database

For this option, you must switch the input of your zSecure Admin session to use a different RACF input source (active primary RACF, active backup, recent UNLOAD, or a recent full RACF backup) than your offline RACF database by selecting option SE.1 (see Figure 4-29).

```

                                zSecure Admin – Setup – Input files          Row 1 of 3
Command ==> _____ Scroll ==> CSR

Description . . . . Active RACF backup, CKFREEZE, ACCESS datasets_____
Complex . . . . . TVT6003 Version . . . . ____

Enter data set names and types.          Type END or press F3 when complete.
Enter dsname with .* to get a list       Type SAVE to save set, CANCEL to quit.
Valid line commands: E L I R D           Type REFRESH to submit unload job.

      Data set name or DSNPREFIX, or Unix file name          Type or ?   NJE node
      - DATA SET NAME DYNAMICALLY OBTAINED FROM COMMON STORAGE ACT.BACK _____
      - 'CRMB.T.CKFREEZE'                                   CKFREEZE _____
      - 'C2PACMON.TVT6003.Y12MON'                           ACCESS _____
***** Bottom of data *****

```

Figure 4-29 Selecting the input set with the active RACF database allocated

Rerun option AM.8.1 again against the active RACF database that you allocated with option SE.1, which still contains the unused SURROGAT class profiles (see Figure 4-30).

```

                                zSecure Admin - Results Enter R to run commands
COMMAND ==> _____ Scroll ==> CSR

The following selections are supported:
B Browse file                      S Default action (for each file)
E Edit file                        R Run commands
P Print file                      J Submit Job to execute commands
V View file                      W Write file into seq. or partitioned data set
M E-mail report

CKRCMD for the specified environments:

   Complex   Njenode   Rrsfnode   System   zSecNode #Lines
R TVT6003   <LOCAL>   ?         ZS34     ?       126
_ RECOVERY  <LOCAL>   ?         ZS34     ?       591
***** Bottom of data *****

```

Figure 4-30 Rerunning the SURROGAT class cleanup commands against the active RACF database

As expected, the same 126 lines of cleanup commands for the SURROGAT class are generated for the complex that is named TVT6003. When you specify R (Run) commands and press Enter, the unused SURROGAT class profiles are successfully removed from the active RACF database.

4.4.6 Cleaning up other unused security definitions from the active primary RACF database

This section describes how to clean up other unused security definitions from the active primary RACF database.

You can continue cleaning up unused resource profiles from other classes by using this same methodology and following the same steps multiple times.

Similarly, you can also perform a similar scenario with option AM.8.2 to remove unused permissions from the ACLs of resource profiles that, according to the consolidated year of Access Monitor records, are not used to access protected resources.

You can use option AM.8.3 to remove user to group connections where, according to Access Monitor records, the user did not use their group connection to access resources that are permitted to their connect group.

In addition, you can also use options AM.V (ID verify) or AM.I (ID usage) to analyze the usage of defined user IDs. You can use these options to report user IDs that are good candidates for deletion because these IDs were not used during the last year. However, these options do not automatically generate RACF commands to delete these unused user IDs, including all their references.

zSecure Admin can delete user IDs including the resource profiles that they own, RACF variables they are part of, master and user catalog entries, and even the datasets that start with that user ID. You can even code a scheduled CARLa script that automatically scans for user IDs whose last used date is more than 1 year old and generates automatic RACF commands to perform a clean sweep of all datasets, catalog pointers, dataset and general resource profiles, and the concerning user profiles. Such a script is outside the scope of this publication.



Converting generic and specific access to group-based access

Another key aspect of maintaining a long-term IBM Resource Access Control Facility (RACF) environment is helping to ensure that security policies align with a group or role-based access control (RBAC) model. You can establish either profiles that are generic enough to satisfy all users or simple enough to satisfy a specific user making a request, which helps ensure the health of the environment and the hardening of your security posture.

The following topics are covered in this chapter:

- ▶ 5.1, “Challenges with generic and specific access permissions” on page 86
- ▶ 5.2, “Moving toward role-based access control” on page 86
- ▶ 5.3, “Establishing groups that accurately reflect user roles” on page 89
- ▶ 5.4, “Converting to group-based access” on page 90

5.1 Challenges with generic and specific access permissions

Specific access permissions, like personalized access permissions, can be secure but make databases difficult to maintain and audit because they provide little context about what job role a particular user performs that requires access to a similar application. Also, users might change job roles and migrate away from their initial privileges. Generic access permissions, like universal access (UACC) to all users, lead to more simplified database management, but lack the concept of individual accountability, which might lead to harmful security gaps.

Some reasons for the existence of generic access permissions are as follows:

- ▶ When new applications are configured, users might not have the full scope of job roles to understand which job roles have a valid requirement for what access level. This situation can lead to requests for RACF administrators to permit access based solely on specific user IDs.
- ▶ Occasionally, there are business imperatives to release an application that grants priority over securing it. That strategy can lead to generic accesses that enable the application to function without security incidents rather than using more job role-based accesses that are more secure.
- ▶ Security administrators often feel confident that the types of protections and measures that they take are secure. This confidence sets aside setting up role-based controls and to using existing generic access paths. Internal and external auditors do not agree with the usage of generic access paths to a company's sensitive resources and demand that more granular access rules are implemented instead of generic access paths.
- ▶ Existing security infrastructure, profile definitions, and access lists can predate modern security best practices. Often, administrators inherit environments that were set up a long time ago, when security policies might have had inaccurate, outdated, or incomplete information, if they existed at all.

As a result, both generic and personalized access permissions pose maintenance challenges or even problems in passing security audits. Moving to RBAC addresses many of these concerns.

5.2 Moving toward role-based access control

With RACF, the access that users or applications have to resources can be based on multiple factors. Access permissions can be based on the user's identity (user ID), the group profiles that a user is connected to, or the UACC level that is defined for a resource. As a best practice, RACF administrators keep their environments aligned with the concept of RBAC. RBAC means that administrators must prioritize using groups that represent a job role in RACF to establish least privilege access to required resources. Consider the following guidelines to manage your environment:

- ▶ Minimizing the usage of universal and generic permissions
- ▶ Minimizing the usage of personalized permissions
- ▶ Minimizing the assignment of the OPERATIONS attribute
- ▶ Minimizing the usage of the WARNING attribute
- ▶ Minimizing the usage of global access checking tables

It is a best practice when the usage of generic and personalized accesses are minimized for those occurrences where it is still required and approved by management. There are probably valid reasons why certain resource profiles might need a UACC permission. However, when speaking more broadly of generic and application-specific resources, consider implementing these best practices.

5.2.1 Minimizing the usage of universal and generic permissions

A common form of a generic access in RACF is the UACC setting that all resource profiles have. The UACC setting designates the access level that applies to all users, applications, and processes in a RACF environment that request access for a resource that is protected by a profile where the requester is not permitted direct or indirect access through their connect groups. Using UACC to provide access is not secure and poses obvious security risks. UACC enables broad, uncontrolled access to a particular resource. From a security perspective, these types of uncontrolled accesses must be avoided because this approach lacks individual accountability. Even user IDs that are not defined in the local RACF database, which can access your system through Network Job Entry (NJE) or Remote Job Entry (RJE), may use resources when the UACC setting grants it. In the context of least privilege, RACF installations should have a security policy that states the following policy: By default, the UACC setting for all resource profiles must be NONE, and deviations from this policy must be approved.

Another common form of generic access in RACF is a permission that applies to all authenticated users. This permission is access to ID(*), which is equivalent to all RACF-authenticated user IDs. Although ID(*) is more restrictive than UACC, it still grants authority to all authenticated users in the RACF environment, which is a lax security policy. As a best practice, discover which job roles require that access level to the protected resource and issue a `permit` command to the collection of corresponding role-based groups instead, except for resources that all RACF-authenticated users need to have access in your environment.

Universal and generic access grant uncontrolled access to the resources that a resource profile protects. Universal and generic access conflicts with zero trust and least privilege. If anyone can access a resource, the system trusts them with this authority, so there is no zero trust in the environment. Often, there is a subset of users or programs that do not require this access to function properly, so this subset does not need UACC.

There are some resource classes and profiles that have a valid business justification for setting the UACC level to a value that exceeds NONE. For example, the resource classes NODES, DIGTCERT, and XFACILIT have profiles that might require a UACC setting that exceeds NONE. For more information about these classes and profiles and why they require this UACC access, see the [RACF Security Administrator's Guide](#).

5.2.2 Minimizing the usage of personalized permissions

Another common form of access in RACF is to assign a permission to specific users. User-based access is often done for increased security because it is the most granular way to administer a RACF environment. Because this granular form of access is secure, prioritizing user-based access does not violate least privilege or zero trust.

A best practice is to avoid assigning permissions to specific users because of the administrative complications of managing such an environment. When accesses are based on users, you must rely on supplemental reasoning and documentation to support the need for this access. When you manage an environment with hundreds of users requesting access to thousands of profiles, this approach quickly becomes untenable. Auditing permissions by each individual user's justified access becomes a monumental effort.

Also, tracking every user's job role and ensuring that accesses are updated for multiple profiles as organizational changes are made causes exponentially more work for security administrators than managing accesses through role-based groups. User-based access is coupled with other hurdles, such as "what if the one person with access to this resource is unavailable?" These administrative and logistical challenges make this security management functionally impossible.

With role-based groups, these accesses can be consolidated, and often in ways that are self-documenting. As an example, you would have to know why USER1 and USER2 needed access to a profile, but if both belong to group DEV1 and DEV1 holds this access, the access might be rooted in the needs of the developer role. If there are changes to the accesses that are required for the developer role, only the permissions of DEV1 change, not each individual developer user. Lastly, if a user leaves a role, you remove them from one role-based group, and possibly add them to a role-based group that represents the user's new job role. With a role-based group implementation, there is no need to remove or define explicit user permissions. Using role-based groups instead of users as the primary method of permitting access is the only way to manage a RACF environment at scale.

5.2.3 Minimizing the assignment of the OPERATIONS attribute

User IDs that are assigned the OPERATIONS attribute are allowed ALTER access to resources in the dataset and the general resource classes that are configured to acknowledge the OPERATIONS attribute. When an OPERATIONS user accesses such a resource in a class, ALTER access is granted by default. If a user ID or one of their connect groups is granted another access level, the access level on the access control list (ACL) or conditional ACL (CACL) is used instead. Auditors often report the usage of the OPERATIONS attribute as noncontrolled access. Using OPERATIONS violates the idea of least privilege by assigning broad and permissive access. It also violates the idea of a zero trust environment by effectively assigning new default permissions for affected users. Replacing the assignment of the OPERATIONS attribute with appropriate permissions to the resources that an OPERATIONS user accesses in their job role improves the security posture of your system.

5.2.4 Minimizing the usage of the WARNING attribute

Activating the WARNING attribute on a resource profile causes RACF to bypass access verification checks for this resource. The WARNING attribute is used in the implementation phase when it is unclear which users require what access level to a resource. When a nonauthorized user requests access to a resource that is protected by a profile in WARNING mode, ALTER access is granted though the user or their connect groups are not permitted access to the resource. This access is then logged to System Management Facilities (SMF) to enable security administrators to populate the ACL and CACL with the permissions. Then, after a period of monitoring SMF records and adding permissions, security administrators can remove the WARNING attribute without causing a security impact. The usage of WARNING violates least privilege and zero trust by establishing broad and permissive access for all users.

5.2.5 Minimizing the usage of global access checking tables

You can implement global access checking (GAC) tables to boost the performance of access verification checks by quickly allowing a particular access level to access certain resources in RACF resource classes without checking RACF profiles and without logging to SMF. Most companies often have public resources that they publicly allow READ access to. For example, banks allow all users to READ their interest rates to attract more customers. However, the GAC tables must not allow access to resources when access to the resource would not be allowed for certain users, or when the company must report who accessed that resource. Therefore, the usage of GAC tables and the list of globally accessible resources must be carefully monitored. Improper usage of these tables violates the principle of zero trust because they allow all users to access the specified resource.

5.3 Establishing groups that accurately reflect user roles

Businesses and organizations are steering their security policies toward RBAC in RACF, but migrating to this state can pose a complex challenge for RACF administrators. It is difficult for RACF administrators to know or research whether the deletion of security definitions results in a business impact because started tasks, jobs, applications, or information systems no longer work correctly due to a lack of authorization. When migrating from a more generic approach to a more specific one, these concerns are key. Also, when moving from user-based access to role-based access, it is a challenge to align the intended access with the user's role to avoid opening security holes when these security changes are made.

The traditional approach to the migration of RACF permissions is to log all successful access to all resources to SMF. Then, an administrator goes through the data for the generic profiles to identify accessing users, and then cross-references these users with common groups. This solution is not feasible because of the sheer amount of SMF records that this implementation produces; the required CPU time; the storage that is associated with it; and the monumental manual work of associating users and groups that are involved.

With zSecure Access Monitor, you can generate reports based on captured access attempts that highlight user-based, ID(*)-based permissions or UACC-based access. You can use the Cleanup utility to generate the commands to automatically convert ID(*) permissions or UACC access events to group-based permissions. Then, with RACF-Offline, you can test new group definitions and permissions against historic access attempts to resources to confirm that the conversion commands do not negatively impact production. Therefore, for conversions from user-based access to group-based access, a security administrator must manually review the access reports and determine what role-based groups to use or define, which users to add to those groups, and what access level to permit to which profiles for the role-based groups. This process must be done in consultation with organizational guidelines and security policies to help ensure that the new role-based groups reflect the appropriate roles for the involved users.

5.4 Converting to group-based access

The details for the general use case preparation steps by using automated (semi-) conversion and cleanup features in zSecure Admin are documented in 2.4, “General preparation steps for the use cases” on page 16, including the following steps:

- ▶ Creating a RACF-Offline database
- ▶ Starting a RACF-Offline session
- ▶ Logging on to the RACF-Offline session
- ▶ Resetting the RACF-Offline log data set
- ▶ Starting and preparing your zSecure Admin session

After completing these steps, you can continue with the following steps to convert generic and specific access to group-based access:

- ▶ Reporting successful access that is allowed through the UACC setting
- ▶ Converting generic UACC access to group-based access
- ▶ Reporting the effect of the UACC conversion commands
- ▶ Reporting successful access through ID(*)
- ▶ Converting generic ID(*) access to group-based access
- ▶ Converting generic OPERATIONS access to group-based access

5.4.1 Reporting successful access that is allowed through the UACC setting

This section describes how to report historic successful access that was allowed through the UACC setting of a resource profile.

You can use the allocated access monitor records to analyze and report which users successfully accessed resources because the UACC setting allowed the requested access during the last year. You can use option AM.1 (Access) to report which users accessed resources through the UACC setting of the protecting resource profile. By default, you can generate access overview reports for all users and resource classes. In this example, the report is restricted to the OPERCMDS class by entering opercmds at option SAF resource class. To limit the report output to only successful accesses that use UACC, you must also activate the options Further selection and Current RACF DB selection in the “Advanced selection criteria” section (see Figure 5-1 on page 91).

To research which users get access to resources through the UACC setting, select option 3 (“Summary by simulated authorization used”). This summary type groups access events that occur through the UACC setting of a resource profile in a single display.


```

zSecure Admin - Access - Access
Command ==> _____

Show records that fit all of the following criteria:
Userid . . . . . _____ (userid or EGN mask)
Complex . . . . . _____ (complex or EGN mask)
SAF resource class . . OPERCMDS (class or EGN mask)
SAF resource name . . . _____
RACF match on . . . . . _____

Advanced selection criteria
└ Further selection _ Date selection └ Current RACF DB selection

Output/run options
3 1. Summary by userid
   2. Summary by member class and profile
   3. Summary by simulated authorization used
   4. Summary by simulated groups used for access
_ Show configured fields _ Show simulated fields _ Timezone (U/L/H)
_ Print format           _ Customize title       _ Send as e-mail
_ Background run         _ Full page form

```

Figure 5-1 Reporting historic access to resources in the OPERCMDS class

After you press Enter, another panel opens. For this analysis report, you are interested only in reporting successful access events. Select option Success in the Result section by entering / or S (see Figure 5-2), and press Enter.

```

zSecure Admin - Access - Further selection
Command ==> _____
Access monitor records for Classes like OPERCMDS

Select access records(Y/N/blank)
_ Use of RACF commands _ Retrieval of access allowed
_ Use of global access checking table _ Bypass JESSPOOL profiles
_ Use of discrete profiles _ ID was undefined during event
_ System special authority used _ User had special attribute
_ Operations authority used _ User had operations attribute
_ Installation exit used _ User had (ro)auditor attribute
_ User requesting access is owner

Resource action  Intended access  Result  Program status
_ Define        _ _ 1. Read    └ Success  _ Defined program
_ Delete        _ 2. Update _ No profile _ Controlled program
_ Addvol        _ 3. Control _ Not authorized _ Specific program
_ Chgvol        _ 4. Alter  _ Other    _ Controlled library

```

Figure 5-2 Report only successful access events in the OPERCMDS class

The activated “Current RACF DB selection” panel opens (see Figure 5-3). On this panel, specify that you want your report to show only successful access through the UACC setting. Select option UACC in the “Authority used in current DB” section by entering / or S and press Enter.

zSecure Admin - Access - Current Database

Command ==>

Access monitor records for Classes like OPERCMDS, Successes

Specify simulated fields (Current DB effect) selection criteria:

Groups used for access

(groups or filter)

Essential groups . . .

(Y/N/blank)

Not using groups . . .

(groups or filter)

Profile owned by . . .

(id or filter)

RACF return code . . .

(operator: > >= < <= = <> ^=)

Authority used in current DB

- APF	- GRP_OPER	- ID_USER	- PRIVTRUS	- SYS_OPER
- CLAUTH	- GRP_SPEC	- INACTIVE	- PROTFAIL	- SYS_SPEC
- CREATE	- GRP_UACC	- NO_CDT	- QUALOWN	/ UACC
- DFLTRC	- ID_GROUP	- NO_PROF	- RESTRICTED	- UNPROT
- GLOBAL	- ID_STAR	- NOTHING	- SPOOLRCVR	- WARNING

User attributes in current DB (Y/N/blank)

- ID present

- ID Revoked

- ID has special

- ID has operations

- ID has (ro)auditor

Figure 5-3 Reporting only successful OPERCMDS access events that used the UACC authority

If successful UACC access to OPERCMDS resources occurred during the last year, your report shows which users accessed OPERCMDS resources through UACC authority (see Figure 5-4).

IBM Security zSecure ACCESS summary

0 s elapsed, 0.1 s CPU

Command ==>

Scroll==> CSR

Access monitor records for Classes like OPERCMD 6 Nov 2024 14:34

Via

Occurrence

First occurrence

Last occurrence

UACC

124

2Nov2023 12:55

12Sep2024 23:36

Occurrence

Userid

Name

First occurrence

Last occur

S

101

CRMBAH1

SYSprog1 AH

4Jan2024 19:25

12Sep2024

—

1

CRMBAH2

SYSprog2 AH

15Jan2024 15:42

15Jan2024

—

22

CRMBEP1

SYSprog1 EP

2Nov2023 12:55

19Apr2024

***** Bottom of Data *****

Figure 5-4 Successful access through UACC to the OPERCMDS class resources

The report reveals which users successfully accessed OPERCMDS resources through UACC authority. Specify S, and press Enter to review the access event details (see Figure 5-5 on page 93).

IBM Security zSecure ACCESS summary										Line 1 of 8
Command ==>										Scroll==> CSR
Access monitor records for Classes like OPERCMD 6 Nov 2024 14:41										
Via		Occurrence First occurrence Last occurrence								
UACC		124 2Nov2023 12:55 12Sep2024 23:36								
Occurrence		Userid	Name				First occurrence		Last occur	
		101	CRMBAH1	SYSPROG1 AH				4Jan2024 19:25		12Sep2024
Occurrence		Intent	Type	RetAll	AccRC	SmRC				
		101	READ	Auth		0 0				
Occurrence		Class								
		101 OPERCMDS								
Occurrence		Resource							Profile key us	
		101 MVS.MCSOPER.CRMBAH1							MVS.MCSOPER.*	
Occurrence		Complex	Syst	RGJCAVP	GUGSOPGX0	SOA	PCSL	First occurrence		Last oc
		101	TVT6003	ZS34	G			4Jan2024 19:25		12Sep20
Occurrence		Timestamp								
		4	4Jan2024 19:25							
		23	16Jan2024 19:02							
		5	18Jan2024 14:45							
		35	12Mar2024 13:51							
		1	12Mar2024 21:07							
		5	11Sep2024 20:28							
		7	12Sep2024 15:27							
		21	12Sep2024 23:36							

Figure 5-5 Successful access through UACC to the OPERCMDS class resources details

From the “Profile key used” column that reports MVS.MCSOPER.*, you can conclude that the UACC setting of that OPERCMDS profile is at least READ. In this example, zooming in on the other reported users reveals that they all obtained READ access through the UACC of the OPERCMDS profile MVS.MCSOPER.*. However, in practice, your RACF database might contain multiple OPERCMDS profiles with a lax UACC setting. If so, you encounter other OPERCMDS profiles with a UACC setting that exceeds NONE in this report. In the next section, you learn how you can use zSecure Admin to convert access through UACC to group-based access permissions.

Important: The access monitor records show only the users that used the access path that the current UACC setting allowed. This UACC implementation implies that all other RACF-authenticated, NJE, and RJE users are also allowed to successfully access these reported OPERCMDS resources with the same access level. Usually, the allowed access level through UACC does not exceed READ, but that might not always be the case. zSecure Admin supports features to (semi) automatically convert historic access that was allowed through a UACC setting, or an ID(*) permission, to group-based permissions and connections.

5.4.2 Converting generic UACC access to group-based access

This section explains how to generate and run automatic RACF commands that convert generic UACC access to group-based access.

Use option AM.9 (Cleanup) to automatically generate RACF commands that convert the access that is allowed through the UACC setting. To begin converting UACC-based access to group permissions and connections, select option 4 (UACC) and press Enter (see Figure 5-6).

zSecure Admin - Access - Cleanup		
Option ==> <u>4</u>		
1	User permit	Redundant permits to userids
2	Dataset	Redundant dataset profiles
3	Empty	Generic profiles without matching disk or tape datasets
4	UACC	Generate permits/connects to convert UACC access
5	ID(*)	Generate permits/connects to convert ID(*) access
Output options		
<u>_</u> Background run		

Figure 5-6 Selecting option 4 (UACC) to convert UACC-based access to group-based permissions and connections.

This section explains how to convert historic access that is granted through the UACC setting of the OPERCMDS profile MVS.MCSOPER.*. If your system includes multiple resource profiles in the OPERCMDS or other resource classes with UACC settings greater than NONE, you can apply the same strategy to convert UACC-based access to group-based permissions and connections by using IBM zSecure Admin.

Suppose that during your research of historical UACC settings for OPERCMDS resources, you find that only z/OS systems programmers accessed these resources. With the UACC conversion function, you can either define a group or use an existing RBAC group for systems programmers. In the example system, the group CRMB is already defined as the RBAC group for z/OS systems programmers.

Specify OPERCMDS in the “SAF resource class” field to limit the UACC conversion to resources in the OPERCMDS class. Because you already identified the existing RBAC group for systems programmers, enter CRMB in the “Group for permit/connect to convert to” field (see Figure 5-7 on page 95). Press Enter to generate the UACC conversion commands.

zSecure Admin - Cleanup - UACC	
Command ==> _____	
Generate permits/connects to convert UACC selection criteria:	
Userid	_____ (userid or EGN mask)
Complex	_____ (complex or EGN mask)
SAF resource class . . .	<u>OPERCMDS</u> (class or EGN mask)
SAF resource name . . .	_____
RACF match on	_____
Intended access	__ _ 1. Read 2. Update 3. Control 4. Alter
Date selection	
From date	_____ Until date _____
Specify data for group for which permit/connect commands are generated	
Group for permit/connect	<u>CRMB</u> (group name; required, no mask allowed)
Superior group	_____ (group name; optional for new group)
Owner for new group . .	_____ (owner name; optional for new group)
Instdata new group . . .	_____
Output options	_ Background run

Figure 5-7 Converting historic access that is granted through the UACC setting to the existing role-based access group CRMB.

IBM zSecure Admin successfully generates the required conversion commands, as shown in Figure 5-8.

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          0.0 s CPU, RC=4
Command ==> go          Scroll ==> CSR
***** Top of Data *****
=NOTE= Enter GO or RUN to run commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001 /* CKRCMD file CKR1CMD complex TVT6003 generated 6 Nov 2024 15:39 */
000002 /* No addgroup cmd created because group CRMB already exists */
000003
000004 connect CRMBAH1 group(CRMB) auth(use)
000005 connect CRMBAH2 group(CRMB) auth(use)
000006 connect CRMBEP1 group(CRMB) auth(use)
000007
000008 permit MVS.MCSOPER.* class(OPERCMDS) id(CRMB) access(READ)
000009
000010 setropts refresh raclist(OPERCMDS)
000011
***** Bottom of Data *****

```

Figure 5-8 UACC conversion commands for OPERCMD resources were successfully generated.

As expected, IBM zSecure Admin generates connect commands to group CRMB for the three users that you identified in your earlier access report. If these users are already connected to group CRMB, you can remove the corresponding connect commands before running them. However, leaving these commands in the CKRCMD work data set does not cause issues: The connect command runs successfully but does not alter the connection unless the user's existing group authority or connect privileges differ. In such cases, the command updates the connection to match the specified settings.

If some of the users that historically used the OPERCMDS resources that the profile MVS.MVSOPER.* protects are not systems programmers and should not have accessed this resource, you can delete the connect commands for these users. Deleting these connect commands may result in access violations for affected users if they attempt to access the resource after you reduce the UACC setting from READ to NONE.

When you are satisfied with the conversion commands, type G0 or RUN in the CLI and press Enter to run them interactively. If you prefer to run the commands in the background as a batch job, use the SUB or SUBMIT command. In this example, the G0 command is used to run the commands interactively.

After you press Enter, IBM zSecure Admin runs the UACC conversion commands against the offline RACF database. You are then automatically redirected to the CKRTSPRT work data set, which displays the results of the ran RACF conversion commands (see Figure 5-9).

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT          Line 0000000000 Col 001 080
Command ==> _____ Scroll ==> CSR
***** Top of Data *****
=====
=== Multiple TSO command output file - scroll max down for overview ===
=== Input data set CRMBTZ1.DATA.C2R1DC6.TEMP.CKRCMD                    ===
=====

=====
=== Commands for local node
=====
/* CKRCMD file CKR1CMD complex TVT6003 generated  6 Nov 2024 15:39 */
/* No addgroup cmd created because group CRMB      already exists */

===== 6Nov24 16:04:11.00019 start record 3 =====
connect CRMBAH1 group(CRMB) auth(use)

===== 6Nov24 16:04:11.02476 start record 5 =====
connect CRMBAH2 group(CRMB) auth(use)

```

Figure 5-9 Reviewing the output of the UACC conversion by examining the results in the CKRTSPRT work data set after running the conversion commands

If a conversion command fails, the message Command failed appears in the upper right of the panel. In that case, the CKRTSPRT work data set displays a reference to the record number of the failed commands at the bottom of the output. To view it, enter the command M (maximum) in the CLI and press F8 to scroll to the bottom (see Figure 5-10 on page 97).

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT          Line 0000000015 Col 001 080
Command ==> _____ Scroll ==> CSR
===== 6Nov24 16:04:11.00019 start record 3 =====
connect CRMBAH1 group(CRMB) auth(use)

===== 6Nov24 16:04:11.02476 start record 5 =====
connect CRMBAH2 group(CRMB) auth(use)

===== 6Nov24 16:04:11.04182 start record 6 =====
connect CRMBEP1 group(CRMB) auth(use)

===== 6Nov24 16:04:11.05980 start record 7 =====
permit MVS.MCSOPER.* class(OPERCMD) id(CRMB) access(READ)
ICH06011I RACLISTED PROFILES FOR OPERCMD WILL NOT REFLECT THE UPDATE(S) UNTIL
A

===== 6Nov24 16:04:11.06309 start record 9 =====
setropts refresh raclist(OPERCMD)
B8R400I SETROPTS Command currently not supported
=====
=== All commands completed successfully ===
=====
***** Bottom of Data *****

```

Figure 5-10 Confirming the successful running of the UACC conversion commands

As expected, all UACC conversion commands ran successfully. The command SETROPTS REFRESH RACLIST(OPERCMD) is reported as not supported. Because you use RACF-Offline, the SETROPTS REFRESH command is not required. (RACF-Offline does not support the SETROPTS REFRESH command.) You may remove this command from the CKRCMD work data set before running the conversion. Press F3 to return to the zSecure results panel (see Figure 5-11).

```

                                zSecure Admin - Results          Enter R to run commands
=ra.r
_____

The following selections are supported:
B Browse file                      S Default action (for each file)
E Edit file                        R Run commands
P Print file                       J Submit Job to run commands
V View file                        M E-mail report
W Write file into seq. or partitioned data set

Enter a selection in front of a highlighted line below:
- SYSPRINT  messages
- REPORT    printable reports
- CKRTSPRT  output from the last TSO commands
- CKRCMD    queued TSO commands
- CKR2PASS  queued commands for zSecure Admin for RACF
- COMMANDS  zSecure Admin for RACF input commands from last query
- SPFLIST   printable output from PRT primary command
- OPTIONS   set print options

```

Figure 5-11 Jumping to the RACF administration panel for general resource profiles

Tip: If the allocated Access Monitor records cover only the past month, you might choose to postpone reducing the UACC setting for now. When you run the same analysis report next month, users who are now permitted through the CRMB group no longer appear as accessing the MVS.MCSOPER.* resources through the UACC setting. However, other users might still be reported as having accessed these resources through UACC.

You can repeat the monthly monitoring process until no additional users are reported as relying on the UACC(READ) setting. At that point, you can safely change the UACC setting from READ to NONE.

Your next step is to reduce the UACC setting for the OPERCMDS profile MVS.MCSOPER.* from READ to NONE. To improve efficiency, you can manually add a RACF command to change the UACC setting of the profiles to NONE in the CKRCMD work data set before running the UACC conversion commands.

However, this document illustrates an alternative user interface (UI) supported function to accomplish this task. Specify =ra.r in the CLI to instruct zSecure Admin to jump to the RA.R panel and press Enter.

However, this document demonstrates an alternative user interface (UI)-supported method to perform this task. Specify =RA.R in the CLI to open the RA.R panel in IBM zSecure Admin, then press Enter.

Specify OPERCMDS in the “Class name” field, MVS.MCSOPER.* in the “Resource profile” field, and select option 2 (Exact) (see Figure 5-12). Then, press Enter.

zSecure Admin - RACF - Resource Selection			
Command ==> _____		_ start panel	
_ Add new general resource profile or segment			
Show general profiles that fit all of the following criteria			
Class name	<u>opercmds</u>	(class or filter)	
Resource profile .	<u>mvs.mcsoper.*</u>		
Owned by	_____	(group or userid, or filter)	2 1 EGN mask
Installation data .	_____	(substring or *)	2 Exact
			3 Match
			4 Any match
Additional selection criteria			
_ Profile fields	_ Access list	_ Segment presence	_ Absence
_ Audit settings			
Output/run options			
_ Show segments	_ All	_ Enable full ACL	_ Specify scope
_ Show differences	_ Summarize by class		
_ Print format	Customize title	Send as e-mail	
Background run	Full detail form	Sort differently	Narrow print
Print ACL	Resolve to users	Incl operations	Print names

Figure 5-12 List in the OPERCMDS class profile MVS.MCSOPER.*

The query displays the settings for the OPERCMDS profile MVS.MCSOPER.*. As expected, the UACC is set to READ. Move the cursor to the UACC column and type over READ with the value NONE (see Figure 5-13 on page 99).


```

0 s elapsed, 0.0 s CPU
zSecure Admin General resource overview
Command ==> _____ Scroll==> CSR
Class OPERCMDS, key mvs.mcsoper.*          6 Nov 2024 16:25
  Class   Profile key                      T UACC   Owner   S/F W
  OPERCMDS MVS.MCSOPER.*                G NONE  SYSAUTH R R
***** Bottom of Data *****

```

Figure 5-13 Typing over the UACC of the OPERCMDS profile MVS.MCSOPER.*

When you press Enter, IBM zSecure Admin generates the appropriate RACF command to update the UACC setting. Depending on your command confirmation settings, the command is either ran immediately or as, in this example, presented for confirmation before running (if your zSecure session is configured to confirm generated commands before running them). You can configure command confirmation behavior, including whether to queue or run commands immediately after confirmation, by using option SE.4 (Setup Confirm).

Important: Always confirm the generated commands before running them, which helps prevent mistakes and provides an opportunity to learn the RACF command syntax while using IBM zSecure Admin.

On the command confirmation panel, select option 1 (the EXECUTE RACF command), then press Enter to run the command (see Figure 5-14).

```

zSecure Admin - Confirm command
Command ==> _____

Confirm or edit the following command
ralter OPERCMDS MVS.MCSOPER.* uacc(NONE)
_____
_____

Command execution . 1 1. EXECUTE RACF command
                      2. EXECUTE CKGRACF command (allows use of Reason)
                      3. ASK administrator to run CKGRACF command
                      4. REQUEST CKGRACF command for later execution
                      5. WITHDRAW CKGRACF command

Reason . . . . . _____
Press ENTER to continue or END to cancel the command

```

Figure 5-14 Confirming and running the generated command to change the UACC setting to NONE

This action returns you to the original display for the OPERCMDS profile MVS.MCSOPER.*. The updated view confirms that the command successfully modified the UACC setting, which now shows as NONE (see Figure 5-15).

```

                                                                    Successfully modified
                                zSecure Admin General resource overview
Command ==> _____ Scroll==> CSR
Class OPERCMDS, key mvs.mcsoper.*                               6 Nov 2024 16:41
  Class   Profile key                                           T UACC   Owner   S/F W
  _ OPERCMDS MVS.MCSOPER.*                                     G NONE   SYSAUTH R R _
***** Bottom of Data *****
```

Figure 5-15 Changing the UACC setting to NONE

Depending on your Setup Confirm configuration, pressing F3 might show the panel in Figure 5-16.

```

                                                                    Press PF3 to accept
C | IBM Security zSecure confirm SETROPTS REFRESH
  | Complex TVT6003
R | Refresh Class Also affected
  | / GENERIC DATASET
  | ***** Bottom of Data *****
```

Figure 5-16 Required SETROPTS refresh command generated

RACF-Offline does not support the SETROPTS REFRESH command. To indicate that you do not want to run this command at this stage, remove the / before pressing F3.

5.4.3 Reporting the effect of the UACC conversion commands

This section explains how to report the impact of the UACC conversion commands.

After you reduce the UACC setting from READ to NONE, users no longer have UACC access to the OPERCMDS class resources that are protected by the OPERCMDS class profile MVS.MCSOPER.*. To verify, use option AM.1 (Access) to rerun the same report that you used earlier. This report identifies which users can still access OPERCMDS resources through the UACC setting. Use the selections that are shown in Figure 5-17 on page 101.

```

                                zSecure Admin - Access - Access
Command ==> _____

Show records that fit all of the following criteria:
Userid . . . . . _____ (userid or EGN mask)
Complex . . . . . _____ (complex or EGN mask)
SAF resource class . . OPERCMDS (class or EGN mask)
SAF resource name . . . mvs.mcsoper.*
RACF match on . . . . . _____

Advanced selection criteria
☒ Further selection  ☐ Date selection  ☒ Current RACF DB selection

Output/run options
☒ 1. Summary by userid
      2. Summary by member class and profile
      3. Summary by simulated authorization used
      4. Summary by simulated groups used for access
☐ Show configured fields  ☒ Show simulated fields  ☐ Timezone (U/L/H)
☐ Print format              Customize title          Send as e-mail
☐ Background run            Full page form

```

Figure 5-17 Reporting historic successful access to OPERCMDS resources with the prefix MVS.MCSOPER

After you press Enter, a selection panel opens.

For this analysis, focus only on reporting successful access events. In the Result section, select the Success option in the Result section by entering / or S, as shown in Figure 5-18. Then, press Enter to continue.

```

                                zSecure Admin - Access - Further selection
Command ==> _____
Access monitor records for Classes like OPERCMDS

Select access records(Y/N/blank)
☐ Use of RACF commands
☐ Use of global access checking table
☐ Use of discrete profiles
☐ System special authority used
☐ Operations authority used
☐ Installation exit used
☐ User requesting access is owner
☐ Retrieval of access allowed
☐ Bypass JESSPOOL profiles
☐ ID was undefined during event
☐ User had special attribute
☐ User had operations attribute
☐ User had (ro)auditor attribute

Resource action  Intended access  Result  Program status
☐ Define      ☐ 1. Read    ☒ Success    ☐ Defined program
☐ Delete      ☐ 2. Update  ☐ No profile  ☐ Controlled program
☐ Addvol      ☐ 3. Control ☐ Not authorized ☐ Specific program
☐ Chgvol      ☐ 4. Alter   ☐ Other       ☐ Controlled library

```

Figure 5-18 Reporting only successful access events to the OPERCMDS resources

Next, the “Current RACF DB selection” panel opens.

On this panel, specify that the report should include only successful access through UACC. In the “Authority used in current DB” section, select the UACC option by entering / or S, as shown in Figure 5-19. Then, press Enter to proceed.

zSecure Admin - Access - Current Database

Command ==> _____

Access monitor records for Classes like OPERCMDS, Successes

Specify simulated fields (Current DB effect) selection criteria:

Groups used for access _____ (groups or filter)

Essential groups . . . _ (Y/N/blank)

Not using groups . . . _____ (groups or filter)

Profile owned by _____ (id or filter)

RACF return code _ _____ (operator: > >= < <= = <> ^=)

Authority used in current DB

_ APF	_ GRP_OPER	_ ID_USER	_ PRIVTRUS	_ SYS_OPER
_ CLAUTH	_ GRP_SPEC	_ INACTIVE	_ PROTFAIL	_ SYS_SPEC
_ CREATE	_ GRP_UACC	_ NO_CDT	_ QUALOWN	<u>/</u> UACC
_ DFLTRC	_ ID_GROUP	_ NO_PROF	_ RESTRICTED	_ UNPROT
_ GLOBAL	_ ID_STAR	_ NOTHING	_ SPOOLRCVR	_ WARNING

User attributes in current DB (Y/N/blank)

_ ID present _ ID Revoked

_ ID has special _ ID has operations _ ID has (ro)auditor

Figure 5-19 Reporting only successful OPERCMDS access events that use the UACC authority

If users successfully accessed OPERCMDS resources through UACC authority within the past year, the report displays which users accessed which resources, as shown in Figure 5-20 on page 103.

zSecure Admin - Access - Access		No records found
Command ==> _____		
Show records that fit all of the following criteria:		
Userid	_____	(userid or EGN mask)
Complex	_____	(complex or EGN mask)
SAF resource class . .	<u>OPERCMDS</u>	(class or EGN mask)
SAF resource name . . .	<u>mvs.mcsoper.*</u>	_____
RACF match on	_____	
Advanced selection criteria		
☒ Further selection ☐ Date selection ☒ Current RACF DB selection		
Output/run options		
☒ 1. Summary by userid ☐ 2. Summary by member class and profile ☐ 3. Summary by simulated authorization used ☐ 4. Summary by simulated groups used for access		
☐ Show configured fields	☒ Show simulated fields	☐ Timezone (U/L/H)
☐ Print format	☐ Customize title	☐ Send as e-mail
☐ Background run	☐ Full page form	

Figure 5-20 No successful access events were found that used the UACC authority

As expected, the report shows no simulated access to OPERCMDS resources with the prefix MVS.MCSOPER by using UACC.

Users CRMBAH1, CRMBAH2, and CRMBEP1 no longer rely on UACC for access. Instead, they access these resources through their connection to group CRMB.

To verify this conclusion, update your selection. Remove the / from the “Current RACF DB selection” option, as shown in Figure 5-21, and press Enter.

```

                                zSecure Admin - Access - Access
Command ==> _____

Show records that fit all of the following criteria:
Userid . . . . . _____ (userid or EGN mask)
Complex . . . . . _____ (complex or EGN mask)
SAF resource class . . OPERCMDS (class or EGN mask)
SAF resource name . . . mvs.mcsoper.* _____
RACF match on . . . . . _____

Advanced selection criteria
/ Further selection _ Date selection _ Current RACF DB selection

Output/run options
3 1. Summary by userid
   2. Summary by member class and profile
   3. Summary by simulated authorization used
   4. Summary by simulated groups used for access
_ Show configured fields / Show simulated fields _ Timezone (U/L/H)
_ Print format          Customize title          Send as e-mail
_ Background run        Full page form

```

Figure 5-21 Removing the option “Current RACF DB selection”

Now, the report shows some access to OPERCMDS resources through user and group permissions.

Because you already know that the users gain access through group CRMB, select the report that is named ID_GROUP by entering / or S, as shown in Figure 5-22. Then, press Enter.

```

                                IBM Security zSecure ACCESS summary    0 s elapsed, 0.1 s CPU
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like OPERCMD 7 Nov 2024 16:52
  Via      Occurrence First occurrence Last occurrence
__ ID_USER      170232 3Apr2024 07:09 31Oct2024 22:45
S ID_GROUP      338 2Nov2023 12:55 31Oct2024 07:56
***** Bottom of Data *****

```

Figure 5-22 Reviewing access events for OPERCMDS resources through group permissions

The report now displays details of users who accessed OPERCMDS resources through permissions that were granted to one of their connect groups.

If everything is configured correctly, the users that you connected to group CRMB should appear in the report. To view more details, select one of the listed users by entering / or S, as shown in Figure 5-23 on page 105, and press Enter.

```

                                IBM Security zSecure ACCESS summary                                Line 1 of 10
Command ==> _____ Scroll==> CSR_
Access monitor records for Classes like OPERCMD 7 Nov 2024 16:52
  Via      Occurrence First occurrence Last occurrence
  ID_GROUP      338 2Nov2023 12:55 31Oct2024 07:56
  Occurrence Userid  Name                      First occurrence Last occur
S_          101 CRMBAH1 SYSPROG1 AH                      4Jan2024 19:25 12Sep2024
_           1 CRMBAH2 SYSPROG2 AH                      15Jan2024 15:42 15Jan2024
_          22 CRMBEP1 SYSPROG1 EP                      2Nov2023 12:55 19Apr2024
_          42 CRMBJK1 SYSPROG1 JK                      9Nov2023 12:23 31Oct2024
_          22 CRMBLU1 SYSPROG1 LU                      27Nov2023 07:56 5Jan2024
_           7 CRMBMK1 SYSPROG1 MK                      25Oct2024 10:23 30Oct2024
_           1 CRMBPH1 SYSPROG1 PH                      7Mar2024 10:21 7Mar2024
_           1 CRMBRL1 SYSPROG1 RL                      23Feb2024 13:35 23Feb2024
_          133 CRMBVK1 SYSPROG1 VK                      6Dec2023 13:45 25Oct2024
_           8 CRMBVK2 SYSPROG2 VK                      17Nov2023 14:24 12Apr2024
***** Bottom of Data *****

```

Figure 5-23 Reviewing the access event details for the OPERCMDS resources

On the next panel, continue entering / or S until you reach the “Access summary” panel, as shown in Figure 5-24.

Once there, enter the M (maximum) command and press F8 to scroll to the bottom of the details.

```

                                IBM Security zSecure ACCESS summary                                Line 40 of 48
Command ==> _____ Scroll==> CSR_
Access monitor records for Classes like OPERCMD 7 Nov 2024 16:52

Current RACF database effect
RACF return code current DB 0
Authority used in current DB ID_GROUP
_ Grp permit used in current DB CRMB
_ RACF Profile type current DB GENERIC
_ RACF class and profile in DB OPERCMDS MVS.MCSOPER.*
_ Profile owner              SYSAUTH
Installation data
Creation/definition date    16 Feb 2010
***** Bottom of Data *****

```

Figure 5-24 Access to the OPERCMDS class MVS.MCSOPER.* is now allowed through group CRMB

This report confirms that the conversion was successful. Users CRMBAH1, CRMBAH2, and CRMBEP1 can now access the resource without relying on the UACC setting.

Note: Your access summary report might also include user IDs that were not part of the conversion. These users were already connected to a group other than CRMB that had existing permission to access the MVS.MCSOPER.* resources.

When you are satisfied with the results of your conversion commands, end your RACF-Offline session and apply the same UACC conversion commands to your active primary RACF database.

Press F3 several times until you return to the ISPF Primary Option Menu. Then, select option X to exit ISPF and return to your RACF-Offline session, as shown in Figure 5-25.

ISPF Primary Option Menu			
Option ==> X			
		More:	+
0	Settings	Terminal and user parameters	User ID . : CRMBTZ1
1	View	Display source data or listings	Time. . . : 17:19
2	Edit	Create or change source data	Terminal. : 3278
3	Utilities	Perform utility functions	Screen. . : 1
4	Foreground	Interactive language processing	Language. : ENGLISH
5	Batch	Submit job for language processing	Appl ID . : ISR
6	Command	Enter TSO or Workstation commands	TSO logon : TS0ZSEC
7	Dialog Test	Perform dialog testing	TSO prefix: CRMBTZ1
9	IBM Products	IBM program development products	System ID : TVT6003
10	SCLM	SW Configuration Library Manager	MVS acct. : ACCT#
11	Workplace	ISPF Object/Action Workplace	Release . : ISPF 8.1
P	PRODUCTS	Dialogs for installed products	
G	GROUP	Dialogs used with your organization	
U	User	Your Own Dialogs	
S	SDSF	System Display and Search Facility	
C	Consul	Consul Risk Management applications	
Enter X to Terminate using log/list defaults			

Figure 5-25 Exiting ISPF

Next, specify what you want to do with your ISPF Log Data Set.

Select your preferred option, as shown in Figure 5-26 on page 107, and press Enter to return to READY mode.


```

Specify Disposition of Log Data Set
Command ==> _____
More: +
Log Data Set (CRMBTZ1.SPFLOG1.LIST) Disposition:
Process Option . . . . 2 1. Print data set and delete
                        2. Delete data set without printing
                        3. Keep data set - Same
                          (allocate same data set in next session)
                        4. Keep data set - New
                          (allocate new data set in next session)

Batch SYSOUT class . . _____
Local printer ID or
writer-name . . . . . _____
Local SYSOUT class . . _____

List Data Set Options not available

Press ENTER key to complete ISPF termination.
Enter END command to return to the primary option menu.

Job statement information: (Required for system printer)
==> _____
==> _____
==> _____

```

Figure 5-26 Specifying the Log Data Set disposition

You now return to the RACF-Offline interface.

To exit your session, enter the command end and press Enter, as shown in Figure 5-27.

```

CRMBTZ1.SPFLOG1.LIST has been deleted.
B8R200A Enter RACF Command or "END"
end

```

Figure 5-27 Exiting your RACF-Offline session

You should now be back in TSO READY mode.

To return to the ISPF Primary Option Menu, enter the command ISPF and press Enter. This time, you are no longer in a RACF-Offline session.

You can now repeat the same steps to generate and run the UACC conversion commands against the active primary RACF database.

Tip: You can replay this scenario as often as needed to convert UACC settings from other OPERCMDS profiles or from resource profiles in different resource classes where the UACC setting exceeds NONE.

5.4.4 Reporting successful access through ID(*)

This section explains how to report historical successful access that was allowed through permission to ID(*).

When you are ready to convert access permitted to ID(*), you can follow the same approach that was used for converting successful access through the UACC. However, this time you must apply different filters to report successful access through permission to ID(*).

Once again, use option AM.1 (Access) and activate similar options as you did when reporting access through UACC. By default, you can generate access overview reports for all resource classes that include resource profiles with permission to ID(*).

To include all resource classes in your report, activate the Further selection and Current RACF DB selection options in the “Advanced selection criteria” section. Because your goal is to report simulated access through permission to ID(*), use option 2 (“Summary by member class and profile”), as shown in Figure 5-28. This summary displays each resource class and profile that include permission to ID(*).

zSecure Admin - Access - Access

Command ==> _____

Show records that fit all of the following criteria:
Userid _____ (userid or EGN mask)
Complex _____ (complex or EGN mask)
SAF resource class . . _____ (class or EGN mask)
SAF resource name . . . _____
RACF match on _____

Advanced selection criteria
/ Further selection _ Date selection / Current RACF DB selection

Output/run options
2 1. Summary by userid
2. Summary by member class and profile
3. Summary by simulated authorization used
4. Summary by simulated groups used for access
_ Show configured fields _ Show simulated fields _ Timezone (U/L/H)
_ Print format _ Customize title _ Send as e-mail
_ Background run _ Full page form

Figure 5-28 Reporting historic access to resources summarized by class and profile

After you press Enter, the “Further selection” panel appears.

For this analysis, focus only on reporting successful access events. In the Result section, select the Success option by entering / or S, as shown in Figure 5-29 on page 109. Then, press Enter to continue.

```

zSecure Admin - Access - Further selection
Command ==> _____
All access monitor records

Select access records(Y/N/blank)
- Use of RACF commands                - Retrieval of access allowed
- Use of global access checking table  - Bypass JESSPOOL profiles
- Use of discrete profiles             - ID was undefined during event
- System special authority used        - User had special attribute
- Operations authority used            - User had operations attribute
- Installation exit used               - User had (ro)auditor attribute
- User requesting access is owner

Resource action  Intended access  Result      Program status
- Define        - 1. Read        - Success    - Defined program
- Delete        - 2. Update       - No profile  - Controlled program
- Addvol        - 3. Control     - Not authorized - Specific program
- Chgvol        - 4. Alter       - Other      - Controlled library

```

Figure 5-29 Reporting only successful access events

On this panel, specify that the report should include only successful access through permission to ID(*). In the “Authority used in current DB” section, select the ID_STAR option by entering / or S, as shown in Figure 5-30. Then, press Enter.

```

zSecure Admin - Access - Current Database
Command ==> _____
All access monitor records, Successes
Specify simulated fields (Current DB effect) selection criteria:
Groups used for access _____ (groups or filter)
Essential groups . . . - _____ (Y/N/blank)
Not using groups . . . _____ (groups or filter)
Profile owned by . . . . _____ (id or filter)
RACF return code . . . . - _____ (operator: > >= < <= = <> ^=)

Authority used in current DB
- APF          - GRP_OPER    - ID_USER      - PRIVTRUS    - SYS_OPER
- CLAUTH       - GRP_SPEC    - INACTIVE     - PROTFAIL    - SYS_SPEC
- CREATE       - GRP_UACC    - NO_CDT       - QUALOWN     - UACC
- DFLTRC       - ID_GROUP    - NO_PROF      - RESTRICTED  - UNPROT
- GLOBAL       - / ID_STAR   - NOTHING      - SPOOLRCVR   - WARNING

User attributes in current DB (Y/N/blank)
- ID present    - ID Revoked
- ID has special - ID has operations - ID has (ro)auditor

```

Figure 5-30 Reporting only the successful access events that used the ID(*) authority

The generated report provides an overview of all resource classes that contain a profile with permission to ID(*) on the access control list (ACL) that is used by users to access protected resources.

To focus on the DATASET class, enter / or S to review the profiles that are involved in the DATASET class, as shown in Figure 5-31. Then, press Enter.

```

                                IBM Security zSecure ACCESS summary      0 s elapsed, 0.2 s CPU
Command ==> _____ Scroll==> CSR
All access monitor records, Successes, Current  8 Nov 2024 10:41
  Occurrence Class    First occurrence Last occurrence
L_____ 26772 DATASET   1Nov2023 04:30 31Oct2024 21:05
  _____ 2012 SDSF    17Nov2023 14:24 31Oct2024 22:49
  _____ 45846 SERVAUTH 17Nov2023 14:25 31Oct2024 22:49
***** Bottom of Data *****

```

Figure 5-31 Reviewing the DATASET profiles with permission to ID(*)

The overview displays three DATASET class profiles that include a permission to ID(*).

To view the details of the DATASET profile USER.*.**, enter /, as shown in Figure 5-32, and press Enter.

```

                                IBM Security zSecure ACCESS summary
Command ==> _____ Scroll==> CSR
All access monitor records, Successes, Current  8 Nov 2024 10:37
  Occurrence Class    First occurrence Last occurrence
    26772 DATASET     1Nov2023 04:30 31Oct2024 21:05
  Occurrence Profile key used
  _____ 13011 CATALOG.**
  _____ 10226 CRMA.X.**
L_____ 3535 USER.*.**
***** Bottom of Data *****

```

Figure 5-32 Zooming in to the details of the DATASET profile USER.*.**

Continue entering / or S until you reach the detail panel for the access record.

Scroll to the bottom of the panel to view the “Current RACF database effect” section, as shown in Figure 5-33.

```

                                IBM Security zSecure ACCESS summary      Line 39 of 48
Command ==> _____ Scroll==> CSR
All access monitor records, Successes, Current  8 Nov 2024 10:41

Current RACF database effect
RACF return code current DB    0
Authority used in current DB   ID_STAR
Grp permit used in current DB
RACF Profile type current DB   GENERIC
_ RACF class and profile in DB  DATASET  USER.*.**
_ Profile owner                 CRMA
_ Installation data
  Creation/definition date      23 Apr 2010
***** Bottom of Data *****

```

Figure 5-33 Current RACF database effect reveals that ID(*) is used for access

However, if you scroll up one page by pressing F7, you see the “Access time effect” section.

This section displays the relevant RACF class and profile. To view the profile details, enter P (Show profile), as shown in Figure 5-34, and press Enter.

```

                                IBM Security zSecure ACCESS summary                                Line 21 of 48
Command ===> _____ Scroll==> CSR
All access monitor records, Successes, Current  8 Nov 2024 10:41

    Access time effect
P  RACF class and profile          DATASET  USER.*.**
    RACF Profile type used        GENERIC
    Access allowed                 READ
    RACF return code              0

```

Figure 5-34 Accessing the involved DATASET profile from the access record details panel

This action performs a recursive call from your report to display the settings of the DATASET class profile USER.*.**, as shown in Figure 5-35.

```

                                zSecure Admin DATASET Overview                                0 s elapsed, 0.0 s CPU
Command ===> _____ Scroll==> CSR
key USER.*.**                                8 Nov 2024 11:02

_ Identification                                TVT6003
_ Profile name                                USER.*.**
_ Type                                        GENERIC
_ Volume serial list
_ Effective first qualifier                USER          DATASET OWNER?
_ Owner                                  SYSAUTH          AUTHORIZATION GRO
_ Installation data
_____

User      Access  ACL id  When          RI Name          DfltGrp
_ - any -  READ  *
_ -group-  ALTER  SUPERUSR
_ -group-  ALTER  SUPPORT
_ -group-  ALTER  SYSPROG
_ -group-  ALTER  SYS1

```

Figure 5-35 Showing the details of the DATASET profile USER.*.** from the allocated RACF input source

As expected, the profile's ACL grants ID(*) READ access.

If you inspect the other reported DATASET, SDSF, or SERVAUTH class profiles, you find that each one also includes a permission to ID(*) on either the ACL or CACL.

5.4.5 Converting generic ID(*) access to group-based access

This section explains the steps that are required to generate and run automatic RACF commands for converting generic ID(*) access to group-based access.

Important: If you logged off your RACF-Offline session earlier, start a new session now before generating the ID(*) conversion commands.

Suppose that your auditors require you to convert ID(*) permissions in DATASET class profiles to a new group that is named IDSTAR, with CRMB as both the owner and superior group.

To generate the appropriate RACF conversion commands, use option AM.9.5 (Cleanup – ID(*)), as shown in Figure 5-36.

zSecure Admin - Cleanup - ID(*)	
Command ==>	_____
Generate permits/connects to convert ID(*) selection criteria:	
Userid	_____ (userid or EGN mask)
Complex	_____ (complex or EGN mask)
SAF resource class . . .	<u>dataset</u> (class or EGN mask)
SAF resource name . . .	_____
RACF match on	_____
Intended access	__ _ 1. Read 2. Update 3. Control 4. Alter
Date selection	
From date	_____ Until date _____
Specify data for group for which permit/connect commands are generated	
Group for permit/connect	<u>idstar</u> (group name; required, no mask allowed)
Superior group	<u>crmb</u> (group name; optional for new group)
Owner for new group . . .	<u>crmb</u> (owner name; optional for new group)
Instdata new group . . .	<u>Conversion of ID(*) dataset permissions</u>
Output options	_ Background run

Figure 5-36 Generating ID(*) conversion commands for a new group that is named IDSTAR

When you press Enter, the ID(*) conversion commands are successfully generated in the CKRCMD work data set, as shown in Figure 5-37 on page 113.

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD                      Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
000001  /* CKRCMD file CKR1CMD complex TVT6003 generated  8 Nov 2024 11:21 */
000002  addgroup IDSTAR sup(CRMB) owner(CRMB) data('CONVERSION OF ID(*) -
000003  DATASET PERMISSIONS')
000004
000005  connect  CKNSERVE  group(IDSTAR) auth(use)
000006  connect  CKNSERV1  group(IDSTAR) auth(use)
000007  connect  CRMBAB2   group(IDSTAR) auth(use)
000008  connect  CRMBAH1   group(IDSTAR) auth(use)
000009  connect  CRMBAH2   group(IDSTAR) auth(use)
000010  connect  CRMBEP1   group(IDSTAR) auth(use)
000011  connect  CRMBNAT   group(IDSTAR) auth(use)
000012  connect  CRBMSG2   group(IDSTAR) auth(use)

```

Figure 5-37 ID(*) conversion commands for new group IDSTAR successfully generated

At the top of the CKRCMD data set, you find the ADDGROUP command followed by the appropriate CONNECT commands for users who historically used the ID(*) permission for DATASET profiles during the past year, as shown in Figure 5-38.

When you scroll to the bottom of the CKRCMD work data set, you see three permit commands that grant group IDSTAR the same access level that was previously granted to ID(*).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD                      Columns 00001 00072
Command ==> _____ Scroll ==> CSR
000019  connect  PAGENT   group(IDSTAR) auth(use)
000020  connect  SSHDAEM   group(IDSTAR) auth(use)
000021
000022  permit  'CATALOG.**' GEN id(IDSTAR) access(UPDATE)
000023  permit  'CRMA.X.**' GEN id(IDSTAR) access(READ)
000024  permit  'USER.*.**' GEN id(IDSTAR) access(READ)
000025
000026  setropts refresh generic(DATASET)
***** ***** Bottom of Data *****

```

Figure 5-38 ID(*) conversion commands for new group IDSTAR successfully generated (continued)

Before running the commands, verify that all users being connected to group IDSTAR require this level of access to the relevant datasets.

You can run the commands interactively by entering the command GO or RUN and pressing Enter. Alternatively, press F3 and enter R (Run) from the Results panel. You are automatically transferred to the CKRTSPRT work data set, as shown in Figure 5-39.

Scroll to the bottom of the data set to confirm that all commands ran successfully.

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT          Line 0000000060 Col 001 080
Command ==> _____ Scroll ==> CSR
connect PAGENT group(IDSTAR) auth(use)

===== 8Nov24 11:32:53.22015 start record 20 =====
connect SSHDAEM group(IDSTAR) auth(use)

===== 8Nov24 11:32:53.26403 start record 21 =====
permit 'CATALOG.**' GEN id(IDSTAR) access(UPDATE)

===== 8Nov24 11:32:53.29307 start record 23 =====
permit 'CRMA.X.**' GEN id(IDSTAR) access(READ)

===== 8Nov24 11:32:53.32110 start record 24 =====
permit 'USER.*.**' GEN id(IDSTAR) access(READ)

===== 8Nov24 11:32:53.36686 start record 25 =====
setropts refresh generic(DATASET)
=====
=== All commands completed successfully ===
=====
***** Bottom of Data *****

```

Figure 5-39 Reviewing the ID(*) conversion successful command execution

In practice, you can monitor the usage of ID(*) access to datasets over an extended period and connect more users who rely on this permission to access protected datasets.

After some time, if no new conversion commands are generated, remove the ID(*) permissions from the relevant DATASET class profiles in the Offline RACF database.

To identify these profiles, use option RA.D (RACF Administration – Data set) to report DATASET profiles that include ID(*) on the ACL. In the “Additional selection criteria” section, select the Access list option, as shown in Figure 5-40 on page 115, and press Enter.


```

zSecure Admin - RACF - Data set Selection
Command ==> _____ start panel

Add new DATASET profile or segment

Show dataset profiles that fit all of the following criteria
Dataset profile . . _____ 1 1 EGN mask
Owned by . . . . . _____ (group or userid, or filter) 2 Exact
High level qual . . _____ (qualifier or filter) 3 Match
Installation data . _____ (substring or *) 4 Any match

Additional selection criteria
_ Profile fields / Access list _ Segment presence _ Absence
_ Audit settings
Output/run options
_ Show segments _ All _ Together _ Enable full ACL _ Specify scope
_ Show differences
_ Print format Customize title Send as e-mail
_ Background run Full detail form Sort differently Narrow print
_ Print ACL Resolve to users Incl operations Print names

```

Figure 5-40 Selecting DATASET profiles based on the Access list details

In the “Id on access list” field, enter '*'.

Make sure that you enclose the asterisk in single quotation marks to prevent zSecure Admin from interpreting it as a wildcard character, as shown in Figure 5-41.

```

zSecure Admin - RACF - Data set Selection
Command ==> _____
All profiles
Specify additional selection criteria:
Find a combination of the following in the access list
# permits . . . . . _____ (operator: < <= > >= = <> ^= )
# conditional permits _____ (operator: < <= > >= = <> ^= )
_ Id on access list . . '*' _____ (*, group or userid, or filter)
When resource . . . . . _____ (resource name or filter)
Access level . . . . . _____ 1. None When class . . 1. PROGRAM
2. Execute 2. CONSOLE
3. Read 3. APPCPORT
4. Update 4. TERMINAL
5. Control 5. JESINPUT
6. Alter 6. SERVAUTH
7. Ignore 7. Present
8. Ignore

Access list filtering
_ Only show matching ACL entries

```

Figure 5-41 Selecting the DATASET profiles with access to ID(*)

After you press Enter, the system generates the panel that is shown in Figure 5-42.

zSecure Admin DATASET Overview					Line 1 of 14
Command ==>					Scroll==> CSR
All profiles with * on ACL					8 Nov 2024 12:11
Profile key	Type	UACC	Owner	S/F	W
___ AA1.DDIRS%.AASRV1.*	GENERIC	READ	AA1	U	U Y
___ AA1.DDIRTA.AASRV1.APPLID.ANYTRAN	GENERIC	NONE	AA1	R	___
___ AA1.DDIRTA.AASRV1.APPLID.TRANID	GENERIC	NONE	AA1	R	___
___ AA1.DDIRT*.AASRV1.APPLID.ANYTRAN	GENERIC	NONE	AA1	R	___
___ AA1.DDIRT*.AASRV1.APPLID.TRANID	GENERIC	NONE	AA1	R	___
___ AA1.SERVER.REXXAPI.AASRV1	GENERIC	NONE	AA1	R	___
___ AA1.SEVER.IMPORT.**	GENERIC	NONE	AA1	R	___
___ CATALOG.**	GENERIC	READ	SYSAUTH	R	___
___ CRMA.X.**	GENERIC	NONE	CRMA	U	U
___ CRMBJU1.LOADLIB	GENERIC	READ	CRMBMB1	R	___
___ CRMBRS3.*.**	GENERIC	NONE	CRMBRS3	R	___
___ SYSP.*.**	GENERIC	NONE	SYSAUTH	U	R
___ SYS1.*.**	GENERIC	NONE	SYSAUTH	R	R
___ USER.*.**	GENERIC	READ	SYSAUTH	R	R
***** Bottom of Data *****					

Figure 5-42 DATASET profiles with access to ID(*) selected

The system reports all DATASET profiles that include a permission to ID(). If you see more DATASET profiles than the ones that were listed in your earlier access monitor report, it means that users did not use the ID() permissions last year to access the protected datasets. Based on this observation, you determine that these DATASET profiles no longer need the ID(*) permission and you can remove it.

However, your organization might require you to follow a formal procedure, such as opening a change management ticket and obtaining management approval, before removing the permissions to ID(*).

Press F11 to scroll right. This action reveals a column that is labeled ID(*), which displays the access level that is granted to ID(*) in the Access Control List (ACL) or Conditional Access Control List (CACL) of each relevant DATASET profile (see Figure 5-43 on page 117).

zSecure Admin DATASET Overview				Line 1 of 14	
Command ==>				Scroll==> <u>CSR</u>	
All profiles with * on ACL		8 Nov 2024 12:11			
Profile key	E SgF	ID(*)	Complex	Notify	
AA1.DDIRS%.AASRV1.*	—	UPDATE	TVT6003	—	
AA1.DDIRTA.AASRV1.APPLID.ANYTRAN	—	READ	TVT6003	—	
AA1.DDIRTA.AASRV1.APPLID.TRANID	—	UPDATE	TVT6003	—	
AA1.DDIRT*.AASRV1.APPLID.ANYTRAN	—	READ	TVT6003	—	
AA1.DDIRT*.AASRV1.APPLID.TRANID	—	UPDATE	TVT6003	—	
AA1.SERVER.REXXAPI.AASRV1	—	NONE	TVT6003	—	
AA1.SEVER.IMPORT.**	—	READ	TVT6003	—	
CATALOG.**	—	UPDATE	TVT6003	—	
CRMA.X.**	—	READ	TVT6003	—	
CRMBJU1.LOADLIB	—	READ	TVT6003	—	
CRMBRS3.*.**	—	UPDATE	TVT6003	—	
SYSP.*.**	—	READ	TVT6003	—	
SYS1.*.**	—	EXECUTE	TVT6003	—	
<u>S</u> USER.*.**	—	READ	TVT6003	—	
***** Bottom of Data *****					

Figure 5-43 DATASET profiles with an access level of permission to ID(*) reported

To view the details of the DATASET profile USER.*.**, enter S, which displays the settings for the profile.

To delete the permission for ID(*), enter D before the corresponding ACL entry, then press Enter (see Figure 5-44).

zSecure Admin DATASET Overview				Line 1 of 51	
Command ==>				Scroll==> <u>CSR</u>	
All profiles with * on ACL		8 Nov 2024 12:19			
Identification				TVT6003	
Profile name		USER.*.**			
Type		GENERIC			
Volume serial list					
Effective first qualifier		USER		DATASET OWNER?	
Owner		<u>SYSAUTH</u>		AUTHORIZATION GRO	
Installation data					
User	Access	ACL id	When	RI Name	DfltGrp
D - any -	READ	*			
-group-	<u>ALTER</u>	<u>SUPERUSR</u>			
-group-	<u>ALTER</u>	<u>SUPPORT</u>			
-group-	<u>ALTER</u>	<u>SYSPROG</u>			
-group-	<u>ALTER</u>	<u>SYS1</u>			
AXRSTC	READ	<u>AXRSTC</u>		AXR USER2	AXRGRP
AXRUSER	READ	<u>AXRUSER</u>			AXRGRP
CRMBEP1	<u>UPDATE</u>	<u>CRMBEP1</u>		SYSPROG1 EP	CRMB
CRMBGUS	<u>UPDATE</u>	<u>CRMBGUS</u>		SYSPROG GUS	CRMA

Figure 5-44 Requesting the deletion of the permission to ID(*)

Select option 1, then press Enter to run the RACF command (see Figure 5-45).

zSecure Admin - Confirm command	
Command ==>	_____
Confirm the following delete command	
<u>permit 'USER.*.*' id(*) delete</u>	

Command execution . 1	1. EXECUTE RACF command 2. EXECUTE CKGRACF command (allows use of Reason) 3. ASK administrator to run CKGRACF command 4. REQUEST CKGRACF command for later execution 5. WITHDRAW CKGRACF command
Specify date for command to be run	
Start date	_____ (ddmmmyyyy, yyyy-mm-dd or TODAY)
Until/for	_____ (ddmmmyyyy, yyyy-mm-dd or number of days)
Reason	_____
Press ENTER to continue or END to cancel the command	

Figure 5-45 Running the deletion of the permission to ID(*)

Repeat the same steps to remove the ID(*) permissions from the DATASET profiles CATALOG.** and CRMA.X.**.

Exit your RACF-Offline session, then start ISPF to verify the results of the conversion against the offline RACF database.

You can now confirm whether your conversion commands worked as intended. Simulate historical access events against the offline RACF database for the DATASET class. The results should show that access through ID(*) no longer occurs.

Use option AM.1 again to generate a report of ID(*) access to DATASET class profiles (see Figure 5-46 on page 119).

```

zSecure Admin - Access - Access
Command ==> _____

Show records that fit all of the following criteria:
Userid . . . . . _____ (userid or EGN mask)
Complex . . . . . _____ (complex or EGN mask)
SAF resource class . . DATASET (class or EGN mask)
SAF resource name . . . _____
RACF match on . . . . . _____

Advanced selection criteria
/ Further selection _ Date selection / Current RACF DB selection

Output/run options
2 1. Summary by userid
   2. Summary by member class and profile
   3. Summary by simulated authorization used
   4. Summary by simulated groups used for access
_ Show configured fields / Show simulated fields _ Timezone (U/L/H)
_ Print format          Customize title          Send as e-mail
_ Background run        Full page form

```

Figure 5-46 Verifying whether DATASET access through a permission to ID(*) still occurs

On the next panels (not shown in this document), select only the successful access events. In the “Authority used in current DB” section, choose the ID_STAR option, then press Enter to generate the report (see Figure 5-47).

```

zSecure Admin - Access - Access          No records found
Command ==> _____

Show records that fit all of the following criteria:
Userid . . . . . _____ (userid or EGN mask)
Complex . . . . . _____ (complex or EGN mask)
SAF resource class . . DATASET (class or EGN mask)
SAF resource name . . . _____
RACF match on . . . . . _____

Advanced selection criteria
/ Further selection _ Date selection / Current RACF DB selection

Output/run options
2 1. Summary by userid
   2. Summary by member class and profile
   3. Summary by simulated authorization used
   4. Summary by simulated groups used for access
_ Show configured fields / Show simulated fields _ Timezone (U/L/H)
_ Print format          Customize title          Send as e-mail
_ Background run        Full page form

```

Figure 5-47 Results of query whether permission to ID(*) to access DATASET resources

The “No records found” message in the upper right of your display confirms that, after the conversion, no datasets are accessed through permission to ID(), which indicates that the conversion of ID() permissions to group IDSTAR was successful.

You can now repeat the same steps to run the ID(*) conversion commands against the active primary RACF database.

You can apply similar steps to migrate ID() permissions in other reported classes, such as SDSF and SERVAUTH. Alternatively, you can generate a report of all profiles in your RACF database that include a permission to ID(). Any classes and profiles that are listed in this report, but not shown in your access overview, represent permissions that were not used in the past year. These profiles are strong candidates for additional cleanup.

5.4.6 Converting generic OPERATIONS access to group-based access

This section outlines the steps for generating and running automatic RACF commands to convert generic OPERATIONS access to group-based access.

The approach for converting OPERATIONS access is similar to the method that is used for converting UACC and ID(*) permissions. However, the zSecure Admin user interface does not support automatic generation of commands for converting OPERATIONS access to group-based access.

With some manual adjustments to the CARLa Auditing and Reporting Language (CARLa) code that zSecure Admin uses behind the scenes, you can perform this conversion semi-automatically.

To begin, use option AM.1 to report successful access events that occurred through OPERATIONS to datasets (see Figure 5-48).

zSecure Admin - Access - Access

Command ==> _____

Show records that fit all of the following criteria:

Userid _____ (userid or EGN mask)

Complex _____ (complex or EGN mask)

SAF resource class . . **DATASET** (class or EGN mask)

SAF resource name . . . _____

RACF match on _____

Advanced selection criteria

☒ Further selection ☐ Date selection ☒ Current RACF DB selection

Output/run options

☒ 1. Summary by userid

☐ 2. Summary by member class and profile

☐ 3. Summary by simulated authorization used

☐ 4. Summary by simulated groups used for access

☐ Show configured fields ☐ Show simulated fields ☐ Timezone (U/L/H)

☐ Print format ☐ Customize title ☐ Send as e-mail

☐ Background run ☐ Full page form

Figure 5-48 Reporting historic access to resources summarized by user ID

After you press Enter, the next selection panel appears.

For this analysis report, focus only on successful access events. In the Result section, select the Success option by entering / or S, then press Enter (see Figure 5-49).

zSecure Admin - Access - Further selection

Command ==>

Access monitor records for Profiles like **, Classes like DATASET

Select access records(Y/N/blank)

Use of RACF commands

Use of global access checking table

Use of discrete profiles

System special authority used

Operations authority used

Installation exit used

User requesting access is owner

Retrieval of access allowed

Bypass JESSPOOL profiles

ID was undefined during event

User had special attribute

User had operations attribute

User had (ro)auditor attribute

Resource action

Intended access

Result

Program status

Define

Delete

Addvol

Chgvol

1. Read

2. Update

3. Control

4. Alter

/ Success

No profile

Not authorized

Other

Defined program

Controlled program

Specific program

Controlled library

Figure 5-49 Reporting only successful access events

The “Current RACF DB selection” panel appears.

On this panel, specify that the report should include only successful access through the system-OPERATIONS attribute. In the “Authority used in current DB” section, select the SYS_OPER option by entering / or S, then press Enter (see Figure 5-50).

zSecure Admin - Access - Current Database

Command ==>

Access monitor records for Profiles like **, Classes like DATASET, Successes

Specify simulated fields (Current DB effect) selection criteria:

Groups used for access

Essential groups . . .

Not using groups . . .

Profile owned by . . .

RACF return code . . .

(groups or filter)

(Y/N/blank)

(groups or filter)

(id or filter)

(operator: > >= < <= = <> ^=)

Authority used in current DB

APF

CLAUTH

CREATE

DFLTRC

GLOBAL

GRP_OPER

GRP_SPEC

GRP_UACC

ID_GROUP

ID_STAR

ID_USER

INACTIVE

NO_CDT

NO_PROF

NOTHING

PRIVTRUS

PROTFAIL

QUALOWN

RESTRICTED

SPOOLRCVR

/ SYS_OPER

SYS_SPEC

UACC

UNPROT

WARNING

User attributes in current DB (Y/N/blank)

ID present

ID has special

ID Revoked

ID has operations

ID has (ro)auditor

Figure 5-50 Reporting the successful access events that used system-OPERATIONS

Figure 5-51 shows that two users with the OPERATIONS attribute successfully accessed datasets.

IBM Security zSecure ACCESS summary					1 s elapsed, 0.3 s CPU	
Command ==> _____				Scroll==> <u>CSR</u>		
Access monitor records for Profiles like **, C1 8 Nov 2024 17:16						
	Occurrence	Userid	Name		First occurrence	Last occur
—	10693	IBMUSER	TO BE REVOKED-LATER		31Oct2023 23:00	31Oct2024
—	930	IWST	IWS TRACKER		3Nov2023 22:46	31Oct2024
***** Bottom of Data *****						

Figure 5-51 Successful DATASET access events that used system-OPERATIONS

Because option AM.9 does not support automatic conversion of OPERATIONS usage, you must use a more manual approach. This method requires advanced knowledge of, and experience with, the zSecure specific CARLa programming language.

Press F3 to return to the AM.1 report. Then, type RESULT in the CLI and press Enter to open the zSecure Results panel, which displays the zSecure work datasets (see Figure 5-52).

zSecure Admin - Results	
Command ==> _____	
The following selections are supported:	
B Browse file	S Default action (for each file)
E Edit file	R Run commands
P Print file	J Submit Job to run commands
V View file	M E-mail report
W Write file into seq. or partitioned data set	
Enter a selection in front of a highlighted line below:	
— SYSPRINT	messages
— REPORT	printable reports
— CKRTSPRT	output from the last TSO commands
— CKRCMD	queued TSO commands
— CKR2PASS	queued commands for zSecure Admin for RACF
<u>S</u> COMMANDS	zSecure Admin for RACF input commands from last query
— SPFLIST	printable output from PRT primary command
— OPTIONS	set print options

Figure 5-52 Results panel of successful DATASET access events that used system-OPERATIONS

The CARLa script that is generated by your selection filters is stored in the COMMANDS work data set.

Enter S to open the CARLa code. Then press Enter to access the COMMANDS work data set, which contains the CARLa code that was used to produce your report (see Figure 5-53 on page 123).


```

EDIT          CRMBTZ1.CARLA.SAMPLES(@CRMBTZ1) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
000001 /* generated by CKRP3AMZ */
000002 newlist type=access nodetailinherit required,
000003 st=",
000004 Access monitor records for Classes like DATASET, Resources like **,
000005 Successes, Current RACF DB=, SYS_OPER",
000006 sumhelppanel=ckrt3ami,
000007 helppanel=ckrt3ami,
000008 detailhelppanel=ckrt3ami
000009 define tot_count("Occurrence",10,udec$abbr) sum(access_count_big)
000010 define avg_reclen avg(record_length)
000011 define first_tod_sum("First occurrence") min(last_tod)
000012 define last_tod_sum("Last occurrence") max(last_tod)
000013 select ,class=DATASET,access_profile=**, sim_via=(,,
000014 SYS_OPER),,access_result=("00"x) rectype=(auth,fast,def)
000015 display last_tod(nd) access_count("Occurrence") last_tod,
000016 / "Access summary"(d,ch),
000017 / complex(d,p),
000018 / userid(d,p) userid:name(d),

```

Figure 5-53 COMMANDS work data set shows the CARLa that was used to produce OPERATIONS usage report

The bolded **SELECT** statement in the report reflects the panel selections that you made to generate the system-OPERATIONS access report. You can copy this statement and use it as the foundation for your own CARLa program to generate system-OPERATIONS conversion commands instead of a report.

After copying the SELECT statement, press F3. Then, enter CARLa on the CLI and press Enter to open the CARLa editor. If you have used the editor before, your previous CARLa code will still be available. If this is your first time using it, the editor opens with a blank panel (see Figure 5-54).

```

EDIT          CRMBTZ1.CARLA.SAMPLES(#CRMBTZ1) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to run commands, SUB or SUBMIT to generate batch job
=NOTE= END or SAVE to save in ISPF profile
000001
.....
.....
.....

```

Figure 5-54 CARLa editor at first usage

Next, copy the following CARLa code into your CARLa editor (see Figure 5-55).

```

EDIT          CRMBTZ1.CARLA.SAMPLES(#CRMBTZ1) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
000001 newlist type=racf dd=ckrcmd nopage outlim=1
000002 sortlist "addgroup <group name> sup(<superior group>) owner(<owner>)",
000003           "data('<Description of system-OPERATIONS access group>')"
000004
000005 newlist type=access dd=ckrcmd nopage nodup
000006 select class=DATASET sim_via=(SYS_OPER) access_result=("00"x),
000007           rectype=(auth,fast)
000008 sortlist "pe ' ' | access_profile(0) | ' ' generic id(<group name>)",
000009           "access(" | intent(0) | ")"
000010 sortlist "co" userid(0) "group(<group name>) authority(use) uacc(none)"
***** ***** Bottom of Data *****

```

Figure 5-55 CARLa code to generate automatic system-OPERATIONS conversion commands

Additional notes and explanations about the copied CARLa code:

- ▶ If you are converting system-OPERATIONS access to an existing group, you can remove the first four lines of the script that define a new group profile because these lines are not needed.
- ▶ All NEWLIST statements in this CARLa program direct their output to the CKRCMD work data set by using the dd=ckrcmd specification.
- ▶ The NOPAGE keyword disables the page layout because this CARLa script generates RACF commands rather than a report.
- ▶ The OUTLIM=1 setting in line 1 limits the NEWLIST output to a single record.
- ▶ The SORTLIST statements in lines 2 and 3 generate the appropriate ADDGROUP command to define a RACF group.
- ▶ Replace the placeholder values shown as <....> with the values that you want to assign to the new group.
- ▶ The NODUP keyword in the NEWLIST statement on line 5 prevents duplicate PERMIT commands from being generated when a user accessed the same data set multiple times.
- ▶ The SELECT statement in lines 6 and 7 is copied from your earlier report. It has been cleaned up by removing unnecessary commas and parentheses to improve readability. The rectype=def filter has also been removed to avoid generating conversion commands for DEFINE requests that report pseudo access levels such as DEFCREATE, DEFDELETE, DEFCHGVOL, and DEFADDVOL.
- ▶ The SORTLIST statements in lines 8 and 9 generate the appropriate permit commands for system-OPERATIONS users, assigning access to the target group based on the access level that is recorded by Access Monitor. The GENERIC keyword helps ensure proper handling of fully qualified generic (FQG) dataset profiles. The vertical bars (|) are concatenation characters that are used to suppress automatic spacing between columns.
- ▶ The SORTLIST statement in line 10 generates the CONNECT commands to the target group that is used in this conversion.

Running the CARLa script with the GO or RUN command should produce output similar to what is shown in Figure 5-56 on page 125.

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
000001 /* CKRCMD file CKR1CMD complex TVT6003 generated  8 Nov 2024 18:18 */
000002 addgroup grpoper sup(crm) owner(crm) data('Conversion of OPERATIONS -
000003 dataset access group')
000004 pe 'CRMBEP1.*.*' generic id(grpoper) access(READ)
000005 pe 'CRMBEP1.*.*' generic id(grpoper) access(ALTER)
000006 pe 'CRMBMK1.*.*' generic id(grpoper) access(READ)
000007 pe 'CRMBPH1.*.*' generic id(grpoper) access(READ)
000008 pe 'CRMBPH1.*.*' generic id(grpoper) access(ALTER)
000009 pe 'CRMBRL1.*.*' generic id(grpoper) access(ALTER)
000010 pe 'CRMBRS1.*.*' generic id(grpoper) access(READ)
000011 pe 'CRMBRS1.*.*' generic id(grpoper) access(ALTER)
000012 pe 'CRMBTZ1.*.*' generic id(grpoper) access(ALTER)
000013 pe 'CRMBVK1.*.*' generic id(grpoper) access(ALTER)
000014 pe 'CRMBVK2.*.*' generic id(grpoper) access(ALTER)
000015 pe 'C2PACMON.*.*' generic id(grpoper) access(READ)
000016 pe 'SYSAPPL.*.*' generic id(grpoper) access(READ)
000017 co IBMUSER group(grpoper) authority(use) uacc(none)
000018 co IWSM group(grpoper) authority(use) uacc(none)
***** ***** Bottom of Data *****

```

Figure 5-56 Automatically generated system-OPERATIONS conversion commands

Before running the commands, review the generated permit statements to identify and remove duplicates to the same DATASET profile with different access levels. Keep only the permit command with the highest access level.

In this example, delete the commands on lines 4, 7, and 10 before running the commands.

When you run the commands, the system transfers you to the CKRTSPRT work data set as usual (see Figure 5-57). Scroll to the bottom of the output to confirm that all commands ran successfully.

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT          Line 0000000032 Col 001 080
Command ==> _____ Scroll ==> CSR
pe 'CRMBVK1.*.**' generic id(grpoper) access(ALTER)

===== 8Nov24 18:20:28.23371 start record 11 =====
pe 'CRMBVK2.*.**' generic id(grpoper) access(ALTER)

===== 8Nov24 18:20:28.23724 start record 12 =====
pe 'C2PACMON.*.**' generic id(grpoper) access(READ)

===== 8Nov24 18:20:28.24029 start record 13 =====
pe 'SYSAPPL.*.**' generic id(grpoper) access(READ)

===== 8Nov24 18:20:28.24356 start record 14 =====
co IBMUSER group(grpoper) authority(use) uacc(none)

===== 8Nov24 18:20:28.25080 start record 15 =====
co IWST group(grpoper) authority(use) uacc(none)
=====
=== All commands completed successfully ===
=====
***** Bottom of Data *****

```

Figure 5-57 Confirming the successful execution of system-OPERATIONS conversion commands

If the users IBMUSER and IWST did not use OPERATIONS access for other resources in classes that acknowledge the OPERATIONS attribute (which you have not yet verified), you can safely remove the OPERATIONS attribute from their profiles. To verify whether OPERATIONS access was used, use the same steps that are outlined in Figure 5-25 on page 106 through Figure 5-27 on page 107 to exit your RACF-Offline session. Then, verify that no system-OPERATIONS access is reported for the DATASET class (see Figure 5-58 on page 127).

zSecure Admin - Access - Access		No records found
Command ==> _____		
Show records that fit all of the following criteria:		
Userid	_____	(userid or EGN mask)
Complex	_____	(complex or EGN mask)
SAF resource class . .	<u>DATASET</u>	(class or EGN mask)
SAF resource name . . .	_____	
RACF match on	_____	
Advanced selection criteria		
☒ Further selection ☐ Date selection ☒ Current RACF DB selection		
Output/run options		
☒ 1. Summary by userid ☐ 2. Summary by member class and profile ☐ 3. Summary by simulated authorization used ☐ 4. Summary by simulated groups used for access		
☐ Show configured fields	☐ Show simulated fields	☐ Timezone (U/L/H)
☐ Print format	☐ Customize title	☐ Send as e-mail
☐ Background run	☐ Full page form	

Figure 5-58 Confirming that no system-OPERATIONS data set access occurs

If everything worked as expected, no system-OPERATIONS access is reported for the DATASET class.

You can apply the same approach and steps to convert system-OPERATIONS usage in other resource classes.

Now, repeat the same steps to run the OPERATIONS attribute conversion commands against the active primary RACF database.



Minimizing access control privileges

Minimizing access control privileges, also known as the principle of least privilege, is essential for reducing the risk of security breaches. Granting users only the minimum access that is necessary to perform their job limits the potential damage if their credentials are compromised or misused, whether through malicious actions or negligence.

The following topics are covered in this chapter:

- ▶ 6.1, “Challenges with access control privileges” on page 130
- ▶ 6.2, “Avoiding the need to trust privileged users” on page 130
- ▶ 6.3, “Revealing permitted access levels that exceed a need” on page 132
- ▶ 6.4, “Minimizing access control privileges” on page 132

6.1 Challenges with access control privileges

IBM Resource Access Control Facility (RACF) administrators face an ongoing challenge: minimizing access control privileges to protect sensitive data and systems from unauthorized access or manipulation. In many RACF environments, users retain permissions that are either no longer necessary or exceed what their roles require.

Several factors contribute to this issue:

- ▶ Business process owners often request RACF permissions when needed, but they rarely notify RACF administrators when those permissions are no longer required. As a result, outdated privileges remain in place.
- ▶ Requesters might not fully understand the application or resource they need access to. They might ask for broader privileges than necessary, leading RACF administrators to grant excessive access.
- ▶ Over time, job roles and application requirements evolve. Without regular reviews, RACF databases accumulate permissions that no longer align with current organizational needs.
- ▶ Overly permissive access definitions can create serious problems. They might cause organizations to fail internal or external audits and expose systems to unnecessary risk. When users can access features or data they do not need, the organization's security posture weakens.

6.2 Avoiding the need to trust privileged users

The principle of least privilege plays a central role in modern, well-managed security environments. Applying this principle in RACF environments is essential for maintaining a secure and efficient system. To support this goal, administrators should follow these key practices:

- ▶ Permitting higher access levels is a poor security practice
- ▶ Minimizing the usage of overly permissive RACF attributes
- ▶ Minimizing the usage of the WARNING attribute
- ▶ Minimizing the usage of global access checking tables

6.2.1 Permitting higher access levels is a poor security practice

Granting higher access levels than necessary is a poor security practice. In RACF, permissions are defined as a hierarchy of access levels, where each level includes the privileges of the levels below it. To follow the principle of least privilege, administrators must ensure that users receive only the access level that is required for their job responsibilities.

For example, if a user needs only READ access to a resource that is protected by a RACF profile, the administrator must not grant UPDATE, CONTROL, or ALTER access instead. Although RACF does not generate authorization errors in such cases, excessive permissions increase the risk of security exposures.

This scenario illustrates the importance of enforcing least privilege. Granting ALTER access when only READ is needed violates this principle and creates opportunities for compromised or malicious users to perform unauthorized actions. Overly permissive access definitions weaken security and can lead to serious vulnerabilities.

6.2.2 Minimizing the usage of overly permissive RACF attributes

In RACF, administrators must also monitor other attributes and access methods to enforce the principle of least privilege. Certain user attributes, such as AUDITOR, OPERATIONS, SPECIAL, TRUSTED, and PRIVILEGED, grant elevated authority. These privileges must be assigned only when necessary and must be carefully documented and reviewed to prevent unauthorized or excessive access.

User IDs with the OPERATIONS attribute receive ALTER access to resources in the dataset and general resource classes that acknowledge this attribute. When such a user accesses a resource in one of these classes, RACF grants ALTER access by default. However, if the user ID or one of its connected groups is granted a different access level, RACF uses the access level that is defined in the access control list (ACL) or conditional ACL (CACL) instead.

Auditors often flag the usage of the OPERATIONS attribute as uncontrolled access. Assigning this attribute violates the principle of least privilege by granting broad, default permissions. It also undermines zero trust principles by bypassing granular access controls.

To strengthen your system's security posture, replace the OPERATIONS attribute with explicit permissions that align with the user's job responsibilities. This approach helps ensure tighter control and better alignment with least privilege and zero trust models.

6.2.3 Minimizing the usage of the WARNING attribute

When the WARNING attribute is activated on a resource profile, RACF bypasses access verification checks for that resource. This attribute is intended for use during the implementation phase, when it is unclear which users require specific access levels.

If a non-authorized user attempts to access a resource that is protected by a profile in WARNING mode, RACF grants ALTER access, even if the user or their connected groups are not explicitly permitted. RACF logs this access to System Management Facilities (SMF), enabling security administrators to analyze the records and update the ACL and CACL with appropriate permissions. After a period of monitoring and adjustment, administrators can remove the WARNING attribute without disrupting access.

Using the WARNING attribute violates both the principle of least privilege and the zero trust model by granting broad, default access to all users. While useful during initial setup, it must be used cautiously and only for a limited time.

6.2.4 Minimizing the usage of global access checking tables

Global access checking (GAC) tables can improve the performance of access verification in RACF by granting specific access levels to certain resources without checking RACF profiles or logging to SMF. Many organizations grant public READ access to public resources. For example, a bank might allow all users to READ interest rate information to attract potential customers.

However, the GAC tables must not grant access to resources when access to the resource would not be allowed for certain users, or when the company must report who accessed that resource. The usage of GAC tables and the list of globally accessible resources must be monitored.

Improper usage of tables violates the principle of zero trust because it grants access to the specified resource to all users.

6.3 Revealing permitted access levels that exceed a need

Reporting overly permissive access is a challenge in a RACF environment. Although SMF records can show when profile permissions are used and what level of access was granted, performing bulk analysis across all relevant profiles requires extensive auditing and processing.

IBM zSecure Access Monitor simplifies this task by generating reports that highlight ACL entries where the permitted access level exceeds what the user requested. Also, administrators can use CARLa Auditing and Reporting Language (CARLa) scripts to automatically generate RACF commands that reduce excessive privileges and support a migration to a least privilege model.

Before applying these changes to a live RACF database, administrators can test their impact by using RACF-Offline. This approach allows for safe validation of security adjustments in an offline environment.

Although this section focuses on reporting excessive access, it complements discussions about managing permissive attributes such as OPERATIONS, WARNING, and global access checking (GAC). Detailed steps for identifying and refining these attributes are provided in Chapter 5, “Converting generic and specific access to group-based access” on page 85.

6.4 Minimizing access control privileges

The general preparation steps for use cases that involve automated or semi-automated conversion and cleanup features in IBM zSecure Admin are documented in 2.4, “General preparation steps for the use cases” on page 16. These steps include:

- ▶ Creating a RACF-Offline database
- ▶ Starting a RACF-Offline session
- ▶ Logging on to the RACF-Offline session
- ▶ Resetting the RACF-Offline log data set
- ▶ Starting and preparing your zSecure Admin session

After completing these steps, you can proceed with the next phase: minimizing access control privileges, which includes the following steps.

- ▶ Reporting the historical permitted DATASET access levels that exceed the used access levels
- ▶ Implementing least privilege for the DATASET class
- ▶ Verifying the permit commands for the DATASET class
- ▶ Running permit commands against the active primary RACF database
- ▶ Reporting permitted general resource access levels that exceed the used access levels

6.4.1 Reporting the historical permitted DATASET access levels that exceed the used access levels

This section explains how to report historical DATASET access where the allowed access level exceeds the level that is used.

You can use allocated Access Monitor records to identify users who successfully accessed resources with more privileges than they used. To generate this report, use option AM.3 (Permit usage). This report shows users who accessed resources with a requested access level that is lower than their permitted access level.

After you press Enter, the Further selection panel opens. On this panel, select the option Highest access used less than access allowed to identify cases where the principle of least privilege might not be properly enforced (see Figure 6-2). Then, press Enter to continue.

zSecure Admin - Access - Further selection

Command ==>

Access monitor records for Classes like DATASET, non-zero counts

Access selection

#Accesses allowed . . .

#Accesses prevented . .

#Accesses unexplained

Permit selection

Creation date from . .

Until

/

Highest access used less than access allowed

Access allowed

Highest access used

Lowest violation

>=

—

1. Execute

<=

—

1. Read

>=

—

1. Read

2. Read

2. Update

2. Update

3. Update

3. Control

3. Control

4. Control

4. Alter

4. Alter

5. Alter

Figure 6-2 Reporting historic DATASET access where the highest access that is used is less than the access that is allowed

This selection generates a permit usage overview report for DATASET profiles that users accessed, where the permitted access level exceeds the highest level that they used. To review the details, enter S (see Figure 6-3) and press Enter, which opens the DATASET profile, where you can examine the ACL and identify permissions that might be candidates for reduction.

Line 1 of 32

Unconditional permits and UACC, by class complex/profile

Command ==>

Scroll==> CSR

Access monitor records for Classes like DATASET 12 Nov 2024 14:30

Allowed

Deny

Unexp

LastUse

Class

Complex

4108400

264

0

31Oct24

DATASET

TVT6003

Allowed

Deny

Unexp

LastUse

Type

Profile

13011

0

0

31Oct24

GENERIC

CATALOG.**

S

20442

0

0

31Oct24

GENERIC

CKNSERVE.**

7

0

0

23Oct24

GENERIC

CRMA.T.**

20710

0

0

31Oct24

GENERIC

CRMA.X.**

6378

0

0

31Oct24

GENERIC

CRMAUTO.**

1

0

0

12Sep24

GENERIC

CRMBAH1.TEST12.**

187

0

0

5Dec23

GENERIC

CRMBEP1.*.**

96

0

0

31Oct24

GENERIC

CRMBJK1.*.**

65

0

0

17Sep24

GENERIC

CRMBJU1.**

2

0

0

17Sep24

GENERIC

CRMBJU1.LOADLIB

4888

0

0

30Oct24

GENERIC

CRMBMK1.*.**

2

0

0

13Sep24

GENERIC

CRMBMK1.TE%T

30

0

0

22Mar24

GENERIC

CRMBPH1.*.**

Figure 6-3 Reporting DATASET profiles where the allowed access level exceeds the used access level

In the upper right, the message “Line 1 of 32” indicates that 32 DATASET profiles allow more access than users used, which suggests that 32 profiles might need to be reviewed and tightened to align with the principle of least privilege.

The next panel displays the specific permissions where the allowed access level exceeds the used access level (see Figure 6-4).

Unconditional permits and UACC, by class complex/profile

Command ==> _____ Scroll==> CSR

Access monitor records for Classes like DATASET 12 Nov 2024 14:30

Allowed	Deny	Unexp	LastUse	Class	Complex					
4108400	264	0	31Oct24	DATASET	TVT6003					
Allowed	Deny	Unexp	LastUse	Type	Profile					
20442	0	0	31Oct24	GENERIC	CKNSERVE.**					
Allowed	Deny	Unexp	LastUse	Id	Access	Used	Failed	Red	RdM	Name
1	0	0	25Oct24	CKNSERVE	QUALOWN	READ		No		MULTI
<u>S</u> 20441	0	0	31Oct24	C2RSERVG	UPDATE	READ		No		

***** Bottom of Data *****

Figure 6-4 Profile CKNSERVE.** permissions where allowed access exceeds used access

Note: By default, Access Monitor includes administrative authority, which is indicated by the access level QUALOWN. This access level does not result from an explicit permission. Instead, it shows that the user ID matches the high-level qualifier (HLQ) of the datasets, making the user the implicit owner. As the owner, the user is always granted ALTER access to those datasets, for example, the CKNSERVE datasets in this case.

The report shows that user C2RSERVG successfully used the UPDATE permission 20,441 times to access datasets with the high-level qualifier (HLQ) CKNSERVE. However, during all of these historical access events, the user only exercised READ access, even though UPDATE was permitted.

To review the access record details, enter S and press Enter. As shown in Figure 6-5, you can optionally enter P to show the profile at the “RACF class and profile” field. Pressing Enter performs a recursive call from the report to display the profile definitions for the relevant resource, in this case, the DATASET profile CKNSERVE.***.

```

Line 1 of 28
Unconditional permits and UACC, by class complex/profile
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like DATASET 12 Nov 2024 16:03

  Profile in current database
  _ Security complex name      TVT6003
  P RACF class and profile    DATASET  CKNSERVE.**
  Profile type                GENERIC
  Volume serial
  Resource location
  Installation data

  Unconditional permit
  _ Permit or connect id      C2RSERVG
  Access or authority        UPDATE
  Highest access used        READ
  Lowest access prevented
  Permit reduces access      No
  Merged permit reduces access
  Username
  Installation data

```

Figure 6-5 Profile CKNSERVE.** permission to C2RSERVG

After you press Enter, the security definitions for the DATASET profile that is named CKNSERVE.*** appear (see Figure 6-6 on page 137). As expected, the ACL includes a permission granting group ID C2RSERVG the UPDATE access level.

To tighten security, you can manually reduce this access by typing over UPDATE with READ, pressing Enter, and running the generated command.

However, this is just one instance. Access Monitor records show that other DATASET profiles also grant access levels that exceed what users historically used. These profiles should also be reviewed and adjusted to align with the principle of least privilege.

zSecure Admin DATASET Overview				0 s elapsed, 0.0 s CPU	
Command ==>			Scroll==> CSR		
key CKNSERVE.**			12 Nov 2024 16:07		
- Identification				TVT6003	
Profile name		CKNSERVE.**			
Type		GENERIC			
Volume serial list					
Effective first qualifier		CKNSERVE MULTI-SYS SERVER		ZSECURE 1.12+ MUL	
Owner		SYSPROG		SYSTEM PROGRAMMIN	
Installation data					
User	Access	ACL id	When	RI Name	DfltGrp
-group-	READ	CRMBZDEV			
-group-	READ	CRMCXGRP			
-group-	READ	CRMQA			
-group-	UPDATE	C2RSERVG			
-group-	ALTER	SYSPROG			
CKNSERVE	ALTER	CKNSERVE		MULTI-SYS SERVER	C2RSERV
CRMBGUS	UPDATE	CRMBGUS		SYSPROG GUS	CRMA
CRMBPH1	UPDATE	CRMBPH1		SYSPROG1 PH	CRMA

Figure 6-6 DATASET profile CKNSERVE.** security settings reported

Instead of manually updating the permitted access levels for this and the other 32 affected DATASET profiles, you can automate the process by using your CARLa programming skills. With CARLa, you can generate the appropriate permit commands to reduce each user's access level to match the highest level they used.

To begin, press F3 repeatedly until you return to the AM.3 “Permit usage” panel.

6.4.2 Implementing least privilege for the DATASET class

This section explains how to generate and run automatic permit commands to enforce the principle of least privilege for the DATASET class.

When you used the recursive call to display the security definitions of the DATASET profile CKNSERVE.**, it overwrote the CARLa code that was originally composed to generate your permit usage report. To restore the CARLa code, rerun the “Permit usage overview” report. This time, avoid using P (Show profile) to display the CKNSERVE.** profile.

Instead, press F3 once to return to the AM.3 “Permit usage” panel.

Next, enter the command result on the CLI and press Enter to access the zSecure work datasets on the Result panel (see Figure 6-7).

zSecure Admin – Access - Per		0.2 s CPU, RC=4
Command ==> <u>result</u>		
Show permits that fit all of the following criteria:		
Permit id	_____	(permit id or EGN mask on access list)
Class	<u>dataset</u>	(class or EGN mask)
RACF profile name . . .	_____	
Complex	_____	(complex or EGN mask)
Show accesses	<u>/</u> Non-zero counts	_ Zero counts
Profile to use <u>2</u> 1. Use historic profile name in access summary if present 2. Simulate access in database to find current profile		
Advanced selection criteria		
<u>/</u> Further selection		_ Date selection
Output/run options		
_ Print format	Customize title	Send as e-mail
_ Background run	Full page form	

Figure 6-7 Using the result command to access zSecure work datasets

After you press Enter, the zSecure Results panel appears. The CARLa code that used to generate your report (showing which DATASET profiles grant higher access levels than users used) is stored in the COMMANDS work data set.

To view this code, enter S or E to open the COMMANDS work data set (see Figure 6-8).

zSecure Admin - Results	
Command ==> _____	
The following selections are supported:	
B Browse file	S Default action (for each file)
E Edit file	R Run commands
P Print file	J Submit Job to execute commands
V View file	M E-mail report
W Write file into seq. or partitioned data set	
Enter a selection in front of a highlighted line below:	
_ SYSPRINT	messages
_ REPORT	printable reports
_ CKRTSPRT	output from the last TSO commands
_ CKRCMD	queued TSO commands
_ CKR2PASS	queued commands for zSecure Admin
<u>S</u> COMMANDS	zSecure Admin input commands from last query
_ SPFLIST	printable output from PRT primary command
_ OPTIONS	set print options

Figure 6-8 Using to access the COMMANDS work data set from the Results panel

When you press Enter, the contents of the COMMANDS work data set appear. The top section of the CARLa script includes statements that define the layout of the report, as shown in Figure 6-3 on page 134. These DEFINE statements create statistical fields and counters that are used in the standard permit usage report. However, this section is not your focus.

Your goal is to locate the SELECT statement that filters Access Monitor records to show only access events where the permitted access level exceeds the used access level. To find these events, press F8, then press Enter to scroll down through the script until you reach the SELECT statement that was generated by the UI-based selection filters (see Figure 6-9).

```

EDIT          CRMBTZ1.CARLA.SAMPLES(@CRMBTZ1) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to execute commands, SUB or SUBMIT to generate batch job
=NOTE= CREATE or REPLACE to save these commands in your own dataset
000001 simulate racf_access
000002 n type=RACF_ACCESS name=CTBYPRFD nodetailinherit required,
000003 st=",
000004 Access monitor records for Classes like DATASET, non-zero counts,,
000005 highest access lower than allowed" I=CTBYPROF,
000006 t="Unconditional permits and UACC, by class complex/profile"
000007 /* generated by CKRP3AMX */
000008 define count_suc(7,"Allowed",udec$abbr,bw,noprop)
000009             sum(access_count_suc)
000010 define count_vio(5,"Deny",udec$abbr,bw,noprop)
000011             sum(access_count_vio)
000012 define count_unk(5,"Unexp",udec$abbr,bw,noprop)
000013             sum(access_count_unk)
000014 define lastuse(7,"LastUse",noprop) max(access_lastuse)
000015 define firstuse(7,"Firstuse",noprop) min(access_lastuse)
000016 define helppanel=C2R3Z241,

```

Figure 6-9 Top part of the COMMANDS work data set

On the next page of the CARLa program (see Figure 6-10), you find the SELECT statement that generated the overview of the 32 DATASET class profiles. Each of these profiles includes at least one permission where the allowed access level exceeds what the permitted user IDs require.

```

EDIT          CRMBTZ1.CARLA.SAMPLES(@CRMBTZ1) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
000019 define helppanel=C2R3Z243,
000020         Miss#(7,"Missing",dec,noprop) count where
000021         (proftype="missing"C)
000022 define Pres#(8,"Permits",dec,noprop) count where
000023         (proftype<>"missing"C)
000024 define helppanel=C2R3Z242,
000025         Perm#(8,"Permits and UACC",dec,noprop) count
000026 select raclist_merge=no class<>group,
000027 proftype<>GLOBAL,class=DATASET,(access_count_suc>0 or,
000028 access_count_vio>0 or access_count_unk>0),,,
000029 access_intent_max_suc<<access)
000030 display id(nd),
000031         access_count_suc(7,key),
000032         access_count_vio(5,"Deny",key),
000033         access_count_unk(5,key),
000034         access_lastuse(7,key,"LastUse"),
000035         id(pas,key) access access_intent_max_suc("Used"),
000036         access_intent_min_vio access_reduced merged_access_reduced,
000037         id:name id:revoke(1) | id:revoke_inactive(1) " ",

```

Figure 6-10 Composed select statement that were generated in the COMMANDS work data

Your next task is to modify the CARLa script so that it generates RACF permit commands instead of a permit usage report. You can reuse the existing SELECT statement from your previous script as the foundation for this customization.

The updated CARLa script should automatically produce permit commands that reduce access levels to match the highest level that is used by each user. An example of such a customized script is shown in Figure 6-11.

```

EDIT          CRMBTZ1.CARLA.SAMPLES(@CRMBTZ1) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
000001 simulate racf_access
000002 n type=RACF_ACCESS nopage dd=ckrcmd
000003 select raclist_merge=no class=dataset access<>(QUALOWN,ALTER-0),
000004         access_intent_max_suc<>(DEFCREATE,DEFDELETE,DEFCHGVOL,DEFADDVOL),
000005         proftype<>GLOBAL (access_count_suc>0 or access_count_vio>0 or,
000006         access_count_unk>0) access_intent_max_suc<<access
000007 sortlist "pe '" | profile(0) | "'" class(dataset) generic id(" |,
000008         id(0) | ") ACCESS(" | access_intent_max_suc(0) | ")" / ,
000009         " /* Access level was" access(0) "*/"
***** ***** Bottom of Data *****

```

Figure 6-11 Customized CARLa script to produce RACF permit commands instead of the report

Here are the notes and explanations regarding the adjustments that were made to the original CARLa program in the COMMANDS work data set:

- ▶ The SIMULATE statement on line 1 remains unchanged.
- ▶ The NEWLIST statement on line 2 (abbreviated as n in the original script) was previously defined across lines 2 - 6. It was replaced with a single-line statement for simplicity and clarity.
 - The NOPAGE keyword is included to suppress page layout elements such as titles, column headers, and page numbers because the goal is to generate RACF permit commands, not a formatted report.
 - The DD=CKRCMD specification directs the output of the CARLa script to the CKRCMD work data set, which is the designated zSecure work data set that is used for running RACF commands.
- ▶ All original DEFINE statements from lines 8 - 25, which were used to produce counters and statistics in the permit usage report, are not needed for generating RACF permit commands. Therefore, these DEFINE statements were removed from the customized CARLa script.
- ▶ The revised SELECT statement was streamlined for clarity and efficiency:
 - Unnecessary commas and parentheses that were originally included to support all UI filters are removed because as they are not required in this CARLa script.
 - An extra filter, ACCESS<>(QUALOWN,ALTER-0), is added to exclude pseudo access levels (QUALOWN and ALTER-0) that represent access by the qualifier owner or through the OPERATIONS attribute. This filter prevents the generation of permit commands for these cases.
 - Another filter, access_intent_max_suc<>(DEFCREATE,DEFDELETE,DEFCHGVOL,DEFADDDVOL), is included to avoid generating permit commands for pseudo access levels that are associated with define-type access events.
 - All other filters remain consistent with the ones that were used in the original permit usage report.
- ▶ The DISPLAY statement is replaced with a SORTLIST statement that generates the appropriate permit commands automatically:
 - The specification “pe ' ” inserts the string pe ' into the RACF command that will be generated output in the CKRCMD work data set.
 - profile(0) generates the corresponding DATASET profile name after pe '. The (0) truncates trailing blanks from the profile name.
 - A vertical bar (|) suppresses the default space between adjacent columns in the SORTLIST output.
 - The specification " ' class(dataset) generic id(" generates the string ' class(dataset) generic id(after the profile name in the command.
 - ID(0) generates the permitted ID name.
 - The string ") ACCESS(" generates the literal) ACCESS(to the permit command.
 - The variable access_intent_max_suc(0) generates the highest access level that is used by the permitted ID, as reported by the Access Monitor permit command.

- The ")" specification generates the closing) and the slash (/) instructs CARLa to continue the output on the next line of the CKRCMD work data set.
- Finally, the string "/* Access level was" access(0) "*/" generates the CARLa comment /* Access level was <access level> */. This comment highlights the originally permitted access level for reviewers of the generated commands.

Tip: If you plan to use this CARLa script regularly, consider saving it in your CARLa samples library.

When you run the CARLa script by using the GO or RUN command, CARLa automatically opens the CKRCMD work data set. This dataset contains the generated permit commands that help implement the principle of least privilege for DATASET profiles on your system (see Figure 6-12).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          Columns 00001 00072
Command ==>          Scroll ==> CSR
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to execute commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001  /* CKRCMD file CKR1CMD complex TVT6003 generated 20 Nov 2024 12:29 */
000002 pe 'CATALOG.**' class(dataset) generic id(IDSTAR) ACCESS(READ)
000003      /* Access level was UPDATE */
000004 pe 'CKNSERVE.**' class(dataset) generic id(C2RSERVG) ACCESS(READ)
000005      /* Access level was UPDATE */
000006 pe 'CRMA.X.**' class(dataset) generic id(SYSPROG) ACCESS(READ)
000007      /* Access level was ALTER */
000008 pe 'CRMAUTO.**' class(dataset) generic id(SYSPROG) ACCESS(UPDATE)
000009      /* Access level was ALTER */
000010 pe 'CRMBJK1.*.**' class(dataset) generic id(CRMBVK1) ACCESS(READ)
000011      /* Access level was ALTER */
000012 pe 'CRMBJU1.**' class(dataset) generic id(CRMB) ACCESS(READ)
000013      /* Access level was UPDATE */
000014 pe 'CRMBJU1.LOADLIB' class(dataset) generic id(CRMB) ACCESS(READ)
000015      /* Access level was UPDATE */
000016 pe 'CSF.SCSFMODE' class(dataset) generic id(SYSPROG) ACCESS(READ)
000017      /* Access level was UPDATE */

```

Figure 6-12 Generating automated RACF permit commands to implement the least privilege principle

Important: Before you run these automatically generated commands, carefully review them to help ensure that they meet your system's requirements.

Verify that the generated permit access level is not a pseudo access level from a define-type access event, which RACF does not support for datasets. Valid access levels for datasets are UPDATE, CONTROL, and ALTER.

If you encounter other values, you can either adjust the access_intent_max_suc<> filters in your CARLa script and rerun it, or delete the corresponding permit command from the CKRCMD work data set before running the commands.

Double-check that the eye-catcher comment, which reports the original access level to be replaced, does not include any values that RACF does not support, such as QUALOWN, ALTER-0, or other pseudo access levels. Valid access levels for datasets are UPDATE, CONTROL, and ALTER.

If you find unsupported values, you can either adjust the ACCESS <> filters in your CARLa script and rerun it, or delete the corresponding permit command from the CKRCMD work data set before running the commands.

Also consider that for DATASET profiles, a specific job role typically acts as the custodian of the datasets. This custodian needs the authority to create, update, and delete the protected datasets. Even if the custodian did not use ALTER access in the past year, reducing that access might not be appropriate.

Before making changes, check whether the ID with ALTER access is the only one that is listed in the ACL. If so, it is best to leave the ALTER permission unchanged. However, if the HLQ of the DATASET profile matches a user ID, reducing ALTER access is likely acceptable. Using personal user datasets in a production environment is considered a poor practice.

In the example, the diagnostics review confirmed that ALTER permissions for group SYSPROG should not be reduced. The z/OS systems programmers serve as custodians of these datasets and require ALTER access in certain situations.

After removing the generated permit commands for ID SYSPROG from your CKRCMD work data set, you can run the remaining commands against your offline RACF database by entering the G0 or RUN command and pressing Enter (see Figure 6-13).

```

BROWSE      CRMBTZ1.DATA.C2R1DC6.CKRTSPRT                Line 0000000000 Col 001 080
Command ==> _____ Scroll ==> CSR
***** Top of Data *****
=====
=== Multiple TSO command output file - scroll max down for overview ===
=== Input data set CRMBTZ1.DATA.C2R1DC6.TEMP.CKRCMD                    ===
=====
=====
=== Commands for local node
=====
/* CKRCMD file CKR1CMD complex TVT6003 generated 13 Nov 2024 09:21 */

===== 13Nov24 09:42:57.04579 start record 2 =====
pe 'CATALOG.**' class(dataset) generic id(IDSTAR) ACCESS(READ)
/* Access level was UPDATE */

===== 13Nov24 09:42:57.05440 start record 4 =====
pe 'CKNSERVE.**' class(dataset) generic id(C2RSERVG) ACCESS(READ)
/* Access level was UPDATE */

===== 13Nov24 09:42:57.06144 start record 6 =====

```

Figure 6-13 Running CKRTSPRT permit commands to implement the least privilege principle

As usual, CARLa automatically opens the CKRTSPRT work data set, which displays the results of the ran permit commands. All commands were processed successfully. You can scroll to the bottom of the CKRTSPRT data set to see the confirmation message indicating that all commands completed without errors.

6.4.3 Verifying the permit commands for the DATASET class

In this section, you learn how to verify that the ran permit commands successfully improved the implementation of the least privilege principle for the DATASET class.

Press F3 a few times to exit ISPF, then terminate your RACF-Offline session by entering the end command. Next, start a regular TSO session by entering ISPF on the CLI and pressing Enter. This session uses the primary RACF database for access verification.

To confirm that your changes had the intended effect, start IBM zSecure Admin and ensure that your allocated input set includes the offline RACF database that you used when running the permit commands.

Then, use option AM.3 again to generate a report showing where DATASET profiles still allow higher access levels than what the permitted IDs use (see Figure 6-14).

```
zSecure Admin - Access - Permit usage
Command ==> _____

Show permits that fit all of the following criteria:
Permit id . . . . . _____ (permit id or EGN mask on access list)
Class . . . . . dataset (class or EGN mask)
RACF profile name . . . _____
Complex . . . . . _____ (complex or EGN mask)
Show accesses . . . . / Non-zero counts    _ Zero counts

    Profile to use 2 1. Use historic profile name in access summary if present
                     2. Simulate access in database to find current profile

Advanced selection criteria
/ Further selection          _ Date selection

Output/run options
_ Print format             Customize title      Send as e-mail
  Background run          Full page form
```

Figure 6-14 Reporting historic access to DATASET class resources against an offline RACF database

After you press Enter, the Further selection panel opens. On this panel, select the option Highest access used less than access allowed to identify cases where the least privilege principle might not be correctly implemented (see Figure 6-15 on page 145). Then, press Enter to continue.

```

zSecure Admin - Access - Further selec
Command ==> _____
Access monitor records for Classes like DATASET, non-zero counts
Access selection
#Accesses allowed . . . _ _
#Accesses prevented . . _ _
#Accesses unexplained _ _

Permit selection
Creation date from . . _ _ _ Until _ _ _

/ Highest access used less than access allowed

Access allowed      Highest access used      Lowest violation
>= _ 1. Execute      <= _ 1. Read      >= _ 1. Read
      2. Read          2. Update          2. Update
      3. Update        3. Control         3. Control
      4. Control       4. Alter           4. Alter
      5. Alter

```

Figure 6-15 Reporting historic DATASET access where the highest access used is less than access allowed

This selection generates a permit usage overview report for DATASET profiles that are used to access protected datasets. The report highlights cases where the permitted access level exceeds the highest access level that is used by the permitted IDs (see Figure 6-16).

```

Line 1 of 26
Unconditional permits and UACC, by class complex/profile
Command ==> _____ Scroll==> CSR
Access monitor records for Classes like DATASET 13 Nov 2024 12:17
  Allowed Deny Unexp LastUse Class Complex
  56232 248 0 31Oct24 DATASET TVT6003
  Allowed Deny Unexp LastUse Type Profile
  _ 1 0 0 25Oct24 GENERIC CKNSERVE.**
  _ 7 0 0 23Oct24 GENERIC CRMA.T.**
  _ 20710 0 0 31Oct24 GENERIC CRMA.X.**
  _ 6378 0 0 31Oct24 GENERIC CRMAUTO.**
  _ 1 0 0 12Sep24 GENERIC CRMBAH1.TEST12.**
  _ 187 0 0 5Dec23 GENERIC CRMBEP1.*.**
  _ 87 0 0 31Oct24 GENERIC CRMBJK1.*.**
  _ 4888 0 0 30Oct24 GENERIC CRMBMK1.*.**
  _ 2 0 0 13Sep24 GENERIC CRMBMK1.TE%T
  _ 30 0 0 22Mar24 GENERIC CRMBPH1.*.**
  _ 10 0 0 16Oct24 GENERIC CRMBRL1.*.**
  _ 162 0 0 16Sep24 GENERIC CRMBRS1.*.**
  _ 3344 0 0 31Oct24 GENERIC CRMBTZ1.*.**
  _ 1472 0 0 31Oct24 GENERIC CRMBVK1.*.**
  _ 58 0 0 16Oct24 GENERIC CRMBVK2.*.**
  _ 13 248 0 31Oct24 GENERIC CSF.SCSFMODE0
  _ 11597 0 0 31Oct24 GENERIC C2PACMON.*.**

```

Figure 6-16 Report DATASET profiles where permitted access exceeds used access

To review the details, enter S and press Enter, which opens the DATASET class profile, allowing you to identify which permissions might be candidates for tightening.

As illustrated, the permit usage report still reports 26 DATASET profiles with permissions that permit an access level that exceeds the used access level. However, when you zoom in to the profile details, you notice that the pseudo access levels such as QUALOWN and ALTER-0 are still included in this report.

As shown in the report, 26 DATASET profiles still have permissions that allow access levels that exceed what was used. However, when you examine the profile details, you notice that pseudo access levels such as QUALOWN and ALTER-0 are still included in the report.

To refine the results, press F3, enter the RESULT command on the CLI, and press Enter to open the Results panel. Then, enter S or E to access the COMMANDS work data set and press Enter. Scroll down by pressing F8, add the filter access<>(QUALOWN,ALTER-0) to the SELECT statement, and run the script again by entering the GO or RUN command (see Figure 6-17).

```

EDIT      CRMBTZ1.CARLA.SAMPLES(@CRMBTZ1) - 01.00      Columns 00001 00072
Command ==> GO                                         Scroll ==> CSR
000018  define auth#(5,"Auth",dec,bw,noprop)  count
000019  define helppanel=C2R3Z243,
000020      Miss#(7,"Missing",dec,noprop)  count where
000021      (proftype="missing"C)
000022  define Pres#(8,"Permits",dec,noprop) count where
000023      (proftype<>"missing"C)
000024  define helppanel=C2R3Z242,
000025      Perm#(8,"Permits and UACC",dec,noprop) count
000026  select raclist_merge=no class<>group access<>(QUALOWN,ALTER-0),
000027      proftype<>GLOBAL,class=DATASET,(access_count_suc>0 or,
000028      access_count_vio>0 or access_count_unk>0),,,
000029      access_intent_max_suc<<access)
000030  display id(nd),
000031      access_count_suc(7,key),
000032      access_count_vio(5,"Deny",key),
000033      access_count_unk(5,key),
000034      access_lastuse(7,key,"LastUse"),
000035      id(pas,key) access access_intent_max_suc("Used"),
000036      access_intent_min_vio access_reduced merged_access_reduced,
000037      id:name id:revoke(1) | id:revoke_inactive(1) " ",

```

Figure 6-17 Adjusting the CARLa script that the UI generated and rerunning the report

When you press Enter, CARLa runs your adjusted script and generates a customized version of the original permit usage report. This updated report focuses on DATASET class profiles with permissions that exceed the access levels that are used by the permitted IDs (see Figure 6-18 on page 147).

Line 1 of 11

```

Unconditional permits and UACC, by class complex/profile
Command ==> _____ Scroll==> CSR
,Access monitor records for Classes like DATASE 13 Nov 2024 12:29
  Allowed Deny  Unexp LastUse Class    Complex
    30548    248      0 310ct24 DATASET TVT6003
  Allowed Deny  Unexp LastUse Type      Profile
    7         0      0 230ct24 GENERIC CRMA.T.**
—   20710      0      0 310ct24 GENERIC CRMA.X.**
—   6378      0      0 310ct24 GENERIC CRMAUTO.**
—   13    248      0 310ct24 GENERIC CSF.SCSFMODE0
—   79       0      0 27Nov23 GENERIC C2RSRV#P.**
—   4        0      0 16Sep24 GENERIC SYS1.BROADCAST
—   1        0      0 2Nov23 GENERIC SYS1.DSDBCTRL
—   1        0      0 2Nov23 GENERIC SYS1.DSDB1
—   1        0      0 2Nov23 GENERIC SYS1.DSDB2
—   3        0      0 12Apr24 GENERIC SYS1.MAN*
—  3351      0      0 310ct24 GENERIC SYS1.TVT6003.**
***** Bottom of Data *****

```

Figure 6-18 Reporting the remaining DATASET profiles where permitted access exceeds used access

As shown in the updated report, only 11 DATASET profiles remain, which is a reduction from 32 in Figure 6-3 on page 134 and 26 in Figure 6-16 on page 145.

Why does the report still show 11 DATASET profiles with permitted access levels that exceed the access levels that are used? Recall that your earlier analysis identified the SYSPROG group as the custodian job role for several of the originally reported datasets. Based on that finding, you chose to remove the generated permit commands for SYSPROG from the CKRCMD work data set before running the commands.

If everything worked as expected, the remaining 11 DATASET profiles should reflect ALTER access permissions for ID SYSPROG, which are necessary for adding or deleting datasets in specific scenarios (see Figure 6-19). You can confirm this change by entering S to view the profile details.

Line 1 of 1

```

Unconditional permits and UACC, by class complex/profile
Command ==> _____ Scroll==> CSR
,Access monitor records for Classes like DATASE 13 Nov 2024 12:29
  Allowed Deny  Unexp LastUse Class    Complex
    30548    248      0 310ct24 DATASET TVT6003
  Allowed Deny  Unexp LastUse Type      Profile
    20710      0      0 310ct24 GENERIC CRMA.X.**
  Allowed Deny  Unexp LastUse Id      Access  Used  Failed  Red RdM Name
—   20710      0      0 310ct24 SYSPROG ALTER   READ           No
***** Bottom of Data *****

```

Figure 6-19 Report DATASET profiles where allowed access intentionally exceeds used access

If you are satisfied with the results, the next step is to run the same permit commands against the primary RACF database.

6.4.4 Running permit commands against the active primary RACF database

In this section, you learn how to run the permit commands to enforce the least privilege principle for the DATASET class against the active primary RACF database.

If you saved the CARLa script in Figure 6-11 on page 140, you can reuse it. To improve the script, consider adding the filter ID<>SYSPROG to the SELECT statement, which prevents the generation of permit commands for the group SYSPROG (see Figure 6-20).

```
EDIT          CRMBTZ1.CARLA.SAMPLES(@CRMBTZ1) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
000001 simulate racf_access
000002 n type=RACF_ACCESS nopage dd=ckrcmd
000003 select raclist_merge=no class=dataset access<>(QUALOWN,ALTER-0),
000004 proftype<>GLOBAL (access_count_suc>0 or access_count_vio>0 or,
000005 access_count_unk>0) access_intent_max_suc<<access ID<>SYSPROG
000006 sortlist "pe ' ' | profile(0) | ' ' class(dataset) generic id(' |,
000007             id(0) | ") ACCESS(" | access_intent_max_suc(0) | )" / ,
000008             " /* Access level was" access(0) "*/"
***** ***** Bottom of Data *****
```

Figure 6-20 Improved CARLa script to generate the appropriate permit commands

Before running the CARLa script, you must switch your selected input set in IBM zSecure. Use option SE.1 to choose an input set that includes a different RACF input source (specifically, your active primary RACF database) and your Access Monitor consolidation data set.

Running this version of the script generates the updated permit commands in the CKRCMD work data set (see Figure 6-21 on page 149).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to execute commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001  /* CKRCMD file CKR1CMD complex TVT6003 generated 13 Nov 2024 13:43 */
000002 pe 'CATALOG.**' class(dataset) generic id(IDSTAR) ACCESS(READ)
000003      /* Access level was UPDATE */
000004 pe 'CKNSERVE.**' class(dataset) generic id(C2RSERVG) ACCESS(READ)
000005      /* Access level was UPDATE */
000006 pe 'CRMBJK1.**' class(dataset) generic id(CRMBVK1) ACCESS(READ)
000007      /* Access level was ALTER */
000008 pe 'CRMBJU1.**' class(dataset) generic id(CRMB) ACCESS(READ)
000009      /* Access level was UPDATE */
000010 pe 'CRMBJU1.LOADLIB' class(dataset) generic id(CRMB) ACCESS(READ)
000011      /* Access level was UPDATE */
000012 pe 'SYSAPPL.**' class(dataset) generic id(CRMAUTO) ACCESS(UPDATE)
000013      /* Access level was ALTER */
000014 pe 'SYS1.**' class(dataset) generic id(CRMBVK9) ACCESS(READ)
000015      /* Access level was UPDATE */
000016 pe 'SYS1.**' class(dataset) generic id(SYS1) ACCESS(READ)

```

Figure 6-21 Regenerating automated RACF permit commands to implement the least privilege principle

You can run the commands against the primary RACF database by entering the GO or RUN command.

Alternatively, you can rerun the permit commands by using your RACF-Offline log data set. This dataset stores the RACF commands that ran during your last RACF-Offline session.

```

zSecure Admin – Results
Enter R to run commands

Command ==> _____

The following selections are supported:
B Browse file          S Default action (for each file)
E Edit file            R Run commands
P Print file           J Submit Job to execute commands
V View file            M E-mail report
W Write file into seq. or partitioned data set

Enter a selection in front of a highlighted line below:
- SYSPRINT  messages
- REPORT    printable reports
- CKRTSPRT  output from the last TSO commands
E CKRCMD    queued TSO commands
- CKR2PASS  queued commands for zSecure Admin
- COMMANDS  zSecure Admin input commands from last query
- SPFLIST   printable output from PRT primary command
- OPTIONS   set print options

```

Enter E (Edit) to open the CKRCMD data set, then press Enter (see Figure 6-23).

[illegible]

After you press Enter, a warning message appears (see Figure 6-24 on page 151).

```
EDIT - Confirm Copy
Command ==> _____

Dataset attributes are inconsistent. Truncation may result in the rightmost
portions of some "from" records if copy is performed.

"From" data set attributes:
  Dataset name . : CRMB.T.RACF.OFFLINE.B8RLOG
  Record format . : VARIABLE
  Record length . : 32,752

"Current" data set attributes:
  Dataset name . : CRMBTZ1.DATA.C2R1DC6.CKRCMD
  Record format . : FIXED
  Record length . : 80

Press ENTER key to copy with truncation.
Enter END command to cancel copy.
```

Figure 6-24 Truncation warning for copying RACF-Offline commands to the CKRCMD work data set

Because you know that none of the generated permit commands exceed 80 characters, you can press Enter to proceed with truncation.

However, instead of using the zSecure CKRCMD work data set, you might prefer to run these commands in the background by using a batch job. If so, use the data set CRMB.T.RACF.OFFLINE.B8RLOG as the input source.

After you press Enter, the logged commands are successfully copied from the RACF-Offline log data set CRMB.T.RACF.OFFLINE.B8RLOG to your CKRCMD work data set (see Figure 6-25).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
=NOTE= Enter GO or RUN to execute commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001 CKGRACF show myaccess
000002 PE 'CATALOG.**' class(dataset) generic id(IDSTAR) ACCESS(READ)
000003 PE 'CKNSERVE.**' class(dataset) generic id(C2RSERVG) ACCESS(READ)
000004 PE 'CRMBJK1.**' class(dataset) generic id(CRMBVK1) ACCESS(READ)
000005 PE 'CRMBJU1.**' class(dataset) generic id(CRMB) ACCESS(READ)
000006 PE 'CRMBJU1.LOADLIB' class(dataset) generic id(CRMB) ACCESS(READ)
000007 PE 'SYSAPPL.**' class(dataset) generic id(CRMAUTO) ACCESS(UPDATE)
000008 PE 'SYS1.**' class(dataset) generic id(CRMBVK9) ACCESS(READ)
000009 PE 'SYS1.**' class(dataset) generic id(SYS1) ACCESS(READ)
000010 PE 'SYS1.LOGREC' class(dataset) generic id(SYS1) ACCESS(UPDATE)
000011 PE 'SYS1.MAN*' class(dataset) generic id(SYS1) ACCESS(CONTROL)
000012 PE 'SYS1.TVT6003.**' class(dataset) generic id(OMVSGRP) ACCESS(READ)
000013 PE 'USER.**' class(dataset) generic id(CRMBEP1) ACCESS(READ)
000014 PE 'USER.**' class(dataset) generic id(CRMBGUS) ACCESS(READ)
000015 PE 'USER.**' class(dataset) generic id(CRMBMC1) ACCESS(READ)
000016 PE 'USER.**' class(dataset) generic id(CRMBPH1) ACCESS(READ)

```

Figure 6-25 RACF commands from the last RACF-Offline session copied to CKRCMD work data set

The command CKGRACF show myaccess on line 1 runs automatically when you start zSecure Admin in an ISPF environment. zSecure uses this command to verify which menu options and commands that you are authorized to use.

zSecure supports customizing both menu options and action commands based on user authorizations. Access to these functions is controlled by profiles with the prefix CKR.ACTION. in the XFACILIT class. However, most zSecure customers do not define CKR.ACTION.** profiles in the XFACILIT class.

It does not matter whether you delete the CKGRACF show myaccess command or leave it in when running the command set.

To run the commands against the active RACF database, enter the GO or RUN command.

This step concludes the walkthrough for implementing the least privilege principle for the DATASET class. However, because the permit command syntax differs for general resource classes, you need a slightly modified CARLa script to handle those resources.

6.4.5 Reporting permitted general resource access levels that exceed the used access levels

This section describes how to report historical successful general resource access when the allowed access level exceeds the used access level.

To do this task, use option AM.3 (Permit usage), but specify a class name other than DATASET, for example, FACILITY. Apply the same filters that you used for reporting access to the DATASET class.

This selection generates a permit usage report similar to the one that is shown in Figure 6-26.

Line 1 of 9

Unconditional permits and UACC, by class complex/profile

Command ==> _____ Scroll==> CSR

Access monitor records for Classes like FACILIT 13 Nov 2024 14:54

Allowed	Deny	Unexp	LastUse	Class	Complex
121151	0	0	31Oct24	FACILITY	TVT6003

Allowed	Deny	Unexp	LastUse	Type	Profile
118983	0	0	25Oct24	GENERIC	CSVAPF.**
245	0	0	12Sep24	GENERIC	CSVDYNEX.**
8	0	0	25Oct24	GENERIC	CSVDYNL.**
655	0	0	25Oct24	GENERIC	CSVLLA.**
330	0	0	31Oct24	DISCRETE	IRR.DIGTCERT.GENCERT
329	0	0	31Oct24	DISCRETE	IRR.DIGTCERT.LISTRING
396	0	0	29Oct24	GENERIC	STGADMIN.ADR.*
198	0	0	29Oct24	GENERIC	STGADMIN.ADR.STGADMIN.*
7	0	0	16Sep24	GENERIC	STGADMIN.IGG.*

***** Bottom of Data *****

Figure 6-26 Reporting FACILITY profiles where the allowed access exceeds the used access

When you zoom into a FACILITY profile level by using S (Select), the display reveals which permissions allow a higher access level than the permitted IDs used (see Figure 6-27).

Line 1 of 2									
Unconditional permits and UACC, by class complex/profile									
Command ==> _____ Scroll==> <u>CSR</u>									
Access monitor records for Classes like FACILIT 13 Nov 2024 14:54									
Allowed	Deny	Unexp	LastUse	Class	Complex				
121151	0	0	31Oct24	FACILITY	TVT6003				
Allowed	Deny	Unexp	LastUse	Type	Profile				
245	0	0	12Sep24	GENERIC	CSVDYNEX.**				
Allowed	Deny	Unexp	LastUse	Id	Access	Used	Failed	Red	RdM Name
222	0	0	12Sep24	CRMBZDEV	ALTER	UPDATE		No	
23	0	0	30May24	SYSPROG	ALTER	UPDATE		No	
***** Bottom of Data *****									

Figure 6-27 Reporting FACILITY profiles where the permitted access exceeds the used access

In this example, two permissions grant ALTER access to the CRMBZDEV and SYSPROG IDs. However, according to Access Monitor data, their highest access level that was used in the past year was UPDATE. These permissions are strong candidates for reduction to support a least privilege implementation.

Unlike the DATASET class, general resource classes include profiles that do not protect physical resources such as programs, terminals, consoles, transactions, or other resource types. Instead, some general resource profiles use access checks to control the use of specific functions or features within an application or subsystem, without securing a physical resource.

For example:

- ▶ The FACILITY class profile BPX.SUPERUSER controls which users are authorized in UNIX System Services to switch to UNIX superuser mode (UID(0)).
- ▶ The UNIXPRIV class profile SHARED.IDS determines which RACF administrators can assign a shared UID value to multiple users.
- ▶ Many other profiles in various general resource classes serve similar purposes.

For resource profiles that do not protect a physical resource, the concept of a custodian does not apply. In these cases, it is acceptable for the ACL to exclude any permissions with the ALTER access level.

To exit the report displaying the FACILITY class profiles, press F3 twice. Then, enter the result command on the CLI and press Enter to open the zSecure Results panel.

To support least privilege implementation across all general resource classes, create a CARLa script that automatically generates permit commands.

Scroll down by pressing F8 to review the composed SELECT statement (see Figure 6-28).

```

EDIT      CRMBTZ1.CARLA.SAMPLES(@CRMBTZ1) - 01.00      Columns 00001 00072
Command ===>                                         Scroll ===> CSR
000020      Miss#(7,"Missing",dec,noprop) count where
000021              (proftype="missing"C)
000022  define Pres#(8,"Permits",dec,noprop) count where
000023              (proftype<>"missing"C)
000024  define helppanel=C2R3Z242,
000025      Perm#(8,"Permits and UACC",dec,noprop) count
000026  select raclist_merge=no class<>group,
000027      proftype<>GLOBAL,class=FACILITY,(access_count_suc>0 or,
000028      access_count_vio>0 or access_count_unk>0),,,
000029      access_intent_max_suc<<access)
000030  display id(nd),
000031      access_count_suc(7,key),
000032      access_count_vio(5,"Deny",key),
000033      access_count_unk(5,key),
000034      access_lastuse(7,key,"LastUse"),
000035      id(pas,key) access access_intent_max_suc("Used"),
000036      access_intent_min_vio access_reduced merged_access_reduced,
000037      id:name id:revoke(1) | id:revoke_inactive(1) " ",
000038      id:dfltgrp id:instdata,
000039  / "Profile in current database"(d,ch),

```

Figure 6-28 Composed select statement that is generated in the COMMANDS work data set

As with the DATASET class, you can use the composed SELECT statement in your customized CARLa script to generate permit commands that enforce the least privilege principle for general resource class profiles in your system.

By applying the same logic that is used for the DATASET class, you can adjust the CARLa script to produce permit commands for all general resource class profiles where the permitted access level exceeds the used access level (see Figure 6-29).

```

EDIT          CRMBTZ1.CARLA.SAMPLES(@CRMBTZ1) - 01.00          Columns 00001 00072
Command ==> _____ Scroll ==> CSR
***** ***** Top of Data *****
000001 simulate racf_access
000002 n type=RACF_ACCESS nopage dd=ckrcmd
000003 select raclist_merge=no class<>(dataset,group) access<>ALTER-0,
000004 proftype<>GLOBAL (access_count_suc>0 or access_count_vio>0 or,
000005 access_count_unk>0) (access_intent_max_suc<=access)
000006 sortlist 'pe' profile(0) 'class(' | class(0) | ')' id(' | id(0) | ')',
000007          'ACCESS(' | access_intent_max_suc(0) | ')' / ,
000008          '          /* Access level was' access(0) '*/'
***** ***** Bottom of Data *****

```

Figure 6-29 Customized CARLa script to produce permit commands for general resource classes

Consider the following items:

- Lines 1 and 2 remain unchanged from the CARLa script that was used for the DATASET class.
- In the SELECT statement (lines 3 - 5), the following changes are applied:
 - The class<>group filter is updated to class<>(dataset,group) to exclude both DATASET and GROUP class profiles.
 - The access<>ALTER-0 filter is added to prevent generating permit commands to replace pseudo access levels in general resource classes that acknowledge the OPERATIONS attribute and allow ALTER access.
 - The class=FACILITY filter is removed to allow the script to generate permit commands for all applicable general resource class profiles.

To run your customized CARLa script, enter the GO or RUN command and press Enter (see Figure 6-30).

```

EDIT          CRMBTZ1.DATA.C2R1DC6.CKRCMD          0.2 s CPU, RC=4
Command ==> _____ Scroll ==> CSR
***** Top of Data *****
=NOTE= Enter GO or RUN to execute commands, SUB or SUBMIT to generate batch job
=NOTE= You can also press PF3, enter R at the cursor location, and press ENTER.
000001 /* CKRCMD file CKR1CMD complex TVT6003 generated 13 Nov 2024 17:33 */
000002 pe ** class(TSOPROC) id(SYSPROG) ACCESS(READ )
000003 /* Access level was ALTER */
000004 pe B8R.RACF.OFFLINE class(XFACILIT) id(CRMBQA) ACCESS(READ )
000005 /* Access level was UPDATE */
000006 pe B8R.RACFDB.** class(XFACILIT) id(CRMBQA) ACCESS(UPDATE )
000007 /* Access level was CONTROL */
000008 pe B8R.RACFDB.** class(XFACILIT) id(CRMBZDEV) ACCESS(UPDATE )
000009 /* Access level was CONTROL */
000010 pe B8R.RACFDB.** class(XFACILIT) id(SYSPROG) ACCESS(UPDATE )
000011 /* Access level was CONTROL */
000012 pe CKG.CMD.FIELD.* class(XFACILIT) id(CRMBLU1) ACCESS(READ )
000013 /* Access level was UPDATE */
000014 pe CKG.CMD.FIELD.* class(XFACILIT) id(SYSPROG) ACCESS(READ )
000015 /* Access level was UPDATE */
000016 pe CKG.CMD.FIELD.PWDX class(XFACILIT) id(CRMBLU1) ACCESS(READ )

```

Figure 6-30 Generating automated RACF permit commands to implement the least privilege principle

The appropriate RACF permit commands, which reduce permitted access levels based on evidence from Access Monitor records, are successfully generated in the CKRCMD work data set.

Important: Always review all generated commands carefully. If any commands appear unexpected, perform more inquiries to verify their accuracy.

For general resource profiles that protect a physical resource, do not remove ALTER access from the custodian, even if Access Monitor records show that ALTER access was not used in the past year.

After completing your review and removing any commands that should not run, run the remaining commands against the offline RACF database. Use the GO or RUN command to run them in the foreground, or use SUB or SUBMIT to run them as a background batch job.

Next steps:

- ▶ Verify that the permit commands that ran successfully implemented the least privilege principle for general resource classes. Follow the same verification steps that are documented for the DATASET class in 6.4.4, “Running permit commands against the active primary RACF database” on page 148.
- ▶ After verification, run the same permit commands against the active primary RACF database to apply the changes in the live environment.

Abbreviations and acronyms

ACF2	Access Control Facility 2
ACL	access control list
CACL	conditional ACL
CARLa	CARLa Auditing and Reporting Language
CDT	class descriptor table
DFLTRC	default return code
ESM	external security manager
GAC	global access checking
GAT	global access table
HLQ	high-level qualifier
IBM	International Business Machines Corporation
NJE	Network Job Entry
RACF	Resource Access Control Facility
RBAC	role-based access control
RJE	Remote Job Entry
SAF	System Authorization Facility
SMF	System Management Facilities
UACC	universal access
UI	user interface



SG24-8578-00

ISBN 0738462136

Printed in U.S.A.

Get connected

